



National Security Agency
Cybersecurity Technical Report

Zero Trust Implementation Guideline

Discovery Phase

January 2026

U/OO/103058-26
PP-25-3989
Version 1.0



Notices and history

Document change history

Date	Version	Description
January 2026	1.0	Initial publication

Disclaimer of endorsement

The information and opinions contained in this document are provided "as is" and without any warranties or guarantees. Reference herein to any specific commercial products, process, or service by trade name, trademark, manufacturer, or otherwise, does not constitute or imply its endorsement, recommendation, or favoring by the United States Government, and this guidance shall not be used for advertising or product endorsement purposes.

Purpose

This document was developed in furtherance of NSA's cybersecurity missions, including its responsibilities to identify and disseminate threats, and to develop and issue cybersecurity specifications and mitigations for National Security Systems, Department of War information systems, and the Defense Industrial Base. This information may be shared broadly to reach all appropriate stakeholders.

Acknowledgements

The National Security Agency (NSA) acknowledges the valuable contribution and support of the Department of War (DoW) Chief Information Officer Zero Trust (ZT) Portfolio Management Office (PfMO) on this endeavor.

Author(s)

National Security Agency (NSA)
Cybersecurity Directorate

Contact information

Cybersecurity Report Feedback: CybersecurityReports@nsa.gov
Defense Industrial Base Inquiries and Cybersecurity Services: DIB_Defense@cyber.nsa.gov
Media Inquiries / Press Desk: NSA Media Relations: 443-634-0721, MediaRelations@nsa.gov
Department of War (DoW) Chief Information Office (CIO) Zero Trust (ZT) Portfolio Management Office (PfMO): osd.zt-pfmo@mail.mil



Executive Summary

Zero Trust (ZT) represents a fundamental enhancement in cybersecurity. Rather than relying on perimeter defenses, ZT emphasizes continuous authentication and authorization of every User/Person Entity (PE), device/Non-Person Entity (NPE), and application, operating under the principles of “never trust, always verify” and “assume breach.” This approach is critical for safeguarding sensitive data, systems, and services against increasingly sophisticated cyber threats.

As mandated by Executive Order (EO) 14028, the United States Government (USG) developed several ZT strategies to achieve ZT. These strategies include frameworks, guidelines, and maturity models designed to assist organizations in implementing ZT. Key foundational documents outlining architecture, maturity models, and guidance supporting this effort include:

- National Institute of Standards and Technology (NIST), Zero Trust Architecture Special Publication (SP) 800-207, August 2020
- The Cybersecurity and Infrastructure Security Agency (CISA) Zero Trust Maturity Model, Version 2.0, January 2022
- The Department of War¹ (DoW) Zero Trust Reference Architecture (ZT RA), Version 2.0, July 2022
- The DoW Zero Trust Strategy, Version 1.0, October 2022

The National Security Agency (NSA), using its Cybersecurity Authorities and role as National Manager (NM) for U.S. National Security Systems (NSS), developed the Zero Trust Implementation Guidelines (ZIGs), leveraging NIST and DoW published guidance. The ZIGs are intended to assist the DoW, Defense Industrial Base (DIB), NSS, and affiliated organizations with incorporating ZT principles into their processes, enabling them to achieve Target-level ZT, as described in the DoW ZT Framework from the DoW ZT Strategy.

In close partnership with the DoW CIO, and in an effort to organize the 152 ZT Activities contained within the DoW ZT Strategy, five phases were developed (Discovery, Phase One and Phase Two, which are Target-level, and Phase Three and Phase Four, which are Advanced-level). These phases are not doctrinal but are a structured approach to organize the ZT Activities. ZT is a framework; therefore in keeping with that model, the

¹ Per EO 14347, the Department of War (DoW) is an authorized secondary title for the Department of Defense (DoD).



phases outlined in the ZIGs are modular and can be aligned to an organization’s specific environment.

The current set of ZIGs consist of a [Primer](#) and three ZT Implementation Guidelines (Discovery, Phase One, and Phase Two) designed to assist skilled practitioners in adopting and integrating ZT Target-level Capabilities (42) and Target-level Activities (91). ZIGs for Phase Three and Phase Four may be developed at a later time. These guidelines provide a modular structure adhering to the DoW ZT Framework’s Pillars, Capabilities, and Activities, as well as NIST SP 800-207, as guidance for implementation.

The ZIGs align with the DoW Target-level phased implementation approach, with this ZIG (Discovery Phase) covering the 14 Activities that support the 13 Capabilities in the Discovery Phase. The purpose of the Activities within the Discovery Phase ZIG is to collect information about the Component environment(s), such as Data, Applications, Assets, and Services (DAAS), Users/PEs/NPEs, etc. [1]. The remaining Target-level Activities and Capabilities are addressed in other ZIGs (Phase One and Phase Two), as applicable.

The ZIGs are intended to assist DoW and NSS communities in implementing ZT concepts to achieve Target-level, as described in the DoW ZT Framework.

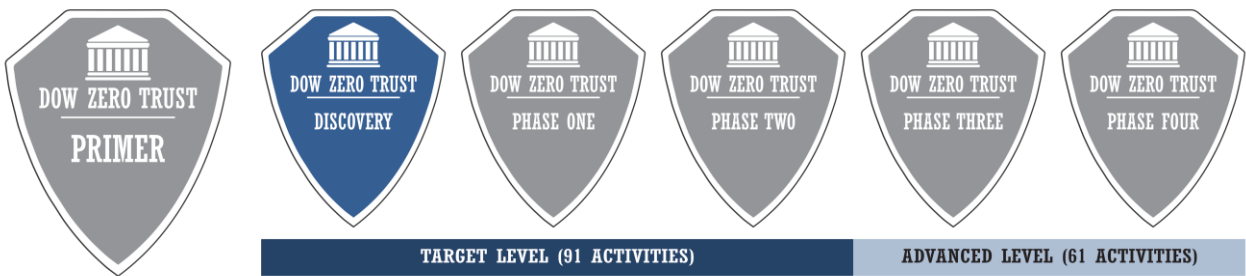


Figure 1: Zero Trust Implementation Guidelines (ZIGs)



Contents

Zero Trust Implementation Guideline Discovery Phase..... i

Executive Summary ii

Background 1

 Adopt a Zero Trust Mindset..... 1

 Zero Trust Design Concepts 2

Purpose..... 4

Target Audience 5

Scope 5

Assumptions 6

ZIG Design Methodology 7

ZIG Structure 7

 Pillars 7

 Capabilities 8

 Activities..... 9

 Considerations..... 11

 Implementation 11

 Summary 11

 Appendices 12

User Pillar 13

 Capability 1.1 User Inventory 13

 Scenario 13

 Positive Impacts 14

 Technology 15

 Activity 1.1.1 Inventory User 16

 Considerations..... 16

 Implementation 17

 Summary 20

Device Pillar..... 21

 Capability 2.1 Device Inventory..... 21

 Scenario 21

 Positive Impacts 22

 Technology 22

 Activity 2.1.1 Device Health Tool Gap Analysis 23

 Considerations..... 23

 Implementation 23

 Summary 26

 Capability 2.3 Device Authorization with Real-Time Inspection 27

 Scenario 27



- Positive Impacts 28
- Technology 29
- Activity 2.3.4 Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C) 30
 - Considerations..... 30
 - Implementation 31
 - Summary 34
- Application and Workload Pillar 35**
 - Capability 3.1 Application Inventory 35
 - Scenario 35
 - Positive Impacts 36
 - Technology 36
 - Activity 3.1.1 Application and Code Identification..... 37
 - Considerations..... 37
 - Implementation 37
 - Summary 40
- Data Pillar..... 41**
 - Capability 4.1 Data Catalog Risk Alignment..... 41
 - Scenario 41
 - Positive Impacts 42
 - Technology 43
 - Activity 4.1.1 Data Analysis..... 44
 - Considerations..... 44
 - Implementation 44
 - Summary 48
 - Capability 4.4 Data Monitoring and Sensing 49
 - Scenario 49
 - Positive Impacts 50
 - Technology 50
 - Activity 4.4.1 Data Loss Prevention (DLP) Enforcement Point Logging and Analysis 51
 - Considerations..... 51
 - Implementation 52
 - Summary 56
 - Activity 4.4.2 Data Rights Management (DRM) Enforcement Point Logging and Analysis..... 57
 - Considerations..... 57
 - Implementation 58
 - Summary 62
- Network and Environment Pillar 63**
 - Capability 5.1 Data Flow Mapping 63
 - Scenario 63



Positive Impacts	64
Technology	65
Activity 5.1.1 Define Granular Control Access Rules and Policies Part 1.....	66
Considerations.....	66
Implementation	67
Summary	70
Capability 5.2 Software-Defined Networking (SDN)	71
Scenario	71
Positive Impacts	72
Technology	73
Activity 5.2.1 Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)	74
Considerations.....	74
Implementation	75
Summary	77
Automation and Orchestration Pillar	78
Capability 6.1 Policy Decision Point (PDP) and Policy Orchestration	78
Scenario	78
Positive Impacts	79
Technology	80
Activity 6.1.1 Policy Inventory and Development	81
Considerations.....	81
Implementation	81
Summary	84
Capability 6.2 Critical Process Automation	85
Scenario	85
Positive Impacts	86
Technology	86
Activity 6.2.1 Task Automation Analysis.....	87
Considerations.....	87
Implementation	87
Summary	90
Capability 6.5 Security Orchestration, Automation, and Response (SOAR)	91
Scenario	91
Positive Impacts	92
Technology	92
Activity 6.5.1 Response Automation Analysis	93
Considerations.....	93
Implementation	93
Summary	95
Capability 6.6 Application Programming Interface (API) Standardization.....	96



Scenario 96

Positive Impacts 97

Technology 98

Activity 6.6.1 Tool Compliance Analysis..... 99

 Considerations..... 99

 Implementation 99

 Summary 101

Visibility and Analytics Pillar 102

 Capability 7.1 Log All Traffic (Network, Data, Apps, Users) 102

 Scenario 102

 Positive Impacts 103

 Technology 104

 Activity 7.1.1 Scale Considerations 105

 Considerations..... 105

 Implementation 105

 Summary 108

Appendix A – Terms and Definitions..... A-1

Appendix B – Abbreviations and Acronyms..... B-1

Appendix C – References C-1

Appendix D – Activity Task Diagrams D-1

 Activity 1.1.1 Inventory User D-3

 Activity 2.1.1 Device Health Tool Gap Analysis D-4

 Activity 2.3.4 Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C) D-5

 Activity 3.1.1 Application and Code Identification..... D-6

 Activity 4.1.1 Data Analysis..... D-7

 Activity 4.4.1 Data Loss Prevention (DLP) Enforcement Point Logging and Analysis D-8

 Activity 4.4.2 Data Rights Management (DRM) Enforcement Point Logging and Analysis..... D-9

 Activity 5.1.1 Define Granular Control Access Rules and Policies Part 1..... D-10

 Activity 5.2.1 Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs) D-11

 Activity 6.1.1 Policy Inventory and Development D-12

 Activity 6.2.1 Task Automation Analysis..... D-13

 Activity 6.5.1 Response Automation Analysis D-14

 Activity 6.6.1 Tool Compliance Analysis..... D-15

 Activity 7.1.1 Scale Considerations D-16



Background

EO 14028, *Improving the Nation's Cybersecurity*, mandates USG agencies to adopt a Zero Trust Architecture (ZTA). Specifically, for NSS networks, National Security Memorandum 8 (NSM-8), *Improving the Cybersecurity of National Security, Department of Defense and Intelligence Community Systems*, implements those cybersecurity requirements mandated by EO 14028. NSM-8 focuses on requirements for NSS as they are defined in 44 U.S.C. § 3552(b)(6), as well as all other DoW and Intelligence Community systems, as described in 44 U.S.C. § 3553(e)(2) and 3553(e)(3). These directives aim to modernize the nation's cybersecurity posture in response to evolving threats by strengthening digital infrastructure, addressing critical vulnerabilities, bolstering cybersecurity practices, and fostering collaboration between the public and private sectors.

A ZT mindset assumes that all environment traffic, users, devices, and infrastructure may be compromised, necessitating a rigorous authentication and authorization process for all access requests. Implementing these measures enhances the security posture of federal networks by rigorously validating every access request, which prevents unauthorized changes, reduces risk of malicious code insertion, and ensures the integrity of software and supply chains, ultimately strengthening the overall cybersecurity of the United States.

Adopt a Zero Trust Mindset

Adopting a ZT mindset involves fundamentally reassessing and rethinking how cybersecurity is approached within an organization. It augments traditional perimeter-based security models, creating a more dynamic approach that assumes no entity can be trusted by default, regardless of its location, inside or outside the environment.

To effectively address the modern dynamic threat environment, organizations should:

- Implement coordinated and comprehensive system monitoring, management, and defensive operations for continuous protection.
- Continuously verify and validate all resource requests and environment traffic.
- Continuously verify and validate the security posture of all devices and infrastructure.
- Prepare for rapid response and recovery, acknowledging the inherent risk incurred in all access approvals and authorizations to critical resources.



NSA | Zero Trust Implementation Guideline Discovery Phase

The guiding principles of ZT, outlined in NIST SP 800-207, are the core of a ZTA:

- **Never trust, always verify** – Treat every User/PE/NPE, device, application/workload, and data flow as untrusted. Dynamically authenticate and explicitly approve all activity, adhering to the principle of Least Privilege.
- **Assume breach** – Operate and defend resources under the assumption that an adversary already has presence within the environment. Plan for deny-by-default and heavily scrutinize all users, devices, data flows, and requests. Continuously log, inspect, and monitor all configuration changes, resource accesses, and environment traffic for suspicious activity.
- **Verify explicitly** – Securely and consistently verify access to all resources, using multiple attributes (dynamic and static), to derive confidence levels for contextual access decisions.

Zero Trust Design Concepts

The following are key concepts to address when designing a ZTA:

- **Define mission outcomes** – Derive the ZTA from organization-specific mission requirements that identify the critical DAAS.
- **Architect from the inside out** – First, focus on protecting critical DAAS. Second, secure all paths to access DAAS.
- **Determine who/what needs access to the DAAS to create Access Control policies** – Create security policies and apply them consistently across all environments (e.g., Local Area Network (LAN), Wide Area Network (WAN), endpoint, perimeter, mobile, etc.).
- **Inspect and log all traffic before acting** – Establish comprehensive, complete visibility of all activities across all layers, from endpoints to the environment, to enable analytics that can detect, trace, and make sense of suspicious activity.

ZT is more than an Information Technology (IT) solution; it is a holistic cybersecurity approach. While ZT may leverage technologies or specific products, it is not a singular capability or device. Adopting ZT is a journey that requires integrating capabilities, technologies, solutions, processes, and enablers. This journey necessitates the involvement of stakeholders to ensure alignment and buy-in, a prioritization scheme to focus resources effectively, and a continuous feedback loop for ongoing improvement and adaptation. In support of this holistic cybersecurity approach, the DoW ZT Strategy



NSA | Zero Trust Implementation Guideline Discovery Phase

outlines four (4) high-level strategic goals for achieving ZT applicable to any Component or Enterprise [2]. The goals are:

- ZT cultural adoption
- Secured and defended information systems
- Technology acceleration
- ZT enablement

These goals encompass supporting functions that drive the successful implementation of ZT and address the enablers and governance to support a successful ZTA. The supporting functions included in the DoW ZT Strategy are discussed throughout the ZIGs, with the exception of policy and training, which are outside the scope of the ZIGs and only discussed briefly here.

- **Policy:** Policies are necessary to ensure the DoW ZT Framework is uniformly applied and fully interoperable across the Enterprise. Enterprise-level processes, policies, and resources may need to be developed, redefined, and synchronized across the applicable Components with ZT principles and approaches.
- **Training:** An Enterprise-wide ZT mindset is essential. It guides the design, development, integration, and deployment of IT across the Enterprise and requires a culture where all personnel are aware of, understand, commit to, and are trained to embrace ZT. A training model should be developed that analyzes the skills needed by the Enterprise to accomplish the mission and/or business needs. Adequate training is fundamental to the ZT process and should address various training needs, including:
 - Awareness Training – Incorporate ZT concepts into ongoing security and privacy literacy training. This training should cover core ZT principles, benefits, and practical implications for daily work.
 - Role-Based Training – Identify the specific roles requiring ZT role-based training. This training, tailored for the assigned duties, may be technical or managerial.
 - Developer Provided Training –Require any system developers, system components, or system services within the environment to provide training on the proper use and operation of the implemented security functions or mechanisms to ensure ZT principles are maintained during operational use.



Purpose

The purpose of this Discovery Phase ZIG document is to provide an overview and linkage to the overarching guidance provided by the DoW, CISA, and NIST for achieving a ZTA at the Target-level, exclusively for the defined Discovery Phase Activities and Capabilities. The Discovery Phase ZIG provides direction and guidance, which outlines the steps to implement the technologies and processes that will enable the Target-level ZT Capabilities, Activities, and Expected Outcomes defined by the DoW ZT Framework.

The purpose of the Activities within the Discovery Phase ZIG is to collect information about the organization's environment(s), such as DAAS, Users/PEs/NPEs, etc. [1]. The following ZIG, Phase One Activities, builds upon or further refines the Component environment(s) to establish a secure foundation that supports ZT Capabilities. Finally, in the Phase Two ZIG, Activities mark the beginning of integrating distinct ZT fundamental solutions within the Component environment. Figure 2 depicts the DoW ZT Framework alignment to the ZIGs by ZT Phase (Discovery, Phase One, Phase Two, Phase Three, Phase Four), Level (Target, Advanced), and the associated Capabilities and Activities included in each document. While the DoW ZT Framework used for the ZIGs may not perfectly align with previous NSA Zero Trust Cybersecurity Information Sheet (CSI) publications, the general principles are consistent. NSA is aware of this and plans to update the CSIs in 2026 to better align with the Zero Trust Implementation Guidelines (ZIGs).

ZIGs addressing the Advanced Levels, Phase Three and Phase Four, may be developed at a later date.

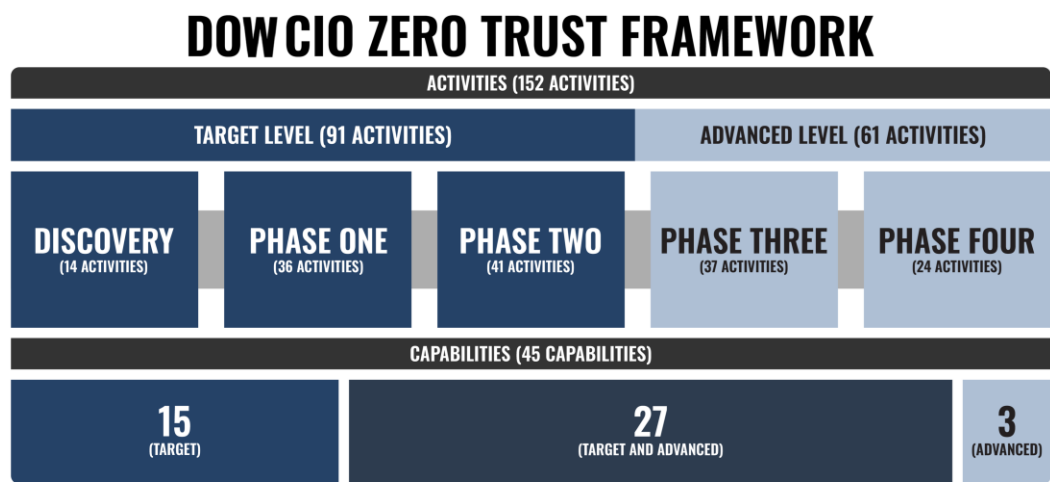


Figure 2: ZIG Alignment to the DoW ZT Framework

Target Audience

This document is designed to be used by skilled practitioners, individuals, stakeholders, and teams responsible for implementing ZT technical and strategic aspects. It may be used within the DoW, DIB, NSS, industry, academia, and affiliated organizations. The target audience includes the following:

- **Technical Implementers/Skilled Practitioners** – Practitioners managing the technical implementation of ZT enabling technologies and configurations.
- **Enterprise Environment Owners** – Stakeholders responsible for maintaining and securing large-scale IT infrastructures.
- **Cybersecurity Leaders** – Professionals tasked with designing, overseeing, and optimizing cybersecurity measures.
- **External Partners and Vendors** – Collaborators providing technologies, services, and/or expertise to support ZT efforts.

Scope

The Discovery Phase ZIG is designed to guide and support organizations within various environments by providing practical, actionable recommendations to facilitate ZT implementation.



In alignment with the current DoW ZT Framework, the ZIGs are most applicable in an IT Enterprise. Future updates may address other contextual environments, including Operational Technology (OT), Defense Critical Infrastructure (DCI), and/or Tactical/Weapons Systems. The ZIGs will continue to be modified as capabilities and technologies advance.

The Primer and associated ZIGs are **not**:

- Prescriptive or mandatory. Organizations should identify their starting points and tailor the Capabilities and Activities to their specific needs.
- A one-size-fits-all or step-by-step sequential guide to implementing ZT.
- Vendor-specific. Technologies listed in the Capabilities sections are included for consideration, may not contain all possible technologies, and are vendor agnostic.
- Designed to supersede, impact, or alter any existing authority, law, or policy.

Assumptions

The following assumptions drive the Primer and associated ZIGs:

- The ZIGs are not designed or intended to have a fixed implementation start or end point. Organizations have the flexibility to choose their starting point and tailor the guidance to their specific environment.
- Activities can be implemented concurrently.
- Readers have a foundational understanding of cybersecurity architectures, principles, and their organization's Critical Infrastructure and Key Resources (CIKR).
- Readers possess technical expertise in areas, such as Identity and Access Management (IAM), endpoint security, network security, and security analytics.
- Implementing organizations are familiar with ZT, their architecture, and the DoW ZT Framework.
- Personnel have the necessary skills and training to implement Software-Defined Networking (SDN), Development, Security, and Operations (DevSecOps) practices, Artificial Intelligence (AI)/Machine Learning (ML) solutions, data protection capabilities, and security orchestration, including Automation and Orchestration (A&O) and Continuous Integration/Continuous Delivery (or Deployment) (CI/CD) pipelines. This includes the ability to leverage cloud-based



solutions (e.g., Platform as a Service (PaaS)/Software as a Service (SaaS)/Infrastructure as a Service (IaaS)/Anything as a Service (XaaS), etc.) for ZT implementations.

- Future ZIGs will address the ZT Advanced-level and subsequent Phases (Phases Three and Four).

ZIG Design Methodology

This Discovery Phase ZIG refines the guidance that the DoW ZT Framework provides for ZTA implementation. It closely follows the DoW ZT Framework's structure beginning at the Pillar level. The DoW ZT Framework defined Capabilities and associated Activities are further broken down into the implementation process for each Activity.

The ZIG methodology focuses on the framework's Activity Level as the lowest-level element, guiding skilled practitioners in building and tailoring their implementation approach. Each Activity is structured into discrete tasks that are further decomposed into recommended processes and actions to meet the Activity's intent.

The DoW ZT Framework uses Pillars and Capabilities to define the "What" and "Why" of implementing a ZTA. The Activities describe the "Why" and the "How" to achieve these goals.

The ZIGs are intentionally designed with some duplication to ensure that each Capability and Activity can function as a standalone reference. Acronyms are consistently spelled out across sections to promote clarity and modularity. Activity names are italicized throughout the document to enhance visibility and ease of identification.

ZIG Structure

The ZIGs are structured as follows:

Pillars

This section introduces each Pillar pertaining to the Discovery Phase of the DoW ZT Framework. The ZT Pillars provide a framework for securing modern IT systems by emphasizing continuous verification, validation, strict access controls, and data protection. Figure 3 shows a graphical description of the DoW ZT Pillars.

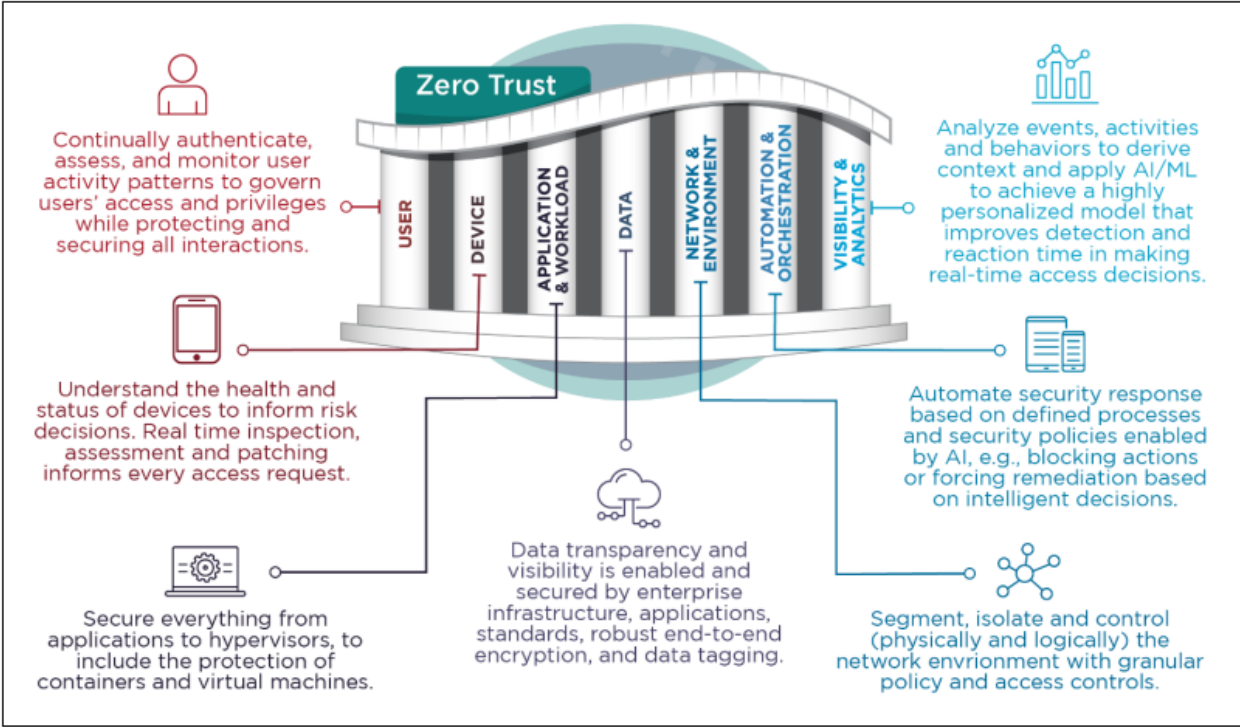


Figure 3: Description of the DoW Zero Trust Pillars

For additional information, see the DoW ZT Framework documents published on the DoW CIO Library, including the Zero Trust Capabilities and Activities, the DoW Zero Trust Strategy, NSA Zero Trust Cybersecurity Information Sheets (CSIs) and the ZT RA [1-11].

Capabilities

This section introduces each Discovery Phase Capability associated with the DoW ZT Framework. The Capability section precedes the associated Activities and describes each ZT Capability as defined by the DoW. It begins with a table similar to Figure 4, which maps to the applicable Pillar and the Capability description. The Pillar and the Capability descriptions shown in Figure 4 are taken from DoW CIO guidance, specifically, the DoW Zero Trust Execution Road Map v 1.1 Data Tables [15]. They are included verbatim, without any changes.



DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
1 - User	1.1 - User Inventory
Description	
Regular and Privileged users are identified and integrated into an inventory supporting regular modifications. Applications, software and services that have local users are all part of the inventory and highlighted.	
Impact to ZT	
Users not on the authorized user list will be denied access by policy.	

Figure 4: Sample Capability Table

Following the Capability table are the Scenario, Positive Impacts, and Technology subsections, which relate to the Capability. The Scenario subsection illustrates practical applications, highlighting how the technologies underpinning each Capability can address specific challenges or opportunities. These scenarios are not comprehensive, nor do they serve to assess a system’s ZT implementation. They provide examples of practical applications and considerations, helping stakeholders understand the value and impact of adopting a Capability. This approach supports informed decision-making and aligns the Capability with organizational objectives.

The Positive Impacts subsection provides examples of potential benefits an organization may derive from implementing the Capability.

The Technology subsection includes a representative list of technologies that enable the Capability and is not an all-inclusive list of technologies that an organization could consider.

For additional information, see the DoW ZT Framework documents published on the DoW CIO Library, including the Zero Trust Capabilities and Activities, the DoW Zero Trust Strategy, and the ZT RA [1-3].

Activities

This section introduces the Activities associated with the Discovery Phase of the DoW ZT Framework. The Activity section begins with the Activity Table, which contains information sourced from the DoW CIO Library’s published updates on ZT Capabilities and Activities, current as of this document’s publication date. Figure 5 depicts a sample Activity Table, and Table 1 details the source of information for each of the sections of the table.



The terms “Enterprise” and “Component” are used throughout the Activities.

- Enterprise refers to an entity of any size, complexity, or positioning within an organizational structure (e.g., a federal agency, or, as appropriate, any of its operational elements, etc.). The Enterprise is responsible for providing policies and guidance to those Components that fall under its purview [12].
- Component refers to the organization implementing ZT.

For additional information, see the DoW ZT Framework documents published on the DoW CIO Library, including the Zero Trust Capabilities and Activities, the DoW Zero Trust Strategy, and the ZT RA [1-3].

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components utilize Enterprise authoritative source of (PE/NPE) identity (PE - AMID, NIS, AFID) and/or establish or augment with local authoritative source. Identity management can be done manually if needed, preparing for automated approach in later stages. Identity source is connected to identity lifecycle management processes (e.g., joiner/mover/leaver/returner, etc.). IT privileged users are clearly identified.	
Predecessor(s)	Successor(s)
None	1.2.2
Expected Outcomes	
• Identified managed non-privileged users. • Identified managed privileged users. • Identified applications using their own user account management for non-administrative and administrative accounts. • Identify the authoritative source of identities.	
End State	
Accurately determine and keep track of users who have both the authorization and authentication to access critical systems or resources. This involves regularly reviewing, communicating, and carefully examining the sources of information that provide the true and up-to-date user data.	

Figure 5: Sample Activity Table



Table 1: Activity Table Source of Information

Element	Source	Comment
ID	DoW CIO Library > Defend Against Cyber Attacks > Zero Trust Capabilities and Activities as of 18 Mar 25	
Description		Includes recommended corrections (grammar, capitalization, hyphens, etc.)
Predecessor(s)		
Successor(s)		
Expected Outcomes	DoW CIO Library > Defend Against Cyber Attacks > Zero Trust Capabilities and Activities as of 18 Mar 25	Includes recommended corrections (grammar, capitalization, hyphens, etc.)
End State		Includes recommended corrections (grammar, capitalization, hyphens, etc.)

Considerations

The Considerations subsection clearly explains the prerequisites, challenges, and lessons learned that may influence the successful implementation of each Activity. It highlights processes and applicable documentation and outlines any limitations or dependencies that may affect the execution of specific Activities. By addressing these considerations, the section aims to equip practitioners and decision-makers with the insights needed to effectively plan and adapt the provided guidance to their unique organizational environments.

Implementation

The Implementation subsection provides an actionable roadmap that guides practitioners through the practical execution of each task, ensuring alignment with the overall ZT objectives and facilitating measurable progress toward implementation.

The Implementation subsection defines high-level Tasks and process steps derived from the Activity Description, Expected Outcomes, and End State outlined in the DoW ZT Framework.

Summary

The Summary subsection provides a high-level overview of key considerations and Expected Outcomes for successfully implementing each Activity, which are presented in a workflow diagram.

- **Readiness Assessment** – Highlights critical ZT readiness questions to consider before implementing the ZT activity, focusing on organizational readiness.



- **Strategic Insights** – A high-level overview that outlines the intended results and benefits expected after implementing the Activity.
- **Expected Outcomes** – The Expected Outcomes are defined in the DoW ZT Framework. To achieve the Expected Outcomes, organizations should align their execution plans with the DoW ZT Strategy.

Appendices

The following Appendices can be found at the end of the document:

- Appendix A – Terms and Definitions
 - A compiled list of terms and definitions specific to the Discovery Phase ZIG.
- Appendix B – Abbreviations and Acronyms
 - A compiled list of abbreviations and acronyms specific to the Discovery Phase ZIG.
- Appendix C – References
 - A compiled list of references specific to the Discovery Phase ZIG.
- Appendix D – Activity Task Diagrams
 - A compilation of activity task implementation diagrams specific to the Discovery Phase ZIG.

The ZIG Primer Appendices contain all terms and definitions, abbreviations and acronyms, references, and activity diagrams related to the Primer, Discovery, Phase One, and Phase Two ZIGs.



User Pillar

Capability 1.1 User Inventory

Table 2: Capability 1.1 — User Inventory

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
1 - User	1.1 - User Inventory
Description	
Regular and Privileged users are identified and integrated into an inventory supporting regular modifications. Applications, software and services that have local users are all part of the inventory and highlighted.	
Impact to ZT	
Users not on the authorized user list will be denied access by policy.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component initiates a project to create a comprehensive User/Person Entity (PE) inventory, ensuring all regular and privileged Users/PEs are identified with detailed information integrated into a centralized inventory system.
- Applications, software, and services with local Users/PEs are identified, and their user lists are collected and reconciled against the central inventory.
- Automated tools are deployed to continuously monitor the network and update the inventory with any new or modified User/PE accounts, ensuring real-time accuracy.
- During routine inventory checks, the Component identifies several outdated accounts belonging to former contractors and employees that were not deactivated.
- A policy is enacted to immediately disable accounts not on the approved User/PE list unless they are actively verified by system owners.
- Shortly thereafter, an external threat actor attempts to use stolen credentials from a recently terminated contractor to gain access to the Component's network.
- The attempt is automatically blocked by the system, as the credentials are flagged as unapproved in the user inventory.



NSA | Zero Trust Implementation Guideline Discovery Phase

- Incident Response (IR) analysts review logs and confirm that the inventory system accurately identified and denied access, preventing a potential data breach.
- The Component conducts a monthly review process with system owners to ensure the inventory remains accurate and up-to-date, addressing any changes in personnel or roles.
- As a result, the Component maintains strict control over its approved and authenticated Users/PEs, achieving enhanced security and reducing the risk of unapproved access.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security Posture:** Comprehensive visibility of all User/PE types enables quick identification of unapproved access, dormant accounts, and privilege risks, allowing proactive threat mitigation.
- **Streamlined Compliance:** Centralized User/PE and application inventory simplifies regulatory compliance demonstration during audits, generating access reports quickly, and reducing preparation time.
- **Improved Efficiency:** Cataloging Users/PEs and applications enables automation of routine access management, reducing Information Technology (IT) workload and minimizing access-related disruptions.
- **Reduced Attack Surface:** Highlighting applications with local User/PE accounts helps prioritize security remediation efforts, systematically closing potential entry points for attackers.
- **Optimized Resource Management:** Clear visibility into privileged access requirements supports better license management, system consolidation, and more effective IT budget allocation.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Identity Management (IdM)
- Identity Provider (IdP)
- Identity, Credential, and Access Management (ICAM)
- System Cross-Domain Identity Management (SCIM)



Activity 1.1.1 Inventory User

Table 3: Activity 1.1.1 — Inventory User

DoW Zero Trust Framework	
<i>Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.</i>	
Description	
DoW Components utilize Enterprise authoritative source of (PE/NPE) identity (PE - AMID, NIS, AFID) and/or establish or augment with local authoritative source. Identity management can be done manually if needed, preparing for automated approach in later stages. Identity source is connected to identity lifecycle management processes (e.g., joiner/mover/leaver/returner, etc.). IT privileged users are clearly identified.	
Predecessor(s)	Successor(s)
None	1.2.2
Expected Outcomes	
• Identified managed non-privileged users. • Identified managed privileged users. • Identified applications using their own user account management for non-administrative and administrative accounts. • Identify the authoritative source of identities.	
End State	
Accurately determine and keep track of users who have both the authorization and authentication to access critical systems or resources. This involves regularly reviewing, communicating, and carefully examining the sources of information that provide the true and up-to-date user data.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Local vs. cloud systems require different management platforms. Various Identity, Credential, and Access Management (ICAM) solutions support either variant. Components should select a solution that aligns with their environment and is most compatible with other systems and solutions (e.g., Security Information and Event Management (SIEM), etc.). If an environment is built on a hybrid platform (e.g., local, cloud, etc.), then the integration of those solutions should also be considered.
- Integrating Attribute-Based Access Controls (ABACs), Role-Based Access Controls (RBACs), and fine-grained access controls mediates access at a granular level and can support the integration between systems, as they offer centralized policy management and consistent enforcement across systems.
- Consider completing Activity 3.1.1 (Discovery) – *Application and Code Identification* prior to this activity, to identify applications using their own account



management leveraging the inventory of approved applications and code being used.

- Activity 1.2.2 (Phase Two) – *Rule-Based Dynamic Access Part 1* is defined by the Department of War (DoW) Zero Trust (ZT) Framework as a successor to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 4: Implementation Tasks for Activity 1.1.1 — Inventory User

Catalog non-privileged Users/Person Entities (PEs) from all authentication sources.
Identify authentication sources: ☐ Compile a list of all authentication systems within the Component (e.g., cloud-hosted, on-premises directory services, third-party Identity and Access Management (IAM), ICAM providers, etc.) [13]. Extract User/PE data: ☐ Extract User/PE data from each authentication source using Application Programming Interfaces (APIs) or other integration methods. ☐ Gather information (e.g., usernames, unique identifiers, associated groups, etc.). Consolidate and normalize data: ☐ Move the extracted User/PE data into a central repository or IAM solution. ☐ Normalize the data to ensure consistency across different authentication sources. • Transform diverse attribute values into standardized formats, such as converting all email addresses to lowercase and removing whitespace from phone numbers to ensure consistent identification during authentication.
Catalog all privileged Users/PEs and ensure their identities are managed within authoritative sources.
Define privileged Users/PEs: ☐ Clearly define the criteria for privileged User/PE designation within your Component (e.g., administrators, system owners, database administrators, others with elevated access, etc.) [5]. Identify privileged Users/PEs: ☐ Identify Users/PEs with privileged access within each authentication source (e.g., review group memberships, specific roles, etc.).

**Verify and validate authoritative management:**

- ☐ Manage privileged User's/PE's identities within a primary authoritative source (e.g., a directory service, etc.) and verify and validate that user access is strictly controlled [13].
- ☐ Normalize the privileged User/PE data.

Identify applications that use integrated account management for non-administrative and administrative accounts.

Utilize discovery tools:

- ☐ Utilize manual and automated discovery tools while performing environment scans to identify all applications during the application inventory process.

*Further details are provided within Activity 3.1.1 (Discovery) – *Application and Code Identification*.

Create application inventory:

- ☐ Gather application management details as relevant data points during the application inventory.

*Further details are provided within Activity 3.1.1 (Discovery) – *Application and Code Identification*.

Catalog non-privileged Users/PEs in applications with independent account management.

Define criteria for non-privileged Users/PEs:

- ☐ Establish a clear definition of non-privileged Users/PEs based on their roles and access permissions. Focus on accounts with no administrative or elevated privileges [5].

Extract and organize User/PE account data:

- ☐ Collect account data from each application, leveraging administrative tools or APIs. Normalize this data to include User/PE identifiers, roles, and associated metadata for cataloging.
- ☐ Compile results in the Component Master User Inventory.

Review for completeness:

- ☐ Cross-reference the cataloged accounts against system logs or application audit trails to identify missing or unaccounted Users/PEs.
- ☐ Document and remediate any gaps.

Store, verify, and validate the catalog:

- ☐ Store the compiled list of non-privileged accounts in a secure, centralized location.
- ☐ Ensure completeness and accuracy by conducting a review with application owners.

Catalog privileged Users/PEs in applications with independent account management.

Define criteria for privileged Users/PEs:

- ☐ Establish criteria for identifying privileged Users/PEs, focusing on roles with administrative or elevated access. If applicable, use Enterprise role-based access standards as a reference [5].

Extract and organize privileged account data:

- ☐ Where possible, retrieve User/PE account data from each application using APIs or administrative tools. Highlight roles, permissions, and any associated metadata indicating privileged access.



Review, verify, and validate privileged accounts:

- ☐ Cross-check the extracted data with application audit logs and system configurations to confirm that all privileged accounts are accurately identified and included.

Store, verify, and validate the catalog:

- ☐ Store the compiled list of privileged accounts in a secure, centralized location.
- ☐ Ensure completeness and accuracy by conducting a review with application owners.



Summary

This diagram outlines the Activity 1.1.1 (Discovery) – *Inventory User* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on readiness assessment and Role-Based Access Control (RBAC). It highlights key questions for managing User/Person Entity (PE) identities, strategic insights driving implementation, and expected outcomes, such as identifying managed Users/PEs and authoritative identity sources.

Table 5: Activity 1.1.1 — Inventory User - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS 1. How are regular Users/PEs identified and managed in your User/PE inventory system? 2. How are privileged Users/PEs identified and managed in your User/PE inventory system? 3. What mechanisms are in place to identify applications using their own User/PE account management?
STRATEGIC INSIGHTS • The Component defines and documents procedures for cataloging Users/PEs from all authentication sources, ensuring that User/PE data is consistently extracted, consolidated, and normalized. • The Component demonstrates compliance by clearly defining privileged User/PE criteria, identifying privileged accounts, and verifying and validating that these identities are managed through authoritative sources. • The Component documents the identified Users/PEs in a Component Master User/PE Inventory. • The Component identifies applications that manage their own User/PE accounts and integrates this information into the Component Master Application Inventory, from Activity 3.1.1 (Discovery) – <i>Application and Code Identification</i>, confirming that both non-administrative and administrative accounts are tracked and managed. • The Component periodically monitors User/PE accounts within the environment to maintain the integrity of the Component Master User/PE Inventory.
EXPECTED OUTCOMES 1. Identified managed non-privileged users. 2. Identified managed privileged users. 3. Identified applications using their own user account management for non-administrative and administrative accounts. 4. Identify the authoritative source of identities.



Device Pillar

Capability 2.1 Device Inventory

Table 6: Capability 2.1 — Device Inventory

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
2 - Device	2.1 - Device Inventory
Description	
DoW Components establish and maintain an approved inventory list of all devices authorized to access the network and enroll all devices on the network prior to network connection. Device attributes will include technical details such as the PKI (802.1x) machine certificate, device object, patch/vulnerability status and others to enable successor activities.	
Impact to ZT	
By default policy, devices will be denied network access; the only devices permitted access to the network shall be known, authorized, and listed in the device inventory.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component conducts a device health tool gap analysis to identify missing capabilities required for tracking and managing devices on the network.
- A centralized device inventory system is implemented, enrolling all devices with their attributes, such as Public Key Infrastructure (PKI) machine certificates, device objects, and patch/vulnerability status.
- The Component establishes a policy that denies network access to any device not listed in the inventory, ensuring only known and authorized devices can connect.
- During the initial enrollment phase, several legacy devices with outdated firmware are flagged as non-compliant and either updated or removed from the network.
- A contractor attempts to connect a personal device to the network without prior enrollment, triggering an automatic block and generating an alert for the Security Operations Center (SOC).
- The Component's security team uses the inventory system to verify and validate that all connected devices are patched and meet baseline security standards before allowing continued network access.



NSA | Zero Trust Implementation Guideline Discovery Phase

- During a routine vulnerability scan, a device on the network is identified as non-compliant due to an expired PKI certificate. The inventory system flags the device and quarantines it until the certificate is renewed.
- Non-Person Entities (NPEs), such as Internet of Things (IoT) devices, are also enrolled in the inventory with detailed attributes, enabling the Component to manage and monitor these devices alongside User/Person Entity (PE)-operated systems.
- The Component integrates its device inventory with the Enterprise Identity Provider (IdP) to ensure device trust is continuously verified in conjunction with User/PE authentication.
- By maintaining a trusted device inventory, the Component ensures only authorized, compliant devices can access the network, thereby reducing the attack surface and reinforcing Zero Trust (ZT) principles.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** Establishing a trusted inventory reduces the risk of unapproved device access, reinforcing security protocols.
- **Improved Compliance:** Regular checks and updates ensure that all devices meet security standards, aiding in compliance with regulations.
- **Streamlined Device Management:** Centralized inventory allows for efficient tracking and management of devices, reducing administrative overhead.
- **Reduced Attack Surface:** The Component minimizes potential entry points for cyber threats by denying access to unapproved devices.

Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Asset/Device/Endpoint Management solutions
- Configuration Management Database (CMDB)
- IT Asset Management (ITAM) Software
- Internet of Things (IoT) Discovery
- Inventory and Asset Management solutions



Activity 2.1.1 Device Health Tool Gap Analysis

Table 7: Activity 2.1.1 — Device Health Tool Gap Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components develop an inventory of devices within the environment, and device attributes are tracked.	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
- Inventory of authorized and approved devices is created per Component with owners. - Determine and implement tools to gauge device health.	
End State	
A comprehensive inventory of authorized and approved devices with designated owners, and effective tools for monitoring and assessing device health are implemented.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Consider completing Activity 1.1.1 (Discovery) – *Inventory User* and Activity 3.1.1 (Discovery) – *Application and Code Identification* prior to this activity, to designate device ownership.
- Leverage existing security solutions and infrastructure (e.g., Security Information and Event Management (SIEM); Security Orchestration, Automation, and Response (SOAR), etc.) for integration and data collection.
- System owners should collect and inventory all relevant data points to establish a detailed overview.
- The data collected for the inventory, including information about devices and Users/Person Entities (PEs), should be uniformly formatted for machine readability. This ensures that device management and access software can make accurate access decisions and support future automation as the inventory process matures.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the



specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 8: Implementation Tasks for Activity 2.1.1 — Device Health Tool Gap Analysis

Inventory all physical and virtual devices in the environment, categorizing them by type (e.g., laptops, desktops, Internet of Things (IoT), mobile, Operational Technology (OT), etc.).
Complete a manual inventory of devices: ☐ Leverage existing Environment documentation (e.g., Ports, Protocols, and Services Management (PPSM), etc.) to generate an inventory of physical and virtual devices, resulting in a comprehensive Hardware/Software List. ☐ Manually audit the physical and virtual infrastructure to verify and validate PPSM data (e.g., ensure only approved ports, like Transmission Control Protocol (TCP) 443, are open on internet-facing servers) and the Hardware/Software List.
Deploy effective solutions for monitoring and assessing device health.
Complete an automated inventory of devices: ☐ Identify existing Information Technology Asset Management (ITAM) systems that can assess device health information within the environment. ☐ Determine if additional asset management tools, hardware, and/or software are required to supplement existing tools. Implement tools to gauge device health: ☐ Install additional asset management servers needed to assess device health, as required. ☐ Deploy endpoint-based agents, where possible, that perform asset management, vulnerability scanning, and security posture monitoring. ☐ Leverage all asset management systems (e.g., automated vulnerability scanning and device configuration assessments, etc.) to gather data, evaluate the environment for all devices, and identify systems not already indicated via the manual process. Analyze log outputs: ☐ Leverage network monitoring solutions within the SIEM to identify devices based on their network communication. SIEM solutions can be effective tools for collecting and correlating log activity [6]. Utilize management solutions to centrally store device data: ☐ Use management solutions (e.g., Information Technology Asset Managements (ITAMs) and Configuration Management Databases (CMDBs), etc.), as a central repository for storing and managing device inventory and data, where possible [6].



Designate ownership for each device.
Define administrative roles: ☐ In accordance with Zero Trust Architecture (ZTA) requirements, define administrator roles for each device type (e.g., virtual systems administrators, physical infrastructure administrators, environment and endpoint security administrators, etc.). Coordinate device management and Identity, Credential, and Access Management (ICAM) solutions: ☐ Leverage the User Inventory from Activity 1.1.1 (Discovery) – <i>Inventory User</i>, to designate ownership of devices to maintain accountability and set the necessary controls in the Mobile Device Management (MDM) and/or Unified Endpoint Management (UEM), where possible, to ensure only approved Users/PEs are operating their respective technology resources [6]. Ensure compatibility and proper communication with Network Access Controls (NACs): ☐ Ensure devices are properly integrated with ICAM and Identity Provider (IdP) services [5].
Monitor the health status of devices.
Manage device health management: ☐ Leverage and review documentation of the inventory conducted previously [6]. ☐ Verify and validate that the Component devices are identified and consistently managed, according to Enterprise policies and procedures [6]. ☐ Utilize asset management solutions to monitor device health for abnormalities in device behavior and functionality. ☐ Regularly monitor and document device status (e.g., configuration settings, installed/operating security software, patch status, signature status, etc.). ☐ Verify and validate the accuracy of device health information, as it is critical when making device access decisions.



Summary

This diagram outlines the Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the incorporation of device inventory and attribute management. It presents strategic insights that drive implementation and expected outcomes, including an inventory of approved devices per Component, along with their owners.

Table 9: Activity 2.1.1 — Device Health Tool Gap Analysis - Workflow



ZERO TRUST READINESS ASSESSMENT QUESTIONS

1. How is a manual inventory of devices created per Component with designated owners?
2. How are device attributes tracked and utilized in the inventory?



STRATEGIC INSIGHTS

- The Component defines and documents policies and procedures for inventorying all devices, including laptops, desktops, Internet of Things (IoT) devices, mobile devices, and Operational Technology (OT) devices, and categorizing them by type and management status.
- The Component demonstrates compliance by deploying endpoint-based agents (if chosen), conducting active and passive network scans, analyzing logs, and using asset management tools to create a comprehensive, centrally managed device inventory.
- The Component provides evidence that it designates device ownership and ensures compatibility with Identity, Credential, and Access Management (ICAM) and Network Access Control (NAC) solutions, maintaining accountability and approved use.
- The Component continuously monitors device inventory to identify gaps in device health management, leveraging integrated endpoint management tools (e.g., Unified Endpoint and Device Management (UEDM) solution, etc.) in addition to verifying and validating that all devices meet established security and compliance standards.
- The Component regularly audits and refines its device inventory, ensuring that processes remain effective, policies are followed, and identified gaps are addressed, thus maintaining a robust device management posture aligned with the Component's security framework.



EXPECTED OUTCOMES

1. Inventory of authorized and approved devices is created per Component with owners.
2. Determine and implement tools to gauge device health.



Capability 2.3 Device Authorization with Real-Time Inspection

Table 10: Capability 2.3 — Device Authorization with Real-Time Inspection

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
2 - Device	2.3 - Device Authorization with Real-Time Inspection
Description	
DoW Components conduct foundational and extended device tooling (Next-Generation Anti-Virus (NextGen AV), AppControl, File Integrity Monitoring (FIM), etc.) integration to better understand the risk posture. Organizational PKI systems are integrated to expand the existing Enterprise PKI to devices as well. Lastly, Entity Activity Monitoring is also integrated to identify anomalous activities.	
Impact to ZT	
Components can use policies to deny devices by default and explicitly allow access to DAAS resources only by devices that meet mandated configuration standards. Security threats identified are remediated faster through continuous activity inspection enables faster remediation of security threats.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component integrates foundational device security solutions, including Next-Generation Antivirus (NextGen AV), Application Control, and File Integrity Monitoring (FIM), to assess the risk posture of all devices attempting network access.
- The Enterprise Public Key Infrastructure (PKI) solution is expanded to include device certificates, ensuring that all devices, including unmanaged and infrastructure devices, are uniquely identifiable and verifiable.
- A deny-by-default policy is implemented, allowing network access only to devices that meet strict configuration and security standards.
- A device attempting to connect is flagged as non-compliant due to missing a valid PKI certificate, and access is denied automatically.
- Real-time Entity Activity Monitoring (EAM) solutions are deployed, tracking device behavior across endpoints and information Technology (IT) infrastructure to identify anomalous or malicious activities.
- During routine operations, EAM detects a device exhibiting unusual activity, such as frequent failed access attempts to restricted resources, and raises an alert for the security team.



NSA | Zero Trust Implementation Guideline Discovery Phase

- The alert triggers an automated response that quarantines the device, isolates it from the network, and initiates further inspection.
- Investigation reveals that the anomalous activity originated from malware attempting to exploit a misconfigured application on the device, which is quickly remediated using integrated NextGen AV and FIM solutions.
- The Component integrates the device security stack with the Comply-to-Connect (C2C) solution, ensuring that devices are continuously monitored and inspected throughout their session in alignment with Zero Trust (ZT) principles, not just at the point of entry.
- By combining real-time inspection with robust device authorization policies, the Component enhances its ability to prevent unauthorized access and mitigate threats quickly.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Comprehensive Risk Assessment:** Integrating advanced security tools like NextGen AV, Application Control, and FIM, provides a more accurate understanding of the overall security landscape.
- **Enhanced Authentication and Trust:** The Component expands PKI integration to devices, establishing stronger identity verification and validation and securing communications across the infrastructure.
- **Early Threat Detection:** The EAM identifies anomalous behaviors before they escalate into significant security incidents.
- **Reduced Security Blind Spots:** The Component combines multiple security technologies into a cohesive system, enabling more thorough protection against sophisticated threats.
- **Data-Driven Security:** Decision-making is supported by integrated tooling that provides actionable intelligence about potential vulnerabilities and attack vectors.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- File Integrity Monitoring (FIM)
- Multi-Factor Authentication (MFA)
- Public Key Infrastructure (PKI)
- Network Access Control (NAC)
- Next-Generation Antivirus (NextGen AV)
- Real-Time Monitoring



Activity 2.3.4 Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)

Table 11: Activity 2.3.4 — Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Component procures and implements an Endpoint Protection Platform (EPP). EPP should have the capabilities to use advanced analytics (e.g., artificial intelligence, behavioral detection, machine learning) to mitigate exploits (e.g., zero-day, signatureless, fileless), provide Network Access Control, and protect against known and unknown threats. These solutions are orchestrated with the C2C or EDR solution for baseline status checks of signatures, updates, etc.	
Predecessor(s)	Successor(s)
None	2.2.1, 2.7.1
Expected Outcomes	
- Critical Endpoint Protection Platform (EPP) data is being sent to C2C and EDR for checks. - EPP tooling is implemented on all critical services applications and endpoint devices.	
End State	
Advanced protection on endpoint devices against modern threats, while developing Automation & Orchestration, as well as Visibility & Analytics pillar, through AI, ML and behavior analysis.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Consider completing Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis* and Activity 3.1.1 (Discovery) – *Application and Code Identification* prior to this activity, to establish an Application Inventory.
- Incorporate industry-recognized best practices for application security:
 - Regular patching and vulnerability remediation
 - Secure coding practices
 - Application whitelisting
 - Supply chain security
- Consider Component requirements for Endpoint Protection Platform (EPP) solutions that have all necessary features, such as Next-Generation Antivirus (NextGen AV), anti-malware, Comply-to-Connect (C2C), and Endpoint Detection and Response (EDR) interoperability.



- Define critical EPP data to be shared with C2C and EDR, for example:
 - Device health status: Including operating system version, patch level, and antivirus status.
 - Application Inventory: List of installed applications.
 - Detected threats: Details of detected malware and other threats.
 - Security events: Logs of suspicious activity.
- Activity 2.2.1 (Phase Two) – *Implement Comply-to-Connect (C2C) and Compliance-Based Network Authorization Part 1* and Activity 2.7.1 (Phase One) – *Implement Endpoint Detection and Response (EDR) Tools and Integrate with Comply-to-Connect (C2C)* are defined by the Department of War (DoW) Zero Trust (ZT) Framework as successors to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 12: Implementation Tasks for Activity 2.3.4 — Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)

Evaluate and select an EPP solution based on Enterprise and Component procurement policies and procedures.
Identify Enterprise and Component procurement requirements and security compliance standards: ☐ Review the Enterprise and Component procurement guidelines to ensure compliance with budgeting, vendor selection, and approval processes. Assess EPP solutions for compatibility with existing infrastructure and security tools (e.g., C2C, EDR, etc.): ☐ Document required controls for endpoint security (e.g., encryption, access control, auditing, Incident Response (IR), etc.). ☐ Determine which standards the EPP should comply with (e.g., data protection, malware detection, remediation, etc.). ☐ Identify potential EPP vendors based on market research to meet mission requirements and solution integration with existing infrastructure.



Select and procure an EPP solution based on performance, compliance, and cost analysis:

- ☐ Use a structured process to evaluate vendors based on predefined criteria (e.g., functionality, support, scalability, vendor reputation, etc.).
- ☐ Include cross-functional stakeholders (e.g., security operations, networking, procurement, etc.) in the review process, where applicable.
- ☐ Conduct testing (e.g., performance, functionality, security, etc.) with selected EPP solutions on a sample set of critical endpoints, where applicable.
- ☐ Based on performance testing, compliance analysis, and cost evaluation, select the EPP solution that best meets the Enterprise and Component needs.

Configure EPP to prepare to send data to C2C.

Establish secure data transfer:

- ☐ Ensure data is encrypted prior to transferring sensitive EPP data in compliance with Least Privilege and data protection requirements.
- ☐ Create secure data channels for EPP systems to communicate with the C2C environment at large to protect data in transit.
- ☐ In preparation for successor Activity 2.2.1 (Phase Two) – *Implement Comply-to-Connect (C2C) and Compliance-Based Network Authorization Part 1*, configure access control to allow only approved endpoints to connect, and prepare to send data to the C2C.
- ☐ Utilize Application Programming Interfaces (APIs) (e.g., Secure File Transfer Protocols (SFTPs), Secure Sockets Layer (SSL), Secure Shell (SSH), Transport Layer Security (TLS), etc.) for secure data transfer, where possible.

Define data types for transfer between the EPP and C2C:

- ☐ Determine the types of data the EPP will send to the C2C (e.g., real-time EDR data, aggregated Extended Detection and Response (XDR) data, relevant security events, etc.).
- ☐ Categorize data as real-time, periodic, or event-driven to optimize C2C ingestion.
- ☐ Establish tagging schema for Attribute-Based Access Control (ABAC) enforcement.
- ☐ Test the integration to ensure data flows correctly and is processed as expected.

Configure EPP to prepare to send data to EDR.

Configure EPP:

- ☐ Verify and validate the configuration processes across the entire endpoint lifecycle, which may vary depending on the EPP and EDR solutions.
- ☐ Configure the EPP to forward relevant data to the EDR solution [14]:
 - Include forwarding alerts, raw telemetry data, policy violations, and user behavior analytics.
 - Verify and validate correlation in EDR dashboards and alerts.



Deploy and configure the EPP solution.

Asset inventory:

- ☐ Leverage approved asset inventory, from Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis*.
- ☐ Verify and validate an inventory of all applications and devices within the Component's environment to ensure the proper application and configuration of the EPP solution.

Implement EPP:

- ☐ Deploy the EPP solution to all identified endpoints, ensuring complete coverage.
- ☐ Leverage, verify, and validate the roles established through previous activities.
- ☐ Ensure roles are properly assigned in the EPP [15].
- ☐ Configure a comprehensive software solution with centralized control and management to maintain consistent policies across all defined endpoints.

Configure policies:

- ☐ Configure the EPP policies to include strict application control, device control, and continuous monitoring.
- ☐ Restrict the use of mobile code (e.g., ActiveX, Java, JavaScript, etc.) to prevent attackers from executing malicious code scripts [15].

Maintain regular updates:

- ☐ Ensure protection against the latest threats by regularly performing software updates to the EPP and its threat intelligence database [16].
- ☐ Schedule and execute validation checks (e.g., health status polling, hash validation, etc.).
- ☐ Implement self-healing or rollback mechanisms for failed updates.



Summary

This diagram outlines the Activity 2.3.4 (Discovery) – *Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the incorporation of Next-Generation Antivirus (NextGen AV). It presents strategic insights that drive implementation and expected outcomes, including the Endpoint Protection Platform (EPP) data being sent to Comply-to-Connect (C2C) and Endpoint Detection and Response (EDR) for checks. Additionally, EPP tooling is included on all critical service applications and endpoint devices.

Table 13: Activity 2.3.4 — Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C) - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS 1. How is critical NextGen AV data sent to C2C for checks? 2. How is NextGen AV tooling implemented on all critical services and applications?
STRATEGIC INSIGHTS • The Component defines and documents policies and procedures for configuring EPP tools to securely transmit data (e.g., telemetry, alerts, file hashes, etc.) to the C2C environment, ensuring adherence to Enterprise security requirements and ZT principles. • The Component demonstrates compliance by establishing secure, encrypted data transfer channels (e.g., Transport Layer Security (TLS), Secure Shell (SSH), etc.) between EPP solutions and C2C systems, verifying that data flows correctly and sensitive information remains protected against unapproved access or exposure. • The Component provides evidence that it integrates EPP with EDR tools, selecting platforms, refining policies, and configuring exploit protection settings to forward relevant alerts, suspicious events, and raw telemetry data for continuous threat monitoring. • The Component ensures full EPP coverage by identifying all applications and devices through a comprehensive asset inventory, deploying EPP software across endpoints, configuring policies (e.g., application and device control, restricted mobile code execution, etc.), and maintaining updated threat intelligence databases. • The Component continuously updates and audits its EPP configurations, patches, and policies, confirming that endpoint protection measures remain aligned with evolving threats, Component objectives, and established security standards while maintaining a robust ZT security posture.
EXPECTED OUTCOMES 1. Critical EPP data is being sent to C2C and EDR for checks. 2. EPP tooling is implemented on all critical services applications and endpoint devices.



Application and Workload Pillar

Capability 3.1 Application Inventory

Table 14: Capability 3.1 — Application Inventory

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
3 - Application and Workload	3.1 - Application Inventory
Description	
System owners ensure that all applications and application components are identified and inventoried; only applications and application components that have been authorized by the appropriate authorizing official/CISO/CIO shall be utilized within the system owner's purview	
Impact to ZT	
Unauthorized applications and application components are not used on or within the system.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component initiates an application inventory project, requiring all system owners to identify and document the applications and components used within their systems.
- System owners submit detailed information about each application, including version, purpose, associated components, and approving official approval status.
- An inventory solution is deployed to automatically scan the network, identifying all installed applications and cross-referencing them against the submitted inventory.
- During the scan, the solution identifies an unapproved application installed on several endpoints that were not approved by the appropriate approving official.
- The security team investigates the unapproved application, finding that it poses a potential vulnerability due to outdated components and a lack of vendor support.
- The application is immediately removed from all affected endpoints, and access controls are updated to prevent reinstallation without prior approval.
- The Component updates its policy to require real-time integration between the inventory solution and a central approval database, ensuring only approved applications can be installed.
- Routine audits are scheduled to verify and validate that all applications in use remain approved and align with security and operational standards.



NSA | Zero Trust Implementation Guideline Discovery Phase

- The inventory solution is enhanced to include application lifecycle tracking, notifying system owners when applications approach end-of-life or require updates.
- By maintaining a comprehensive and accurate application inventory, the Component ensures that only approved software is used, reducing risks from unapproved, unauthorized, or unsupported applications.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** Reduces the risk of vulnerabilities from unapproved or unsupported applications, aligning with security best practices.
- **Improved Compliance:** Ensures adherence to Component policies and regulatory requirements regarding software usage.
- **Better Resource Management:** Facilitates effective tracking of application lifecycles, leading to timely updates and support.
- **Streamlined Audits:** Simplifies the audit process by maintaining an accurate and up-to-date inventory of applications in use.

Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Application Portfolio Management (APM)
- Asset Management solutions
- Configuration Management Database (CMDB)
- Software Asset Management (SAM)
- Source Code Management (SCM)



Activity 3.1.1 Application and Code Identification

Table 15: Activity 3.1.1 — Application and Code Identification

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components create an inventory of approved applications and code being used, including open-source, commercial, and in-house developed software. Each Component will track the supportability (i.e., active, legacy, etc.) hosted location (i.e., cloud, on-premises, hybrid, etc.) and record important data (i.e., name, version, team responsible, licensing and support, mapped dependencies).	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
• Component has identified applications and classified as either legacy, virtualized on-premises, and cloud hosted. • Applications and code are tracked by vendor, version number, commercial name, and patch level.	
End State	
Develop an inventory to better support patch management and supply chain risk management increasing security by identifying unauthorized apps and identify security vulnerabilities.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Clearly define application ownership for accountability.
- Integrate or leverage the existing Software Acquisition Lifecycle (SALC) to track contractual requirements whenever applicable.
- Ensure the application/code inventory is accurate by integrating with a change management process.
- Review vendor security bulletins and supply chain risk management to ensure continuous compliance.
- Develop/leverage capabilities for regular updates.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.



Table 16: Implementation Tasks for Activity 3.1.1 — Application and Code Identification

Catalog all existing applications and codes.
Establish application identification: □ Identify all legitimate and necessary applications required for various functions in the Component and create a whitelist of these approved applications to reference or make changes to later. This may involve contacting vendors, reviewing documentation, and/or using software discovery solutions. These can range from basic network discovery solutions built into common operating systems to more comprehensive commercial solutions. Establish code identification: □ Gather necessary contextual information, such as code source names, unique identifiers, location (on-premises or off-site), and supportability. This information is used with other Zero Trust (ZT) services to create need-to-know access to each application [17]. Enable network traffic discovery: □ Leverage network analysis and deep packet inspection to capture network traffic and identify applications based on data flows, communication patterns, protocols, and port usage. Enable signature-based discovery: □ Review and analyze code source file headers and associated metadata to identify existing codes based on known attributes and unique signature patterns.
Establish application and code classification.
Define objectives and scope: □ Clearly define what constitutes a legacy, virtualized on-premises, or cloud-hosted application. Define the details to be collected, including vendor information, version numbers, commercial names, patch levels, licensing details, support contacts, etc. □ Identify the details necessary for effective application and code management. Consider factors like age, hosting environment, and dependencies. Establish common criteria: □ Review the approved applications list and classify each according to the established criteria. This will involve consultation with application owners or technical experts and product documentation references. □ Add the new classification fields to the Component’s application tracking solution if the fields are not already present. Establish code ownership: □ Review features within code source attributes and file metadata to establish and document code ownership.



Develop a comprehensive application and code inventory.

Define objectives and scope:

- ☐ Identify the details necessary for effective application and code management.

Establish code repository management:

☐ Collect, maintain, and review classification attributes. Leverage the National Institute of Standards and Technology (NIST) cybersecurity framework to maintain inventories for all types of software and services, including Commercial Off-The-Shelf (COTS), open-source, custom applications, Application Programming Interface (API) services, and cloud-based applications and services.

- ☐ Update the inventory or repository with the classification details for each approved application.

Explore inventory methods:

☐ Enable automated discovery with scanning tools and technologies to identify applications, operating systems, software components, versions, and unique code source patterns.

☐ Collaborate with stakeholders and specific mission partners to provide manual input and insights on relevant application purpose and functionality, classification attributes, and applicable risk-based security bulletins.

Established a centralized repository:

☐ Set up an encrypted central repository for the application whitelist. At its outset, this can begin as a manual process using a spreadsheet or database, then move to centralized ownership using an Information Technology (IT) asset management system, such as a Configuration Management Database (CMDB). CMDBs store application information and can track changes, relationships, and dependencies [18].

Maintain the integrity of the application/code inventory.

Maintain Application/Code Inventory:

☐ Verify and validate the accuracy of the application/code inventory in accordance with the Enterprise/Component defined requirements, or at a recommended frequency of no greater than annually.



Summary

This diagram outlines the Activity 3.1.1 (Discovery) – *Application and Code Identification* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the incorporation of application and code identification, classification, and inventory. It presents strategic insights that drive implementation and expected outcomes, including the integration of application classifications and application/code tracking.

Table 17: Activity 3.1.1 — Application and Code Identification - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS
1. How are applications and code identified and inventoried? 2. How are applications classified as legacy, virtualized on-premises, or cloud-hosted?
STRATEGIC INSIGHTS
• The Component defines a structured approach to cataloging applications and code by identifying all necessary software, establishing classification criteria, and maintaining a centralized Component Master Application Inventory. • The Component demonstrates security and compliance by implementing application and code identification processes, leveraging network and signature-based discovery, and ensuring that only approved applications are tracked and managed. • The Component provides verifiable enforcement through an encrypted, centralized repository, supported by automated discovery tools and classification frameworks, ensuring continuous visibility and control over application and code assets. • The Component leverages industry standards, such as the National Institute of Standards and Technology (NIST) Cybersecurity Framework, to manage inventories, track dependencies, and maintain oversight of Commercial Off-The-Shelf (COTS), open-source, and cloud-based applications. • The Component ensures ongoing integrity by regularly verifying, validating, and updating the application/code inventory, integrating stakeholder input, and maintaining compliance with organizational and security requirements.
EXPECTED OUTCOMES
1. Component has identified applications and classified as either legacy, virtualized on-premises, and cloud hosted. 2. Applications and code are tracked by vendor, version number, commercial name, and patch level.



Data Pillar

Capability 4.1 Data Catalog Risk Alignment

Table 18: Capability 4.1 — Data Catalog Risk Alignment

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
4 - Data	4.1 - Data Catalog Risk Alignment
Description	
Data owners ensure that data is identified and inventoried and any changes to the data landscape are automatically detected and included within the catalog. The data landscape must then be reviewed to identify potential risks related to data loss, attack, or any other unauthorized alteration and/or access.	
Impact to ZT	
Data assets are known and can therefore be collected, tagged, and protected according to risk levels in alignment with a prioritization framework, and encrypted for protection.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component establishes a data catalog system to identify and inventory all data assets, including their sensitivity levels, ownership, and locations.
- Automated solutions are integrated to detect and update the catalog with any changes to the data landscape, such as the addition of new datasets or modifications to existing ones.
- Data owners regularly review the catalog to ensure all data assets are appropriately classified and tagged according to their risk levels and Enterprise/Component-defined priorities.
- During a routine analysis, the cataloging system identifies a new dataset stored in an unapproved cloud location that has not been encrypted or properly secured.
- The dataset is flagged as a high risk, and an alert is sent to the data owner and the security team for immediate remediation.
- The Component applies encryption to the dataset and migrates it to an approved storage location with enhanced access controls to mitigate the identified risks.
- A periodic review of the data catalog reveals that a previously tagged dataset's risk level has increased due to changes in regulatory compliance requirements.



NSA | Zero Trust Implementation Guideline Discovery Phase

- Data owners adjust security controls, including access permissions and encryption protocols, to align with the updated risk level and compliance standards.
- Automated alerts are configured to notify data owners of potential risks, such as unapproved alterations, access attempts, or signs of data exfiltration.
- By maintaining an up-to-date data catalog and continuously aligning risk levels, the Component ensures that data assets are identified, protected, and encrypted according to their prioritization framework.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Comprehensive Visibility:** Components maintain complete awareness of their data assets, automatically detecting new or modified data and ensuring nothing slips through the cracks.
- **Preemptive Protection:** Regular risk reviews enable Components to identify and address vulnerabilities before they can be exploited, significantly reducing the likelihood of a breach.
- **Improved Decision Intelligence:** With accurate, current data catalogs, leadership can make better-informed strategic decisions about resource allocation and security investments.
- **Rapid Incident Response (IR):** Components with well-maintained data inventories can quickly determine potential impact scope and prioritize protection efforts when security events occur.
- **Streamlined Governance:** Automated detection of data landscape changes eliminates manual cataloging efforts while ensuring continuous compliance with regulatory compliance requirements.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Compliance Management solutions
- Compliance and Governance Automation solutions
- Data Management and Integration
- Governance, Risk, and Compliance (GRC)
- Metadata Management Systems



Activity 4.1.1 Data Analysis

Table 19: Activity 4.1.1 — Data Analysis

DoW Zero Trust Framework	
<i>Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.</i>	
Description	
DoW Enterprise will develop algorithm(s) for Components to map data for tagging and labeling, and establish the governing body for oversight. Data at a Component level should be categorized and analyzed by an overseeing governing body.	
Predecessor(s)	Successor(s)
None	4.3.2
Expected Outcomes	
- Algorithms are entered into an algorithm registry with appropriate tagging and labeling set by the Enterprise to allow search and retrieval as appropriate (e.g., accommodating data catalog risk alignment). - Component data catalog is updated with data types for each application and service based on data classification levels.	
End State	
Data analysis ensures data protection and reduces risk. All problems have a data analysis algorithm registered in a repository with associated data indicated, and the oversight governance body has awareness that is Visible, Accessible, Understandable, Linked, Trusted, Interoperable, and Secure (VAULTIS) compliant.	

Considerations

- Presumption: The Enterprise has established algorithm(s) for Components to map data for tagging and labeling.
- The accuracy and completeness of the Component Master Data Inventory, listing all data assets owned and managed by the Component, is a foundational resource for many of the activities across multiple Pillars.
- A centralized algorithm catalog should be established at the Enterprise level to promote consistency across Components. Components may develop and utilize algorithms, registering them in the enterprise catalog for broader use and management.
- Activity 4.3.2 (Phase Two) – *Manual Data Tagging Part 1* is defined by the Department of War (DoW) Zero Trust (ZT) Framework as a successor to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the



specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 20: Implementation Tasks for Activity 4.1.1 — Data Analysis

Leverage the Enterprise algorithm registry.
Gather requirements: ☐ Leverage documentation of previously established algorithms and processes developed by the Enterprise to provide governing body oversight and awareness that it is Visible, Accessible, Understandable, Linked, Trusted, Interoperable, Secure (VAULTIS) compliant [19]. Define objectives and scope: ☐ Collaborate with the Enterprise to establish clear objectives, guidelines, and scope definition for creating the algorithm registry [8]. • Include improving transparency. • Include enhancing management. • Include compliance requirements. Identify approved authentication sources: ☐ Create and maintain a comprehensive list of all approved authentication systems and codes used for task automation analysis within the Component. ☐ Assign a responsible system owner to each category based on resource criticality [20]. Select solutions and technologies: ☐ Choose solutions for documenting algorithms. • Include markdown editors. • Include documentation generators. • Include version control systems. Develop the Component Master Data Catalog plan: ☐ Define criteria for documenting algorithms. • Include algorithm type. • Include algorithm's purpose. • Include algorithm inputs. • Include algorithm outputs. • Include performance metrics.



Create a Component-level data governance body.

Create a data governance body:

- ☐ Create and implement a governance structure that enables the collection and sustainment of the Component Master Data Catalog to facilitate search and retrieval in a distributed environment for baseline and change management during component growth for mission-critical tasks [19].
- ☐ Assign a responsible system owner to each category based on resource criticality [8].

Develop a Component-level data catalog.

Develop data catalog standards:

- ☐ Identify and standardize metadata.
 - Metadata: Information about the data, including data sources, formats, owners, and descriptions.
 - Search and Discovery: Features that allow users to search and browse the catalog for data assets and store that information in the catalog.
 - Data Lineage: Store data lineage information to track the flow of data from source to destination.
 - Data Profile: Features that allow data to be profiled, document data quality rules, and track data quality issues.
- ☐ Metadata should be determined by the Component in alignment with Enterprise requirements.
 - Descriptive Metadata Standard: Information about the data, including data sources, formats, owners, and descriptions.
 - Structural Metadata Standard: Features that allow users to search and browse the catalog for data assets and store that information in the catalog.
 - Administrative Metadata Standard: Store data lineage information to track the flow of data from source to destination.
- ☐ Examples include:
 - Categorize Data based on types.
 - Include data sorting.
 - Include data searching.
 - Include data encryption.
 - Include data Machine Learning (ML).
 - Categorize data based on the application domain and the field or industry it relates to.
 - Include data processing.
 - Include cryptography.
 - Include Artificial Intelligence (AI).



- Categorize based on data-identified complexity levels.
 - Mark Level – low (simple data)
 - Mark Level – medium (moderate data)
 - Mark Level – high (complex data)

☐ As per the need of the Component, adopt one or more of the four (4) Master Data Management architecture styles to implement master data: (a) Registry Style, (b) Consolidation Style, (c) Coexistence Style, and (d) Transaction/Centralized Style.

Create the Component-level Master Data Inventory.

Develop Master Data Inventory and standards:

- ☐ Leverage data owners to compile a comprehensive list of data and associated metadata.
- ☐ Consolidate information collected into the Component Master Data Inventory.
- ☐ Choose Master Data Management solutions for creating Master Data.
 - Include markdown editors.
 - Include documentation generators.
 - Include version control systems.
 - Ability to read various data formats.
 - Ability to handle Application Programming Interface (API) calls (e.g., Representational State Transfer (REST), Simple Object Access Protocol (SOAP), etc.).
- ☐ Using data governance processes, create data update rules to create the master data “golden” record, also known as “Single Version of Truth”. (Data update rules can include data cleansing, data transformation, data standardization, data merge, etc.)
- ☐ Identify and document the goals and key outcomes of their Master Data Management process. For example, a Component can create a Master Data Management process to improve their data quality, improve access, and/or usage.

Periodically verify and validate the Master Data Inventory.

Verify and validate the accuracy/integrity of the Master Data Inventory:

- ☐ To ensure the integrity of the Master Data Inventory, it is necessary to review it for accuracy and completeness periodically.
- ☐ The frequency for periodic review of data governance will need to be determined by the Component in alignment with Enterprise requirements.
 - It is strongly recommended that the frequency is no longer than annually.
- ☐ Continuously monitor the Master Data Management implementation to add new data sources and update new business rules that govern the “golden” record.



Summary

This diagram outlines the Activity 4.1.1 (Discovery) – *Data Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the incorporation of service catalog management based on varying data types and data classification levels. It presents strategic insights that drive implementation and expected outcomes, including enabling search and retrieval as appropriate, using an algorithm registry with tagging and labeling.

Table 21: Activity 4.1.1 — Data Analysis - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS	
1. How is the service catalog updated with data types for each application and service based on data classification levels?	
STRATEGIC INSIGHTS	• The Component defines and documents the creation of an algorithm registry in alignment with Enterprise guidelines, ensuring consistency across Components and compliance with Visible, Assessable, Understandable, Linked, Trusted, Interoperable, and Secure (VAULTIS) standards for data protection and risk reduction. • The Component demonstrates compliance by establishing objectives and scope, categorizing algorithms based on complexity, purpose, and application domain, and integrating authentication sources for task automation analysis to maintain a governed, structured, and auditable registry. • The Component provides a structured approach for selecting and managing registry solutions, including markdown editors, documentation generators, and version control systems, ensuring approved personnel can view, edit, and manage algorithm data based on defined access control policies. • The Component leverages an Enterprise data governance body to catalog and baseline algorithm data, assigning ownership, security guidelines, and interoperability requirements while maintaining a comprehensive Component Master Data Inventory. • The Component ensures periodic verification, validation, and review of the Master Data Inventory to verify and validate its accuracy, integrity, and compliance, aligning with Enterprise-defined review cycles, with strong recommendations for assessments no longer than annually.
EXPECTED OUTCOMES	1. Algorithms are entered into an algorithm registry with appropriate tagging and labeling set by the Enterprise to allow search and retrieval as appropriate (e.g., accommodating data catalog risk alignment). 2. Component data catalog is updated with data types for each application and service based on data classification levels.



Capability 4.4 Data Monitoring and Sensing

Table 22: Capability 4.4 — Data Monitoring and Sensing

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
4 - Data	4.4 - Data Monitoring and Sensing
Description	
Data owners will capture active metadata that includes information about the access, sharing, transformation, and use of their data assets. Data Loss Prevention (DLP) and Data Rights Management (DRM) enforcement point analysis is conducted to determine where tooling will be deployed. Data outside of DLP and DRM scope such as File Shares and Databases is actively monitored for anomalous and malicious activity using alternative tooling.	
Impact to ZT	
Data in all states are detectable and observable.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component deploys solutions to capture active metadata, including information on access, sharing, transformation, and usage of all data assets, ensuring data observability in all states.
- Data Loss Prevention (DLP) solutions are implemented at key enforcement points, supporting Zero Trust (ZT) by continuously validating User/Person Entity (PE) actions and flagging potentially unauthorized behaviors.
- Data Rights Management (DRM) solutions are configured to track how data is accessed, shared, and transformed within approved applications and workflows.
- An analysis of enforcement point logs reveals gaps in coverage, prompting the deployment of additional DLP and DRM solutions at critical locations, such as file servers and endpoints.
- Alternative monitoring solutions are implemented to observe activity on data sources outside DLP and DRM scope, such as file shares and databases, to detect anomalous or malicious behavior.
- Anomalous activity is detected on a shared drive, where a User/PE unexpectedly downloads large volumes of sensitive files during non-working hours.
- Alerts generated by the file activity monitoring tool prompt the Security Operations Center (SOC) to investigate the User/PE's behavior, confirming the action as unauthorized.



NSA | Zero Trust Implementation Guideline Discovery Phase

- The User/PE's access is revoked, and the anomalous activity logs are forwarded for further analysis, leading to policy updates to prevent similar incidents.
- Database activity monitoring solutions identify unusual query patterns that attempt to access restricted tables, prompting an automated response to block the queries and notify the database administrator.
- By capturing active metadata and monitoring data activities comprehensively across all systems, the Component ensures that data is detectable and observable, preventing unauthorized access.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Data Security:** By implementing DLP and DRM solutions, Components can significantly reduce the risk of data breaches and unapproved access to sensitive information.
- **Improved Compliance:** The ability to monitor and manage data usage helps Components comply with regulatory requirements related to data protection and privacy.
- **Increased Visibility:** Active metadata capture provides Components with comprehensive visibility into how data is accessed and used, enabling better decision-making.
- **Evidence-Based Governance:** Comprehensive monitoring creates a complete audit trail of data access and transformation, helping components demonstrate compliance and exercise greater control over their information assets.

Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Anomaly Detection
- Behavioral Analytics solutions
- Data Loss Prevention (DLP)
- Digital Rights Management (DRM)
- File Integrity Monitoring (FIM)
- Monitoring and Analytics solutions



Activity 4.4.1 Data Loss Prevention (DLP) Enforcement Point Logging and Analysis

Table 23: Activity 4.4.1 — Data Loss Prevention (DLP) Enforcement Point Logging and Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components identify business rules for managing Data Loss Prevention (DLP) enforcement points, such as specific services and user endpoints. Using the established Enterprise cybersecurity incident response standard, Components ensure the appropriate level of detail of data is captured. Additionally, protection, detection, and response use cases are developed to better outline solution coverage.	
Predecessor(s)	Successor(s)
None	4.4.6
Expected Outcomes	
• Business rules for access control are established and coordinated with Cyber Operations to support standardized logging for managing DLP enforcement. • Standardized logging schema is enforced at the Component-level. • Components identify enforcement points.	
End State	
The right people are allowed to access the right data in the right place at the right time. Data loss prevention rules restrict exfiltration of information from an access control boundary, enhance visibility, and prevent data breaches when aligned with an incident response standard.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Enterprise/Component logging standards have not yet been identified/implemented. Consider industry best practices for log standards. Understand that logging standards are established in Activity 7.1.2 (Phase One) – *Log Parsing*.
- The data catalog in Activity 4.1.1 (Discovery) – *Data Analysis* and the respective device and application inventories in Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis* and Activity 3.1.1 (Discovery) – *Application and Code Identification* should be leveraged for this activity.
- Activity 4.6.1 (Phase One) – *Implement Enforcement Points* will leverage this activity.



- Activity 4.4.6 (Phase Four) – *Comprehensive Data Activity Monitoring* is defined by the Department of War (DoW) Zero Trust (ZT) Framework as a successor to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 24: Implementation Tasks for Activity 4.4.1 — Data Loss Prevention (DLP) Enforcement Point Logging and Analysis

Establish a Component Data Loss Prevention (DLP) policy supporting loss activity detection.
Identify key stakeholders: □ Establish a cyber collaboration center to assess cyber incidents and securely share findings with approved partners. Review Enterprise initiatives and compliance requirements on Indicators of Compromise (IoC), data breaches, and Incident Responses (IRs). • Create dedicated internal teams. • Identify external components. • Establish broader national partners. Define objectives and scope: □ Leverage the data sensitivity/classification levels documented in the Component Data Catalog, from Activity 4.1.1 (Discovery) – <i>Data Analysis</i>. □ Collaborate with stakeholders to establish a DLP policy. The Component DLP plan should include: • Scope: ○ What systems will fall under DLP enforcement? ▪ Environments, devices, endpoints, etc. • Integration: ○ Determine how DLP responses will integrate with existing Component IR actions, which, at a minimum, should include: ▪ Preparation and planning ▪ Detection and analysis ▪ Data recovery • Enforcement: ○ Establish the business rules/enforcement strategy, such as when to block vs. alert on policy violations.



- Exceptions:
 - Create an exception process and standards.
- Visibility:
 - Audit requirements, such as frequency, alert criteria, integration into Security Information and Event Management (SIEM), Security Orchestration, Automation and Response (SOAR), and other Capabilities established in the Visibility and Analytics and/or Automation and Orchestration Pillars.
- Reporting:
 - Determine how alerts are handled, including stakeholders, data owners, and IR responders.

Identify enforcement points and decision points.

Identify DLP enforcement points:

☐ Identify DLP enforcement points within the Component environment:

- Endpoint DLP:
 - Install DLP agents on endpoint devices to monitor and safeguard sensitive data where possible.
- Web DLP:
 - Deploy web gateways to scan web traffic for sensitive data.
- Network DLP:
 - Deploy network appliances with DLP built-in capability.
- Email DLP:
 - Protect email servers with DLP monitoring.
- Cloud DLP:
 - Adopt cloud-based DLP solutions.

Select a DLP solution.

Select a DLP solution that meets the needs of the Component:

- ☐ Leverage the previously created Component DLP policy.
- ☐ Leverage the Component Data Catalog from Activity 4.1.1 (Discovery) – *Data Analysis*.
- ☐ Leverage the Component Master Device Inventory from Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis*.
- ☐ Leverage the Component Master Application Inventory from Activity 3.1.1 (Discovery) – *Application and Code Identification*.



Verify and validate the DLP solution functionality.

Verify and validate the DLP solution:

- ☐ Ensure the selected solutions provide the necessary capabilities by testing their ability to implement Enterprise/Component requirements.

Establish logging types generated by DLP enforcement points.

Review Enterprise/Component logging requirements:

- ☐ Leverage industry standards, such as National Institute of Standards and Technology (NIST) Special Publication (SP) 800-92r1 log management implementation planning, policies, and processes [21].

Review DLP logging events.

- ☐ Explore data enrichment with contextual information for in-depth log analysis to help create a complete story and timeline of application and event logs.
- ☐ Leverage log information to trigger the appropriate DLP action (e.g., block, alert, allow, quarantine, etc.).

Review DLP logging formats:

- ☐ Adopt a standardized format for all application and event logs consistent across all platforms for searching, filtering, and collection from various sources for unified analysis.
- ☐ Consolidate all DLP enforcement points generated logs into a centralized logging repository for advanced threat detection, malicious activity, and correlation.
- ☐ Integrate logging with the Component solutions supporting the Visibility and Analytics and/or Automation and Orchestration Pillars.

Establish DLP log analysis.

Analyze DLP logs:

- ☐ Leverage the DLP-generated logs to assess and track data security incidents. Capture and analyze standard fields in DLP logging format to identify threats and manage compliance.

Monitor DLP events:

- ☐ Implement system capability to identify, monitor, and protect data in use, data in motion, and data at rest through activity monitoring, encryption, deep packet content inspection, and contextual security analysis of transactions within a centralized management framework [22].
- ☐ In coordination with all relevant stakeholders (e.g., System Administrators (SAs), Subject Matter Experts (SMEs), owners, operators, managers, etc.), define each distinct DLP Policy Enforcement Point (PEP) access control boundary.
- ☐ Use a collaborative approach, Technology Expense Management, and Information Processes and Technology systems engineering processes, managing Users/Person Entities (PEs)/Non-Person Entities (NPEs) in approved legacy Enterprise-wide DLP or equivalent solutions.



Enable testing, verification, and validation of DLP enforcement activity.

Develop data retention for testing DLP policies:

- ☐ Establish and obtain identified and defined rules for DLP enforcement to create a comprehensive catalog of all task activities that collect and process all DLP evaluation logs and make them available to the Computer Network Defense Service Provider (CNDSP), Cyber Operations (CyberOps), or Security Operations Center (SOC/Security Operations (SecOps)).
- ☐ Establish data retention policies to make DLP-generated logs available for IR and forensic analysis.

Review, verify, validate, and audit DLP logs:

- ☐ Create a comprehensive catalog of all identified DLP logs with PEP for access control boundaries to establish a baseline list that facilitates communication between Software-Defined Networking (SDN) components.
- ☐ Review regulatory changes in data governance, such as the Health Insurance Portability and Accountability Act (HIPAA), General Data Protection Regulation (GDPR), and Payment Card Industry Data Security Standard (PCI DSS), to drive continuous compliance and update DLP policies.



Summary

This diagram outlines the Activity 4.4.1 (Discovery) – *Data Loss Prevention (DLP) Enforcement Point Logging and Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the identification and logging of Data Loss Prevention (DLP) enforcement points. It presents strategic insights that drive implementation and expected outcomes, including establishing business rules for access control that have been coordinated with Cyber Operations to support standardized logging for managing DLP enforcement.

Table 25: Activity 4.4.1 — Data Loss Prevention (DLP) Enforcement Point Logging and Analysis - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS How are DLP enforcement points identified and logged at both Enterprise and Component levels?
STRATEGIC INSIGHTS - The Component defines a DLP policy by establishing a cyber collaboration center, identifying stakeholders, and aligning with Enterprise compliance requirements for data security and Incident Response (IR). - The Component demonstrates compliance by defining enforcement points across endpoints, networks, email, and cloud, integrating DLP with IR actions, and establishing audit and reporting mechanisms. - The Component provides evidence through verification and validation testing, log analysis, and standardized event logging to track security incidents, trigger enforcement actions, and ensure regulatory compliance. - The Component leverages centralized logging and analytics to enhance threat detection, automate policy enforcement, and improve visibility into data security events. - The Component ensures ongoing compliance through continuous monitoring, regulatory updates, and periodic audits to refine DLP policies and maintain security posture.
EXPECTED OUTCOMES - Business rules for access control are established and coordinated with Cyber Operations to support standardized logging for managing DLP enforcement. - Standardized logging schema is enforced at the Component level. - Components identify enforcement points.



Activity 4.4.2 Data Rights Management (DRM) Enforcement Point Logging and Analysis

Table 26: Activity 4.4.2 — Data Rights Management (DRM) Enforcement Point Logging and Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components identify business rules for managing the accepted use of the assets managing Data Rights Management (DRM) enforcement points, such as specific services and user endpoints. Using the established Enterprise cybersecurity incident response standard, Components ensure the appropriate detail of data is captured. Additionally, protection, detection, and response use cases are developed to better outline solution coverage.	
Predecessor(s)	Successor(s)
None	4.4.6
Expected Outcomes	
- Business rules for managing accepted use of data assets are established and coordinated with Cyber Operations to support standardized logging for managing DRM. - Standardized logging schema is enforced at the Component-level. - Components identify enforcement points.	
End State	
Data Rights Management rules restrict the allowed use of information from the access control boundary.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Consider completing Activity 4.1.1 (Discovery) – *Data Analysis* and Activity 4.3.1 (Phase One) – *Implement Data Tagging and Classification Tools* prior to this activity, as this activity leverages data attributes defined in these activities.
- Consider completing Activity 1.3.1 (Phase One) – *Organizational Multi-Factor Authentication (MFA) and Identity Provider (IdP)* and Activity 1.7.1 (Phase One) – *Deny User by Default Policy* prior to this Activity, to define the Component Data Rights Management (DRM) access control policies.
- Enterprise has established Incident Response (IR) standards.
- Consider completing Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis* and Activity 3.1.1 (Discovery) – *Application and Code Identification* prior to this activity, to assist in the selection of a DRM solution.



- Leverage industry standards and best business practices to potentially extend/enhance logging standards beyond existing Enterprise/Component-defined standards.
- Activity 4.4.6 (Phase Four) – *Comprehensive Data Activity Monitoring* is defined by the Department of War (DoW) Zero Trust (ZT) Framework as a successor to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 27: Implementation Tasks for Activity 4.4.2 — Data Rights Management (DRM) Enforcement Point Logging and Analysis

Establish a Component DRM policy supporting data activity protection.
Review Enterprise data standards: ☐ Adopt the Enterprise open data architecture to enable data and information secure utilization and sharing. Review and align with the data “fit for purpose” principle for protected quality data, readily discoverable and understood within the context of its intended use [19]. ☐ Leverage the Enterprise metadata guidance to exploit metadata as a key element to effectively provide protection and context and enforce DRM control access policies [23]. Define Component-level access control policies: ☐ Leverage existing Enterprise standards to establish Component-level access control and identity authentication for information systems [24]. ☐ Leverage Multi-Factor Authentication (MFA), from Activity 1.3.1 (Phase One) – <i>Organizational Multi-Factor Authentication (MFA) and Identity Provider (IdP)</i>. ☐ Review, verify, and validate at the Component-level that the access requirements align with Least Privilege and deny-by-default policy, from Activity 1.7.1 (Phase One) – <i>Deny User by Default Policy</i>. Define Component-level data guidelines: ☐ Leverage Component Data Catalog, from Activity 4.1.1 (Discovery) – <i>Data Analysis</i> to understand data sensitivity/classification levels. ☐ Leverage global key access store as the single source of truth regarding data attributes, from Activity 4.3.1 (Phase One) – <i>Implement Data Tagging and Classification Tools</i>. Manage data assets Acceptable Use Policy (AUP): ☐ Define roles and responsibilities for data stewardship, custodian to enforce the ethical use of data created, collected, and shared across all infrastructure platforms in accordance with AUP. Integrate



DRM with Data Loss Prevention (DLP) tools to apply protective countermeasures and encryption to sensitive and regulated data types [19].

Identify DRM enforcement and decision points.

Define DRM key enforcement points:

☐ Adopt a strong encryption algorithm(s) for content protection at either disk or file level. Enable robust encryption for data at rest, in motion, and in use.

- Where possible, leverage Enterprise and industry standards, such as National Institute of Standards and Technology (NIST) Federal Information Processing Standards (FIPS) 140-3 Security Requirements for Cryptographic Modules.

☐ Establish dynamic permission management and licensing control for sensitive and copyrighted digital content. Enable file tampering detection and protection.

Identify DRM enforcement points:

☐ Identify DRM enforcement points within the Component environment:

- Endpoint DRM: Install DRM agents on endpoint devices to monitor and safeguard sensitive data where possible.
- Web DRM: Deploy web gateways to scan web traffic for sensitive data.
- Network DRM: Deploy network appliances with DRM built-in capability.
- Email DRM: Protect email servers with DRM monitoring.
- Cloud DRM: Adopt cloud-based DRM solutions.

Establish DRM interoperability standards aligned with the Enterprise cybersecurity IR.

Identify key stakeholders:

☐ Establish a cyber collaboration center to assess cyber incidents and securely share findings with approved partners. Review Enterprise initiatives and compliance requirements on Indicators of Compromise (IoC), data breaches, and IRs.

- Create dedicated internal teams.
- Identify Enterprise-approved Communities of Interest (COI).
- Establish broader national partners.

Define cyber defense and IR strategy:

☐ Collaborate with mission partners, various agencies, and other Components to adopt a proactive cyber defense plan to protect critical assets against cyber threats through deterrence, prevention, detection, containment, and response.

Integrate DRM solutions with data security tools:

☐ Select complementary tools, compatible DRM solutions, and data security tools that offer Application Programming Interfaces (APIs) and integration capabilities to enable unified Access Control and policy enforcement.



☐ Integrate an Identity and Access Management (IAM) policy with a DRM solution to enable and restrict data Access Control based on User/Person Entity (PE)/Non-Person Entity (NPE) roles, permissions, and contextual attributes.

Review DRM compliance requirements:

☐ Establish a centralized DRM protection solution to monitor and improve data compliance across various infrastructure platforms, file repositories, network segments, and host-based and cloud-based storage.

☐ Import extracted DRM log schema-compliant metrics for tracking into a consolidated, central repository or designated ticket tracking system(s).

☐ Normalize the data to ensure consistency across different authenticated and approved sources.

Select a DRM solution.

Select a DRM solution that meets the needs of the Component:

☐ Leverage the previously created Component DRM policy.

☐ Leverage the Component Master Device Inventory, from Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis*.

☐ Leverage the Component Master Application Inventory, from Activity 3.1.1 (Discovery) – *Application and Code Identification*.

☐ Leverage the Component Data Catalog, from Activity 4.1.1 (Discovery) – *Data Analysis*.

Verify and validate DRM solution functionality.

Review data interoperability requirements:

☐ Ensure the selected solutions provide the necessary capabilities by testing their ability to implement Enterprise/Component requirements.

☐ Enable the adoption of diverse DRM content formats with offline access capabilities and support for legacy systems. Review and evaluate the interoperability requirements for DRM implementation.

☐ Prioritize DRM solutions that support multiple open DRM standards and APIs and enable format conversions to ensure compatibility across different platforms and devices without compromising security.

☐ Select and leverage technology and technological systems to protect copyrighted digital content and limit illegal sharing and unapproved spread.

Establish logging analysis and types generated by DRM enforcement points.

Review Enterprise/Component logging requirements:

☐ Leverage industry standards, such as National Institute of Standards and Technology (NIST) Special Publication (SP) 800-92r1 log management implementation planning, policies, and processes [25].

☐ Verify and validate that standardized logging procedures are sufficient to support DRM toolset configuration.

**Review DRM logging events:**

- ☐ Explore data enrichment with contextual information for in-depth log analysis to help create a complete story and timeline of application and event logs.
- ☐ Leverage log information to trigger the appropriate DRM action (e.g., block, alert, allow, quarantine, etc.).

Review DRM logging formats:

- ☐ Adopt a standardized format for all application and event logs consistent across all platforms for searching, filtering, and collection from various sources for unified analysis.
- ☐ Consolidate all DRM enforcement point-generated logs into a centralized logging repository for advanced threat detection, malicious activity, and correlation.
- ☐ Integrate logging with the Component solutions supporting the Visibility and Analytics and/or Automation and Orchestration Pillars.

Enable testing and monitoring of DRM enforcement activity.

Develop data activity monitoring for testing of DRM policies:

- ☐ Establish and obtain identified and defined rules for DRM enforcement to create a comprehensive catalog of all task activities that collect and process all DRM evaluation logs and make them available to the Computer Network Defense Service Provider (CNDSP), Cyber Operations (CyberOps), or Security Operations Center (SOC/SecOps).
- ☐ Establish data retention policies to make DRM-generated logs available for IR and forensic analysis.

Review, verify, validate, and audit DRM logs:

- ☐ Create a comprehensive catalog of all identified DRM logs with Policy Enforcement Points (PEPs) for Access Control boundaries to establish a baseline list that facilitates communication between Software-Defined Networking (SDN) components.
- ☐ Review regulatory changes on data governance, such as the Health Insurance Portability and Accountability Act (HIPAA), General Data Protection Regulation (GDPR), Payment Card Industry Data Security Standard (PCI DSS), and mission-critical data assets to drive continuous compliance and update DRM policies.
- ☐ Review DRM PEP with approved, authoritative, and authenticated sources from across and within the Enterprise and extended to the Communities of Interest (COI).
- ☐ Normalize the data to ensure consistency across different approved authentication sources.



Summary

This diagram outlines the Activity 4.4.2 (Discovery) – *Data Rights Management (DRM) Enforcement Point Logging and Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on identification and logging of Data Rights Management (DRM) enforcement points. It presents strategic insights that drive implementation and expected outcomes, including establishing business rules for access control that have been coordinated with Cyber Operations to support standardized logging for managing DRM enforcement.

Table 28: Activity 4.4.2 — Data Rights Management (DRM) Enforcement Point Logging and Analysis - Workflow

 ZERO TRUST READINESS ASSESSMENT QUESTIONS 1. How are DRM enforcement points identified and logged at both Enterprise and Component levels?
 STRATEGIC INSIGHTS • The Component defines an extended File Activity Monitoring (FAM) solution that includes regulatory-protected data, such as Controlled Unclassified Information (CUI), Personally Identifiable Information (PII), and Protected Health Information (PHI). • The Component demonstrates compliance by ensuring the extended FAM solution aligns with Enterprise security and regulatory requirements. • The Component provides evidence through verification and validation testing, confirming functionality, security, and operational impact. • The Component leverages periodic reassessments to maintain comprehensive coverage and ensure continued compliance. • The Component ensures ongoing alignment with evolving Enterprise mandates through continuous monitoring and policy updates.
 EXPECTED OUTCOMES 1. Business rules for managing accepted use of data assets are established and coordinated with Cyber Operations to support standardized logging for managing DRM. 2. Standardized logging schema is enforced at the Component-level. 3. Components identify enforcement points.



Network and Environment Pillar

Capability 5.1 Data Flow Mapping

Table 29: Capability 5.1 — Data Flow Mapping

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
5 - Network and Environment	5.1 - Data Flow Mapping
Description	
DoW Components reconcile data flows by gathering, mapping, and visualizing network traffic data flows and patterns to ensure authorized access and protection for network and DAAS resources specifically tagging programmatic (e.g., API) access when possible.	
Impact to ZT	
Sets the foundation for network segmentation and tighter access control by understanding data traffic on the network.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component begins by gathering network traffic data to identify and document data flows across all systems, applications, and Data, Applications, Assets, and Services (DAAS) resources.
- Traffic patterns are mapped and visualized using specialized tools, highlighting connections between Users/Person Entities (PEs), devices, applications, and data repositories.
- Programmatic access, such as Application Programming Interface (API) traffic, is identified and tagged to differentiate it from User/PE or device-generated data flows, ensuring more granular insights into network activity.
- Analysis of the mapped data flows reveals several unapproved or unexpected connections between systems, prompting further investigation.
- Granular access control rules and policies are defined based on the mapped data flows, ensuring that only approved Users/PEs, devices, and services can interact with specific network segments and resources.
- During implementation, the Component applies these policies to enforce network segmentation, isolating sensitive resources and limiting exposure to unapproved traffic.



NSA | Zero Trust Implementation Guideline Discovery Phase

- A routine review of data flow maps reveals an anomaly: A device is attempting to access DAAS resources outside its designated scope. The connection is automatically blocked and an alert is raised.
- The Component integrates continuous monitoring tools to ensure that changes in network traffic patterns are detected and updated in the data flow maps in near real-time.
- Security analysts utilize visualized data flow maps to verify and validate compliance with Zero Trust (ZT) principles, identifying opportunities for additional network segmentation and policy refinement.
- By reconciling, mapping, and visualizing data flows, the Component gains a comprehensive understanding of its network traffic, enabling tighter access controls, enhanced segmentation, and improved protection of network and DAAS resources.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** By mapping and visualizing data flows, Components can identify unapproved access attempts and anomalies, leading to improved security posture.
- **Improved Compliance:** Continuous monitoring, verification, and validation against ZT principles help Components maintain compliance with regulatory requirements.
- **Granular Access Control:** This capability enables the definition of precise access control policies, ensuring that only approved users, personnel, and devices can access sensitive resources.
- **Informed Decision-Making:** With a comprehensive understanding of network traffic, Components can make better-informed decisions regarding network segmentation and resource allocation.
- **Proactive Threat Management:** Continuous monitoring and real-time alerts enable Components to respond swiftly to potential threats, reducing the risk of data breaches.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- API Gateway and Management solutions
- API Integration Frameworks
- Behavioral Analytics solutions
- Anomaly Detection
- Monitoring and Analytics solutions
- Threat Intelligence Platform (TIP)



Activity 5.1.1 Define Granular Control Access Rules and Policies Part 1

Table 30: Activity 5.1.1 — Define Granular Control Access Rules and Policies Part 1

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Enterprise, working with the Components, creates granular network access rules and policies. Associated Concept of Operations (CONOPS) are developed in alignment with access policies, as well ensure future supportability. Once agreed upon, Components will implement these access policies into existing network technologies (e.g., Next-Generation Firewalls, Intrusion Prevention Systems, etc.) to improve initial risk levels and ensure future interoperability.	
Predecessor(s)	Successor(s)
None	5.1.2, 5.2.1
Expected Outcomes	
- Enterprise provides standardized policy for deployment. - Identify Communities of Interest. - Components implement access policies according to Enterprise standards and CONOPS.	
End State	
Provide access control over multiple identities, applications, devices, and traffic levels, reducing the risk of unauthorized access and increasing visibility on monitoring for threat response.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Ensure alignment and development of granular network access rules and policies. Coordinate with Enterprise tenants and Components to develop granular network environment access rules and policies that align with a Concept of Operations (CONOPS)-based Interface Control Document (ICD) or equivalent approach.
- Ensure future supportability of granular network access rules without escalated privileges. Establish granular network access rules that support future scalability without requiring escalated privileges.
- Ensure complete network visibility and security gateway boundaries for control access monitoring.
- Define granular access control permissions, objectives, and goals.
- Leverage the existing CONOPS as the basis for a Capabilities-Based Assessment (CBA).



- Enforce separation of duties and Least Privilege principles to avoid conflicting responsibilities and potential privilege creep.
- Consider completing Activity 4.2.1 (Phase One) – *Define Data Tagging Standards* prior to this activity, to categorize data and network environment assets.
- Consider completing Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis*, Activity 3.1.1 (Discovery) – *Application and Code Identification*, and Activity 4.1.1 (Discovery) – *Data Analysis* prior to this activity, to link asset inventories to classification levels.
- Activity 5.1.2 (Phase One) – *Define Granular Control Access Rules and Policies Part 2* and Activity 5.2.1 (Discovery) – *Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)* are defined by the Department of War (DoW) Zero Trust (ZT) Framework as successors to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 31: Implementation Tasks for Activity 5.1.1 — Define Granular Control Access Rules and Policies Part 1

Define granular control access policy objectives and scope.
Collaborate with key stakeholders and the Enterprise to clearly outline, identify, create, and establish granular network access rules and policies: ☐ Conduct cross-organizational joint workgroups to collaboratively define Network Access Control (NAC) rulesets and policies. ☐ Identify, create, and maintain a comprehensive inventory of all approved systems and code sources for NAC rulesets and policies. Identify the drivers for establishing the granular control access policies: ☐ Tailor the control access policies to address each driver's specifics, whether for regulatory compliance or data security requirements. ☐ Determine the level of granularity required for the NAC policy (e.g., file level, endpoint device, network segments, etc.).



Leverage existing data classification rules and asset inventories developed in prior activities.

Review data and asset classification:

☐ Leverage data classification initiated with data tagging, from Activity 4.2.1 (Phase One) – *Define Data Tagging Standards*, to categorize data and network environment assets based on sensitivity level and determine access conditions.

Leverage existing asset inventories:

- ☐ Link asset inventories to classification levels to establish access control permissions based on role, risk, and sensitivity levels aligned with existing CONOPS.
- Leverage Component Master Device Inventory, from Activity 2.1.1 (Discovery) – *Device Health Tool Gap Analysis*.
 - Leverage Component Master Application Inventory, from Activity 3.1.1 (Discovery) – *Application and Code Identification*.
 - Leverage Component Master Data Inventory, from Activity 4.1.1 (Discovery) – *Data Analysis*.

Define roles and responsibilities and identify Communities of Interest (COI).

Identify roles:

- ☐ Collaborate with key stakeholders to define Users/Person Entities (PEs)/Non-Person Entities (NPEs) roles requiring Data, Applications, Assets, and Services (DAAS) granular access control.
- ☐ Leverage the separation of duties principle to limit excess data access and authority to any role.

Assign responsibilities:

☐ Collaborate with all key stakeholders (e.g., system administrators, Subject Matter Experts (SMEs), system owners, operators, managers, etc.) to define responsibilities associated with each unique role to determine network access requirements.

Establish a COI collaboration:

☐ Leverage the Enterprise guidelines in data exchange requirements and CONOPS to verify, validate, and identify COI applicable to the granular control access rules and policies.

Develop access control policies aligned with the approved Enterprise standards and CONOPS.

Establish permission rules:

- ☐ Role-Based Access Control (RBAC), where permissions are assigned based on the role of the User/PE/NPE.
- ☐ Attribute-Based Access Control (ABAC), where a combination of several factors related to User/PE/NPE, data, and the environment are leveraged to restrict or allow network access based on a set of predefined rules and conditions.
- ☐ Discretionary-Based Access Control (DBAC), where controls are implemented based on specific rules and privileges granted to a specific requestor.

**Define contextual access requirements:**

☐ Consolidate and normalize network access control data. Use Application Programming Interfaces (APIs), scripts, feeds, or other integration methods to extract detailed data and metadata from each approved, authorized, and authenticated source. Gather specific information, such as usernames, namespaces, unique identifiers, associated groups, location, device compliance status, tags, and labels, to utilize in interoperable granular network environment access controls [26].

Define control access rules:

- ☐ Leverage data encryption to further safeguard highly sensitive data and restrict access based on predefined data access rules. Focus on interoperable granular network access controls by gathering specific information, such as usernames, namespaces, unique identifiers, associated groups, tags, and labels [26].
- ☐ Define dynamic access control policies where access rules are adaptive based on additional conditions, such as granting full rights to specific resources while on-premises but limited while teleworking.

Adopt Just-In-Time (JIT) access:

☐ Consider temporary access privileges where Users/PEs/NPEs are granted temporary privileged access on-demand to complete specific tasks or actions, and those rights are terminated once the action or timeline is executed.

Establish testing, verification, and validation procedures for control access rules and policy enforcement.

Adopt comprehensive logging of all activities:

- ☐ Establish a policy to log all access requests and attempts with sufficient metadata information (e.g., timestamp, User Identification (ID), platform, etc.) to allow for forensic analysis.
- ☐ Develop a policy to securely store logs generated for control access-related activities.

Regular updates and audits:

- ☐ Enable periodic review of established access control policies to verify and validate compliance, enforceability, and effectiveness.
- ☐ Update policies as needed to support changing business needs, cyber threat landscape, and the broader stakeholder feedback.

Continuous monitoring:

- ☐ Adopt continuous monitoring to track all access requests and attempt activities to ensure compliance with the granular access control policies.
- ☐ Establish alerting policies as part of the comprehensive access control activities, logging where alerts are triggered for detected User/PE/NPE access anomalies.



Summary

This diagram outlines the Activity 5.1.1 (Discovery) – *Define Granular Control Access Rules and Policies Part 1* of Department of War (DoW) Zero Trust (ZT) Framework, focusing on defining granular access rules and policies at both the Enterprise and organizational levels. It presents strategic insights that drive implementation and expected outcomes, including the implementation of access policies according to Enterprise standards and Concept of Operations (CONOPS).

Table 32: Activity 5.1.1 — Define Granular Control Access Rules and Policies Part 1 - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS
1. How are granular network access rules and policies being defined at both Enterprise and Component levels?
STRATEGIC INSIGHTS
• The Component defines the objectives and scope for granular access control policies by collaborating with key stakeholders to outline Network Access Control (NAC) rules, data classification, and asset inventory alignment with Enterprise standards. • The Component demonstrates a structured approach to identifying regulatory and security drivers for granular access controls, assessing the required level of detail for policy enforcement, and ensuring alignment with data classification and sensitivity levels. • The Component provides a documented framework for defining roles, responsibilities, and Communities of Interest (COI), establishing access models, such as Role-Based Access Control (RBAC), Attribute-Based Access Control (ABAC), and Discretionary-Based Access Control (DBAC) to support policy development. • The Component leverages Enterprise guidelines, existing data inventories, and policy frameworks to map access control requirements, ensuring comprehensive tracking of approved systems, applications, and data sources for future enforcement. • The Component ensures ongoing alignment with Enterprise security policies by outlining requirements for periodic policy reviews, access control audits, and continuous monitoring strategies to support compliance and evolving operational needs.
EXPECTED OUTCOMES
1. Enterprise provides standardized policy for deployment. 2. Identify Communities of Interest. 3. Components implement access policies according to Enterprise standards and CONOPS.



Capability 5.2 Software-Defined Networking (SDN)

Table 33: Capability 5.2 — Software-Defined Networking (SDN)

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
5 - Network and Environment	5.2 - Software-Defined Networking (SDN)
Description	
DoW Components define API decision points and implement SDN programmable infrastructure to separate the control and data planes and centrally manage and control the elements in the data plane. Integrations are conducted with decision points and segmentation gateway to accomplish the plane separation. Analytics are then integrated to real-time decision making for access to resources.	
Impact to ZT	
Enables the control of packets to a centralized server, provides additional visibility into the network, and enables integration requirements.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component begins by defining Application Programming Interface (API) decision points that will enable programmable control of network traffic, ensuring consistent application of access policies across the network.
- A Software-Defined Networking (SDN) infrastructure is implemented to separate the control and data planes, centralizing the management of network elements and improving visibility into traffic flows.
- Network flows are segmented into three (3) distinct planes: control, management, and data, providing better isolation and security for sensitive operations.
- A network asset discovery process is conducted to identify and document all connected devices, optimizing traffic management and ensuring all assets comply with SDN policies.
- Integration of decision points with the segmentation gateway ensures that API-driven policies are enforced at every point of interaction within the network.
- The SDN infrastructure is integrated with analytics solutions to enable real-time visibility into traffic patterns and decision-making for resource access requests.
- A suspicious packet attempting to bypass a segmentation gateway is detected by the SDN analytics solution. The centralized controller blocks the packet, preventing unauthorized access to sensitive resources.



- During a routine review, SDN analytics reveal suboptimal routing in the data plane. The controller automatically adjusts the routing configuration to optimize performance without compromising security.
- Real-time access decisions are further enhanced by integrating User/Person Entity (PE)/Non-Person Entity (NPE) and application attributes from other Zero Trust (ZT) pillars, ensuring traffic is only allowed when fully authorized.
- By leveraging SDN programmable infrastructure and real-time analytics, the Component gains granular control over network traffic and enhances security through segmentation for managing and protecting network resources.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** By implementing SDN and segmentation, Components can isolate sensitive operations and reduce the risk of lateral movement by attackers.
- **Improved Traffic Management:** Centralized control over network traffic enables better optimization and routing, resulting in enhanced performance.
- **Real-Time Analytics:** Integration with analytics tools provides visibility into traffic patterns, enabling proactive decision-making and rapid response to threats.
- **Alignment with Zero Trust Principles:** The capability supports a ZT architecture by ensuring that access decisions are based on comprehensive User/PE, device, and application attributes.
- **Operational Efficiency:** Automating network management tasks reduces the burden on Information Technology (IT) staff, enabling them to focus on strategic initiatives rather than routine maintenance.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Network Function Virtualization (NFV)
- Network Virtualization
- Micro-Segmentation
- Macro-Segmentation
- Internet Protocol Security (IPsec)
- Traffic Filtering and Inspection



Activity 5.2.1 Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)

Table 34: Activity 5.2.1 — Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Enterprise works with Components to define the necessary APIs and other programmatic interfaces that enable Software-Defined Networking (SDN) or alternative networking approach functionalities. These APIs will enable authentication decision point, application delivery control proxy, and segmentation gateways automation.	
Predecessor(s)	Successor(s)
5.1.1	5.2.2
Expected Outcomes	
SDN or alternative networking approach APIs are developed using machine-readable patterns and protocols and implemented (per "Standardized API Calls & Schemas Pt. 1 and Pt. 2").	
End State	
SDN or alternative networking approach APIs are standardized and implemented, enabling robust automation of authentication decision points, application delivery control proxies, and segmentation gateways. This standardization ensures consistent and secure SDN or alternative networking approach operations across the Enterprise, enhancing network flexibility, scalability, and security.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Activity 5.1.1 (Discovery) – *Define Granular Control Access Rules and Policies Part 1* is defined by the Department of War (DoW) Zero Trust (ZT) Framework as a predecessor to this activity.
- Verify and validate that Application Programming Interfaces (APIs) are programmatically standardized and properly implemented to support Software-Defined Networking (SDN) functionality.
- Promote an agile network infrastructure design.
- Approve SDN flow control.
- Activity 5.2.2 (Phase One) – *Implement Software-Defined Networking (SDN) Programmable Infrastructure* is defined by the DoW ZT Framework as a successor to this activity.



Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 35: Implementation Tasks for Activity 5.2.1 — Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)

Collaborate with the Enterprise to review, develop, and adopt existing API technical guidance for successful SDN deployment.
Define objectives and scope: ☐ Collaborate with key stakeholders and the Enterprise to provide an overview of SDN API concepts and design principles. ☐ Collaborate with Enterprise stakeholders to define baseline functional, performance, and security requirements for APIs, scripts, secure programming, feeds, and protocols. Ensure these requirements support consistent, reliable, and quality-controlled real-time operations for SDN or equivalent technologies. Key components of SDN APIs: ☐ Simplified network control through layer abstraction. ☐ Enable programmatic control through network automation. ☐ Centralized SDN controller to provide a single point of control for the entire network. ☐ API security through strong authentication and authorization. Align and optimize SDN compliance sustainability: ☐ Design APIs that enhance organizational SDN capabilities, emphasizing optimal uptime and long-term sustainability. Align API development with organizational guidance and governance standards, ensuring broader compliance with open standards and interoperability.
Review the API normalization and standardization concept.
Establish a common data model: ☐ Establish a standardized schema, a common data model for use across all API endpoints. ☐ Define data sharing between API components for seamless integration, consistency, and data interoperability. Review existing open standards and protocols: ☐ Promote interoperability and open standards design architecture for easy and more extensive adoption. Leverage open standards and protocols to ensure compatibility between SDN API components.

**Design for security compliance:**

- ☐ Establish secure communication channels as part of the functional requirements of SDN API design and development.
 - Enforce strong security mechanisms, such as authentication and authorization, to protect the entire SDN architecture.
 - Restrict access to the SDN controller and management plane only to approved entities.
 - Apply Least Privilege principle and Just-In-Time (JIT) access where applicable.
 - Incorporate log management/mechanisms as part of the API framework for implementation.

Establish API functional requirements for SDN implementation.

Review Northbound APIs:

- ☐ Leverage and design northbound APIs to establish communication between the SDN controller and the network applications.
- ☐ Enable network automation and dynamic traffic management through APIs.

Review Southbound APIs:

- ☐ Leverage and design southbound APIs to enable communication between the SDN controller and the network devices.
- ☐ Define the protocol standards and processes required to configure network devices through the SDN controller.

Review Data Plane APIs:

- ☐ Define the data plane APIs and related components responsible for packet forwarding and flow table updates.
- ☐ Enable SDN real-time operations, high performance, and traffic path management.

Define Telemetry APIs:

- ☐ Define network performance metrics and telemetry data statistics to enhance network troubleshooting, optimization, and security.
- ☐ Leverage API versioning to ensure compatibility between different components of the SDN architecture.



Summary

This diagram outlines the Activity 5.2.1 (Discovery) – *Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on defining and standardizing Software-Defined Networking (SDN) Application Programming Interfaces (APIs) across the Enterprise. It presents strategic insights that drive the implementation and expected outcomes, including the development of SDN or alternative networking approach APIs using machine-readable patterns and protocols.

Table 36: Activity 5.2.1 — Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs) - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS 1. How are SDN APIs being defined and standardized across the DoW Enterprise?
STRATEGIC INSIGHTS • The Component defines objectives and technical requirements for API-driven SDN deployment by collaborating with Enterprise stakeholders to align SDN API concepts, security mechanisms, and real-time operations standards. • The Component demonstrates a structured approach to API normalization by establishing a common data model, ensuring interoperability between SDN components, and leveraging open standards to facilitate seamless integration across network environments. • The Component provides a documented framework for SDN API functional requirements by reviewing Northbound, Southbound, Data Plane, and Telemetry APIs, defining their roles in network automation, traffic management, and performance optimization. • The Component leverages secure API design principles, enforcing authentication and approval controls to protect SDN controllers, management planes, and network communication channels from unapproved access. • The Component ensures long-term SDN compliance and sustainability by aligning API development with governance standards, optimizing telemetry data for continuous monitoring and maintaining compatibility across evolving SDN architectures.
EXPECTED OUTCOMES 1. SDN or alternative networking approach APIs are developed using machine readable patterns and protocols and implemented (per "Standardized API Calls & Schemas Pt1 and Pt2").



Automation and Orchestration Pillar

Capability 6.1 Policy Decision Point (PDP) and Policy Orchestration

Table 37: Capability 6.1 — Policy Decision Point (PDP) and Policy Orchestration

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
6 - Automation and Orchestration	6.1 - Policy Decision Point (PDP) and Policy Orchestration
Description	
DoW Components initially collect and document all rule-based policies to orchestrate across the security stack for effective automation; DAAS access procedures and policies will be defined, implemented, and updated. DoW Components mature this capability by establishing PDPs and PEPs (including the Next-Generation Firewall) to make DAAS resource determinations and enable, monitor, and terminate connections between a user/device and DAAS resources according to predefined policy.	
Impact to ZT	
PDPs and PEPs ensure proper implementation of DAAS access policies to users or endpoints that are properly connected (or denied access) to requested resources.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component initiates a comprehensive review of its existing Data, Applications, Assets, and Services (DAAS) access procedures, collecting and documenting all rule-based policies to create a centralized policy inventory.
- Policies are updated to align with Zero Trust (ZT) principles, ensuring granular access control rules based on User/Person Entity (PE) identity, Non-Person Entity (NPE) compliance, and data sensitivity.
- A Policy Decision Point (PDP) is established to serve as the central authority for evaluating and enforcing DAAS access policies dynamically, embodying the ZT approach by continuously assessing trust levels before granting access.
- Policy Enforcement Points (PEPs), including a Next-Generation Firewall (NGFW), are deployed to enforce access decisions made by the PDP, monitoring and controlling traffic to DAAS resources.
- A User/PE attempts to access a DAAS resource from an unmanaged NPE. The PEP consults the PDP, which evaluates the request against predefined policies and denies access due to the NPE's non-compliance.



NSA | Zero Trust Implementation Guideline Discovery Phase

- The Component develops an Enterprise Security Profile that defines the attributes, risk tolerances, and access controls required for various User/PE roles, NPEs, and data types.
- Real-time monitoring and automation are integrated into the PDP and PEP framework, enabling the system to dynamically adapt policies in response to emerging threats or changes in User/PE or NPE status.
- During a simulated attack, the PDP detects an anomaly in a User/PE's access pattern and instructs the PEP to terminate the connection, preventing unauthorized access to critical DAAS resources.
- Policy orchestration solutions provide detailed logs and analytics on access decisions, enabling security teams to refine policies and ensure they remain effective over time.
- By leveraging PDPs and PEPs in conjunction with updated policies and automation, the Component ensures secure, monitored, and dynamic access to DAAS resources.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** By implementing PDPs and PEPs, Components can enforce strict access controls, reducing the risk of unapproved access to sensitive resources.
- **Dynamic Policy Adaptation:** Real-time monitoring allows for policies to adapt swiftly to emerging threats, ensuring ongoing protection.
- **Centralized Policy Management:** A centralized policy inventory simplifies the management and updating of access rules, promoting consistency and compliance.
- **Improved Compliance:** Aligning with ZT principles enables Components to meet regulatory requirements and standards, thereby enhancing their overall compliance posture.
- **Operational Efficiency:** Automating access decisions reduces the burden on security teams, allowing them to focus on strategic initiatives rather than manual policy enforcement.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Identity and Access Management (IAM)
- Identity-Based Access Control (IBAC)
- Attribute-Based Access Control (ABAC)
- Role-Based Access Control (RBAC)
- Policy Decision Points (PDPs)
- Policy Enforcement Points (PEPs)
- Structured Threat Information eXpression (STIX) protocols
- Trusted Automated Exchange of Intelligence Information (TAXII)



Activity 6.1.1 Policy Inventory and Development

Table 38: Activity 6.1.1 — Policy Inventory and Development

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Enterprise works with Components to catalog and inventory existing cybersecurity policies and standards. Policies are updated and created in cross-pillar activities as needed to meet critical ZT Target-level functionality.	
Predecessor(s)	Successor(s)
None	3.5.1
Expected Outcomes	
• Component policies have been collected in reference to applicable compliance and risk (e.g., NIST). • Policies have been reviewed for missing Pillars and Capabilities by Enterprise per the ZT RA. • Enterprise and Components make updates to missing areas of policies to meet the capabilities per the ZT RA.	
End State	
Policies are aligned to support interoperability and enable ZT functionality.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- The Enterprise provides the Component guidance and oversight throughout this activity to ensure alignment with Zero Trust (ZT).
- Conduct all policy inventory and development with consideration for applicable compliance frameworks (e.g., National Institute of Standards and Technology (NIST)) and identified risk profiles.
- Activity 3.5.1 (Phase Three) – *Continuous Authorization to Operate (cATO) Part 1* is defined by the Department of War (DoW) ZT Framework as a successor to this activity.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.



Table 39: Implementation Tasks for Activity 6.1.1 — Policy Inventory and Development

Collaborate with the Enterprise to inventory and catalog existing cybersecurity policies and standards.
Inventory and catalog existing cybersecurity policies and standards: ☐ The Enterprise and Component collaborate to define a standardized format for policy documentation to facilitate comparison and analysis across the Component environment. ☐ In collaboration with the Enterprise, Component collects cybersecurity policies and standards for inventory and cataloging (e.g., access control, identification, and authentication policies). ☐ Component documents the scope of the inventory (e.g., systems, data types, User/Person Entity (PE)/Non-Person Entity (NPE) groups are covered, etc.) and any known limitations. Document initial gaps and inconsistencies during inventory and cataloging: ☐ Component documents preliminary gaps and/or conflicting policies discovered in cybersecurity policies and standards during inventory and cataloging.
Determine gaps for identified cybersecurity policies and standards across all Pillars and Capabilities according to the Zero Trust Reference Architecture (ZT RA).
Review and analyze Component cybersecurity policies and standards to identify gaps in accordance with the ZT RA: ☐ The Enterprise and Component collaboratively review existing policies and standards for alignment with ZT principles. ☐ Perform gap analysis of Component cybersecurity policies and standards to determine and document gaps across Pillars and Capabilities according to the ZT RA. ☐ The Enterprise and Component leverage documentation of discovered gaps across Pillars and Capabilities according to the ZT RA, detailing missing or inadequate policies. Review and validate Enterprise gap analysis: ☐ Review the gap analysis report for accuracy and completeness.
Create and/or update policies and fill identified gaps to meet critical ZT Target-level functionality.
Enterprise and Component collaborate to develop remediation plans for identified gaps: ☐ Develop a remediation plan outlining the steps to address each gap identified in the previous task, in accordance with Enterprise and Component policies and procedures, prioritizing gaps based on overall ZT implementation strategy. Enterprise and Component develop and/or update existing policies to address identified gaps: ☐ Ensure new or existing policies are: • Consistent with applicable laws, regulations, and industry best practices. • Designed to support interoperability and enable ZT functionality across the Enterprise and Component.



Implement updated policies in cross-pillar activities:

- ☐ Communicate policy updates to relevant stakeholders.
- ☐ Apply updated policies for cross-pillar activities, where applicable.

Component maintains cybersecurity policies through continuous lifecycle management.

Based on Enterprise guidance, the Component establishes a continuous lifecycle management strategy:

- ☐ Component establishes a continuous lifecycle management strategy that:
 - Maintains cybersecurity policies.
 - Incorporates feedback from stakeholders.
 - Meets the evolving needs of the Component.
 - Has a defined schedule for periodic policy reviews and updates.
 - Counters emerging threats.
- ☐ As required, Component provides progress reports to the Enterprise on policy inventory completion, gap remediation, and policy update implementation.
- ☐ Component investigates opportunities to integrate policy information with existing security solutions to automate policy enforcement and compliance monitoring.



Summary

This diagram outlines the Activity 6.1.1 (Discovery) – *Policy Inventory and Development* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on effective automation of access decisions using rule-based policy collection and documentation across the security stack. It presents strategic insights driving implementation and expected outcomes that include the collection of Component policies in reference to applicable compliance and risk (e.g., National Institute of Standards and Technology (NIST)).

Table 40: Activity 6.1.1 — Policy Inventory and Development - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS	
1. How are all rule-based policies collected and documented to orchestrate across the security stack for effective automation of access decisions?	
STRATEGIC INSIGHTS	
• The Component defines a cybersecurity policy inventory by collaborating with the Enterprise to catalog and align existing policies and standards with ZT principles. • The Component demonstrates compliance by identifying policy gaps, updating Enterprise policies, and ensuring interoperability across cybersecurity pillars to meet ZT Target-Level functionality. • The Component provides evidence through policy reviews, cross-pillar alignment, and verification of cybersecurity policies against Zero Trust Reference Architecture (ZT RA) requirements. • The Component leverages continuous lifecycle management to monitor, update, and refine policy frameworks, ensuring full interoperability and alignment with evolving cybersecurity needs. • The Component ensures ongoing compliance by applying and validating cybersecurity policies, maintaining an adaptive policy management system, and supporting interoperability for ZT implementation.	
EXPECTED OUTCOMES	
1. Component policies have been collected in reference to applicable compliance and risk (e.g., NIST). 2. Policies have been reviewed for missing Pillars and Capabilities by Enterprise per the ZT RA. 3. Enterprise and Components make updates to missing areas of policies to meet the capabilities per the ZT RA.	



Capability 6.2 Critical Process Automation

Table 41: Capability 6.2 — Critical Process Automation

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
6 - Automation and Orchestration	6.2 - Critical Process Automation
Description	
DoW Components employ automation methods, such as RPA, to address repetitive, predictable tasks for critical functions, such as data enrichment, security controls, and incident response workflows, according to system security engineering principles.	
Impact to ZT	
Response time and capability is increased with orchestrated workflows and risk management processes.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component conducts a task automation analysis to identify repetitive and predictable tasks across critical functions, such as data enrichment, security controls, and Incident Response (IR) workflows.
- Robotic Process Automation (RPA) is implemented to handle routine tasks like log analysis, vulnerability scanning, and incident ticket creation, freeing up analysts to focus on higher-value activities.
- An automated workflow is established to enrich security alerts with contextual data, such as Non-Person Entity (NPE) compliance, User/Person Entity (PE) identity, and threat intelligence, improving incident prioritization.
- During a phishing attack simulation, the automation system detects a suspicious email, isolates it, and extracts Indicators of Compromise (IoC) for further analysis without manual intervention.
- The IoC are automatically cross-referenced with external threat intelligence feeds and flagged for inclusion in the Component’s threat database.
- Security controls, such as firewall rules and endpoint protection configurations, are dynamically updated in response to the detected threat, reducing exposure time.
- An IR workflow is triggered, orchestrating automated tasks like quarantining affected endpoints, notifying stakeholders, and generating a detailed incident report.



NSA | Zero Trust Implementation Guideline Discovery Phase

- The automation framework integrates with Enterprise workflow solutions to ensure that all critical steps, including manual approvals and escalation protocols, are completed seamlessly.
- Continuous monitoring and analysis of automated processes provide insights into their effectiveness, enabling the Component to optimize workflows and reduce response times further.
- By employing automation methods like RPA and orchestrating critical workflows, the Component improves response times, enhances risk management and system security engineering practices.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Increased Efficiency:** Automating repetitive tasks enables analysts to focus on higher-value activities, thereby improving overall productivity.
- **Improved IR:** Automated workflows enhance the speed and effectiveness of IR, reducing potential damage from threats.
- **Enhanced Accuracy:** Automation minimizes human error in critical processes, leading to more reliable outcomes in security operations.
- **Better Resource Allocation:** By automating routine tasks, Components can allocate resources more effectively, ensuring that skilled personnel are engaged in strategic initiatives.

Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Automation Frameworks and Libraries
- Automation Orchestration solutions
- Continuous Integration/Continuous Delivery (or Deployment) (CI/CD) Pipelines
- Disaster Recovery and Business Continuity solutions
- Managed Detection and Response (MDR)



Activity 6.2.1 Task Automation Analysis

Table 42: Activity 6.2.1 — Task Automation Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components identify and enumerate all task activities that can be executed both manually and in an automated fashion. Task activities are organized into automated and manual categories. Manual activities are analyzed for retirement.	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
- Automatable tasks are identified. - Tasks are enumerated. - Components create process flow of all cybersecurity defense automations tasks developed with an independent audit process before operational implementation.	
End State	
Components optimize mission-critical processes with automation, reducing the time and resources spent, increasing accuracy (limiting human error) when validated, and supporting incident response.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Consider completing Activity 6.3.1 (Phase Two) – *Enterprise Security Profile Part 1* prior to this activity, to leverage security profiles when establishing an independent audit process.
- Presumption: Task automation efforts adhere to the Enterprise/Component security frameworks.
- Some manual task activities may remain non-retired and unsuitable for automation due to mission impacts and compatibility requirements.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.



Table 43: Implementation Tasks for Activity 6.2.1 — Task Automation Analysis

Identify and enumerate all task activities that can be executed both manually and/or automatically.
Identify, enumerate, and organize manual and automated tasks: ☐ Apply appropriate solutions to identify and categorize lists of manual and automated task activities across the Enterprise and within the Component environment, where applicable. ☐ Using the solutions in the previous step, organize task activities into manual and automated categories. ☐ Identify repetitive and predictable tasks from the task activity list. Establish an independent audit process for automated security tasks based on defined assessment criteria: ☐ Establish clear and measurable criteria against which the automated tasks will be audited. - These criteria should be derived from the security profiles, from Activity 6.1.3 (Phase Two) – <i>Enterprise Security Profile Part 1</i>, and align with relevant security policies and regulatory requirements. ☐ Examples of criteria include: - Effectiveness: Does the automated task achieve its intended security outcome? - Accuracy: Does the task perform its function correctly and reliably? - Efficiency: Does the task perform its function in a timely and resource-efficient manner? - Compliance: Does the task adhere to relevant security policies and regulations? - Logging and Monitoring: Does the task generate sufficient logs and metrics for monitoring and analysis? ☐ Analyze the audit results to ensure the task activities function as expected and are interoperable across the Enterprise and the Component environments before operational use.
Organize task activities from the manual and automated task activity lists into categories.
Analyze the manual and automated task activity lists and categorize the task activities appropriately: ☐ Monitor the Component environment to further understand the manual and automated task activities and categorize them appropriately and effectively. ☐ Normalize and maintain the manual and automated activity list categories for consistency based on the needs of the Enterprise and the Component. Prepare Enterprise and Component environments for cybersecurity defense strategy based on the task activity categories: ☐ Select appropriate cybersecurity solutions based on the policies and procedures of the Enterprise and Component environment. ☐ Leverage the cybersecurity solutions to fulfill the required functionality to manage the manual and automated task activities based on their determined categories.



Analyze manual task activities from the manual task activity list for retirement.

Assess the manual task activities and their respective categories in preparation for retirement:

- ☐ Evaluate manual task activity operational overhead (e.g., time, labor, resources, etc.).
 - Processing time and system resources.
 - System accuracy and effectiveness.
 - Potential User/Person Entity (PE)/Non-Person Entity (NPE) error(s).
 - Sustained operational functionality and performance metrics.
 - Verification and validation of cybersecurity posture.
- ☐ Based on the evaluation, create a list of manual task activities to be retired.
- ☐ If manual task activities are to be retired, ensure no loss of functionality within the Enterprise and Component environments prior to manual task activity retirement.
- ☐ Verify and validate that automated mechanisms are in place and operational before retiring any manual task activities, where applicable.

Create a process flow diagram for automated cybersecurity defense strategies to include an independent audit process before operational implementation.

Select a cybersecurity defense strategy based on the policies and procedures of the Enterprise and the Component:

- ☐ Enterprise and Component are encouraged to collaborate to establish the cybersecurity policies and procedures to meet environmental requirements.
- ☐ Choose an automated cybersecurity defense strategy, per the established policies and procedures of the Enterprise and the Component, that can depict process flow diagrams of the environment.

Conduct an independent audit process of the automated cybersecurity defense strategy before operational implementation:

- ☐ Audit the cybersecurity defense strategy to ensure effectiveness, Component environment readiness, and interoperability before operational implementation.

In preparation for implementation, create a process flow diagram for the automated cybersecurity defense strategy:

- ☐ Create a process flow diagram for the automated cybersecurity defense strategy.



Summary

This diagram outlines the Activity 6.2.1 (Discovery) – *Task Automation Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on identifying and enumerating automatable tasks within the Component. It presents strategic insights driving implementation and expected outcomes that include enumeration of tasks and identification of automatable tasks.

Table 44: Activity 6.2.1 — Task Automation Analysis - Workflow

 ZERO TRUST READINESS ASSESSMENT QUESTIONS
1. How are automatable tasks identified and enumerated within the Component?
 STRATEGIC INSIGHTS
• The Component defines manual and automated task activities by identifying, categorizing, and organizing tasks based on Enterprise and Component requirements. • The Component demonstrates compliance by developing an independent audit process to validate task functionality, ensuring interoperability before operational use. • The Component provides evidence through categorization and monitoring of manual and automated task activities, selecting cybersecurity solutions to support defined policies and procedures. • The Component leverages automation to reduce operational overhead, assess manual task retirement feasibility, and verify that functionality is maintained before transitioning tasks. • The Component ensures cybersecurity defense readiness by establishing process flow diagrams, conducting independent audits, and validating automated strategies before implementation.
 EXPECTED OUTCOMES
1. Automatable tasks are identified. 2. Tasks are enumerated. 3. Components create process flow of all cybersecurity defense automations tasks developed with an independent audit process before operational implementation.



Capability 6.5 Security Orchestration, Automation, and Response (SOAR)

Table 45: Capability 6.5 — Security Orchestration, Automation, and Response (SOAR)

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
6 - Automation and Orchestration	6.5 - Security Orchestration, Automation, and Response (SOAR)
Description	
DoW Components achieve initial operational capability of security technologies to orchestrate and automate policies (e.g., PEPs and PDPs) and rulesets to improve security operations, threat and vulnerability management, and security incident response by ingesting alert data, triggering playbooks for automated response and remediation.	
Impact to ZT	
Predefined playbooks from collection to incident response and triage enables initial process automation that accelerates a security team's decision and response speed.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component conducts a response automation analysis to identify repetitive and high-priority tasks in security operations, such as threat detection, vulnerability management, and Incident Response (IR).
- Security Orchestration, Automation, and Response (SOAR) solutions are implemented to centralize and automate the ingestion of alert data from security technologies, including Policy Enforcement Points (PEPs) and Policy Decision Points (PDPs).
- Predefined playbooks are developed for common security incidents, such as phishing attacks, malware detection, and unapproved access attempts, enabling consistent and efficient responses.
- During a routine security scan, a SOAR solution ingests an alert indicating anomalous network traffic, which is indicative of potential malware activity.
- The SOAR solution triggers a playbook that isolates the affected device, conducts a quick malware scan, and sends a notification to the Security Operations Center (SOC).
- The playbook gathers contextual data, such as recent device activity, User/Person Entity (PE) details, and threat intelligence, enriching the alert and reducing the time required for manual investigation.



NSA | Zero Trust Implementation Guideline Discovery Phase

- A vulnerability in a critical application is identified during threat management. The SOAR solution automates the remediation process by applying patches to affected systems and verifying and validating successful deployment.
- The SOAR solution integrates with the Component's policy orchestration framework to dynamically adjust PEP and PDP rulesets based on the threat level, blocking similar traffic patterns across the network.
- Analytics from SOAR processes are reviewed periodically to refine playbooks, ensuring they remain effective against evolving threats and vulnerabilities.
- By automating alert ingestion, triggering playbooks, and orchestrating policies, the Component accelerates response times, improves decision-making, and enhances its overall security posture.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- Increased Efficiency: Automating repetitive tasks reduces the burden on security teams, allowing them to focus on more complex issues.
- Accelerated IR: Predefined playbooks enable quicker reactions to security incidents, minimizing potential damage.
- Improved Decision-Making: Contextual data gathered during automated processes enhances the quality of decisions made by security teams.
- Enhanced Security Posture: Continuous monitoring and automated remediation help maintain a robust defense against evolving threats.

Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Endpoint Detection and Response (EDR)
- Extended Detection and Response (XDR)
- Policy Decision Points (PDPs)
- Policy Enforcement Points (PEPs)
- Security Orchestration, Automation, and Response (SOAR)
- Security Information and Event Management (SIEM)



Activity 6.5.1 Response Automation Analysis

Table 46: Activity 6.5.1 — Response Automation Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components identify and enumerate all response activities that are executed both manually and in an automated fashion. Response activities are organized into automated and manual categories.	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
- Automatable response activities are identified. - Response activities are enumerated.	
End State	
Components optimize response processes with automation, improving the response time for true positives and supporting a better awareness and understanding of security incidents.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Enterprise/Component should consider industry best practices when developing policies and procedures for response activity identification and automation.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 47: Implementation Tasks for Activity 6.5.1 — Response Automation Analysis

Identify and categorize all response activities executed manually and automatically within the Enterprise and Component environments.
Identify and categorize all response activities within the environment: ☐ Uniquely identify all response activities for all approved manual and automated response activities within the Enterprise and Component environments.



☐ Uniquely identify and create categorized criteria or elements for all manual and automated response activities within the Enterprise and Component environments.

☐ Verify and validate that categorization is comprehensive and accurate across Enterprise and Component environments.

Enumerate response activities to further understand security incidents.

Analyze categorized response activities to address security incidents and operational challenges:

☐ Leverage categorized response activities for all manual and automated response activities within the Enterprise and Component environments to improve awareness and handle incidents and challenges.

☐ Verify and validate that security incidents are handled in a timely and effective manner to ensure that threats and anomalies are addressed systematically and efficiently.

Optimize response processes with automation, where applicable.

Improve response time through response process automation:

☐ Enterprise and Component collaborate to automate Zero Trust (ZT) responses based on established policies, such as access revocation, network segmentation changes, and alerting.

☐ Integrate automated response tooling with existing Policy Enforcement Points (PEPs) to streamline security actions and ensure consistent application.



Summary

This diagram outlines the Activity 6.5.1 (Discovery) – *Response Automation Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on identification and categorization of response activities into automatable and manual tasks. It presents strategic insights driving implementation and expected outcomes that include enumeration of response activities and identification of automatable response activities.

Table 48: Activity 6.5.1 — Response Automation Analysis - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS
1. How are response activities identified and categorized into automatable and manual tasks?
STRATEGIC INSIGHTS
• The Component defines response activities by identifying and categorizing manual and automated security response processes across Enterprise and Component environments. • The Component demonstrates compliance by verifying and validating response categorization to ensure comprehensive coverage of security incidents and operational challenges. • The Component provides evidence through analysis of categorized response activities, ensuring security incidents are addressed systematically and efficiently. • The Component leverages automation solutions to optimize response processes, improve incident handling, and enhance security awareness across the environment. • The Component ensures continuous improvement by collaborating with the Enterprise to refine response automation, aligning with cybersecurity policies and procedures.
EXPECTED OUTCOMES
1. Automatable response activities are identified. 2. Response activities are enumerated.



Capability 6.6 Application Programming Interface (API) Standardization

Table 49: Capability 6.6 — Application Programming Interface (API) Standardization

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
6 - Automation and Orchestration	6.6 - Application Programming Interface (API) Standardization
Description	
DoW establishes and enforces enterprise-wide programmatic interface (e.g., API) standards; all non-compliant APIs are identified and replaced.	
Impact to ZT	
Standardizing APIs across the department improves application interfaces, enabling orchestration, and enhancing interoperability.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component conducts a tool compliance analysis to identify all existing Application Programming Interfaces (APIs) and evaluate their adherence to Enterprise-wide programmatic interface standards.
- A catalog of non-compliant APIs is created, prioritizing those that pose the highest security or operational risks for replacement or remediation.
- Standardized API schemas and calls are defined, ensuring all new and existing APIs meet the Component’s interoperability, security, and orchestration requirements.
- Developers are trained on the standardized API framework, ensuring they understand the required specifications and best practices for building compliant interfaces.
- An automated solution is deployed to monitor API traffic, flagging non-compliant API calls for review and notifying developers of policy violations.
- A legacy API used for a critical application is flagged as non-compliant. The Component replaces it with a standardized API, ensuring seamless integration and improved security controls.
- During a simulated attack, the standardized API framework detects and blocks a malformed API request, preventing the attacker from exploiting a vulnerability in the interface.



NSA | Zero Trust Implementation Guideline Discovery Phase

- Standardized APIs enable streamlined orchestration across applications, improving workflow automation and reducing development complexity for integrating systems.
- Regular audits of API compliance ensure that new APIs are built according to standardized schemas and that existing APIs are updated as needed to maintain compliance.
- By enforcing Enterprise-wide API standards, the Component enhances application interfaces, strengthens security, and ensures consistent interoperability across the department.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Security:** By enforcing standardized API protocols, Components can significantly reduce vulnerabilities and improve their security posture.
- **Improved Interoperability:** Standardized APIs facilitate seamless integration between different systems and applications, enhancing overall operational efficiency.
- **Reduced Development Complexity:** Developers benefit from clear guidelines and standards, which simplify the process of creating and maintaining APIs.
- **Streamlined Workflow Automation:** With standardized APIs, Components can automate workflows more effectively, leading to faster and more reliable processes.
- **Consistent Compliance Monitoring:** Regular audits and compliance checks ensure that all APIs adhere to established standards, reducing the risk of non-compliance and associated penalties.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- API Management solutions
- Cyber Threat Intelligence (CTI) ingestion from multiple approved sources
- Data Integration and Extract, Transform, Load (ETL)
- Interoperability Standards and Protocols
- Microservices APIs



Activity 6.6.1 Tool Compliance Analysis

Table 50: Activity 6.6.1 — Tool Compliance Analysis

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
Automation and Orchestration tooling and solutions are analyzed for compliance and capabilities based on the DoW Enterprise API machine-readable patterns and protocols.	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
Components API status is determined to be compliant or non-compliant to Enterprise API standards.	
End State	
Ensure tools include standardized API security with the proper protocols and capabilities to monitor, control access, and interoperate with other pillars.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Presumption: The Enterprise has established Application Programming Interface (API) standards for Automation and Orchestration tooling and solution compliance requirements.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 51: Implementation Tasks for Activity 6.6.1 — Tool Compliance Analysis

Analyze Automation and Orchestration tooling and solutions in accordance with Enterprise API standards to ensure compliance.
Evaluate tooling and solutions for compliance:
☐ Review Enterprise API standards.



☐ Determine which Automation and Orchestration tools should be reviewed for compliance across the Enterprise and Component environments.

☐ Ensure the tools adhere to Enterprise API security standards and protocols across the Enterprise and Component environments.

Based on the evaluation, determine if the tooling is compliant or non-compliant with Enterprise API standards:

☐ Define assessment criteria for evaluating tool compliance (e.g., proper protocols and capabilities to monitor, control access, interoperate with other pillars, etc.).

☐ Create a compliance checklist based on the identified Enterprise API standards and requirements.

☐ Using the checklist results, determine whether the Automation and Orchestration tooling and solutions are compliant or non-compliant.

Verify and validate that compliant Automation and Orchestration tooling capabilities have the required functionality.

Perform a technical evaluation of Automation and Orchestration tooling to confirm functionality:

☐ Test each compliant tool to verify and validate required functionalities (e.g., monitoring, access control, interoperability with other pillars, etc.).



Summary

This diagram outlines the Activity 6.6.1 (Discovery) – *Tool Compliance Analysis* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on the compliance of automation and orchestration tools using Application Programming Interface (API) standards. It presents strategic insights driving implementation and expected outcomes that include determination of API compliance or non-compliance status according to Enterprise API standards.

Table 52: Activity 6.6.1 — Tool Compliance Analysis - Workflow

ZERO TRUST READINESS ASSESSMENT QUESTIONS	
1. How is the compliance of automation and orchestration tools with DoW API standards assessed?	
STRATEGIC INSIGHTS	
• The Component defines Automation and Orchestration tooling requirements by evaluating solutions against Enterprise API security standards and compliance protocols. • The Component demonstrates compliance by assessing tooling capabilities using predefined criteria, creating a compliance checklist, and verifying adherence to Enterprise security policies. • The Component provides evidence through technical evaluations, validating that compliant solutions support monitoring, access control, and interoperability across security pillars. • The Component leverages Automation and Orchestration solutions to enhance security operations, streamline response processes, and improve integration with Enterprise environments. • The Component ensures continuous compliance by reviewing and updating tooling assessments, maintaining alignment with evolving Enterprise API standards and security requirements.	
EXPECTED OUTCOMES	
1. Components API status is determined to be compliant or non-compliant to Enterprise API standards.	



Visibility and Analytics Pillar

Capability 7.1 Log All Traffic (Network, Data, Apps, Users)

Table 53: Capability 7.1 — Log All Traffic (Network, Data, Apps, Users)

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Pillar	Capability
7 - Visibility and Analytics	7.1 - Log All Traffic (Network, Data, Apps, Users)
Description	
DoW Components collect and process all logs including network, data, application, device, and user logs and make those logs available to the appropriate Computer Network Defense Service Provider (CNDSP) or Security Operations Center (SOC). Logs and events follow a standardized format and rules/analytics are developed as needed.	
Impact to ZT	
Foundational to the development of automated hunt and incident response playbooks.	

Scenario

The following scenario illustrates the practical applications and considerations for this capability:

- The Component implements a logging framework to collect and process logs from all critical sources, including network, data, applications, and Users/Person Entities (PEs)/Non-Person Entities (NPEs).
- A standardized format for logs is established to ensure consistency across sources and enable efficient analysis by the Security Operations Center (SOC) and Computer Network Defense Service Provider (CNDSP)/Cybersecurity Service Provider (CSSP).
- Logging infrastructure is designed with scalability in mind, accounting for increased data volumes from expanding network, cloud, and application environments.
- Logs are parsed and normalized into a centralized system, enabling real-time correlation and analysis of events across multiple domains.
- The SOC configures automated analytics rules to detect anomalies, such as unusual login attempts, unexpected data transfers, or unauthorized access to sensitive applications.
- During routine monitoring, the analytics solution identifies anomalous traffic from a compromised User/PE account attempting to access restricted resources,



emphasizing the Zero Trust (ZT) focus on strict access controls and Least Privilege.

- An alert is generated and the SOC triggers a playbook to investigate, isolate the account, and prevent further unauthorized activity.
- Historical logs are reviewed to trace the origin of the compromise, revealing a phishing attempt that successfully stole the User/PE's credentials.
- The insights gained from log analysis are used to refine automated hunting playbooks and improve the detection of similar threats in the future.
- By collecting and processing logs from all traffic sources, the Component establishes a robust foundation for threat detection, proactive hunting, Incident Response (IR) and enhanced security visibility.

Positive Impacts

The below is not a comprehensive list of benefits, but rather a selection of the advantages fundamental to this capability:

- **Enhanced Threat Detection:** By collecting and analyzing logs from all critical sources, Components can quickly identify and respond to potential security threats.
- **Improved IR:** This capability enables effective IR through automated alerts and playbooks, thereby minimizing the impact of security incidents.
- **Standardized Logging Practices:** Establishing a standardized log format promotes consistency and efficiency in log analysis across different systems and devices.
- **Informed Decision-Making:** Insights gained from log analysis can inform security strategies and improve overall Component security posture.



Technology

The below is not a comprehensive list of technologies, but rather a selection fundamental to this capability:

- Intrusion Detection Systems (IDS)/Intrusion Prevention Systems (IPS)
- Log Management solutions
- Monitoring and Auditing solutions
- Network Flow Data
- Network Traffic Analysis (NTA)



Activity 7.1.1 Scale Considerations

Table 54: Activity 7.1.1 — Scale Considerations

DoW Zero Trust Framework	
Content in this table is sourced from authoritative DoW Zero Trust Framework documentation current at the time of publication.	
Description	
DoW Components conduct analysis to determine current and future scaling needs for monitoring, detection, and response. This requires a prioritization plan aligned with Component business/mission considerations and associated risk alignment. Scaling is analyzed following common industry best practices and aligns with ZT Pillar requirements. The team works with existing Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP) groups to determine distributed environment needs in emergencies and Component growth.	
Predecessor(s)	Successor(s)
None	None
Expected Outcomes	
- Evaluate opportunities for scaling (e.g., infrastructure sizing, bandwidth capacity, distributed environments) across the different pillars as it applies to visibility and analytics outcomes. - Create or utilize existing governance structure to operationalize the strategy.	
End State	
Analyze scaling needs for monitoring, detection, and response, aligning with business considerations, risk, industry best practices, and ZT Pillar requirements, while collaborating with BCP and DRP groups for distributed environment needs during emergencies and growth.	

Considerations

Below is a list of key prerequisites, potential challenges, and lessons learned that may influence the successful implementation of this activity. While informative, this list is not exhaustive, and its relevance may vary based on the specific environment and architecture.

- Ensure scaling strategies align with Zero Trust (ZT) Pillar requirements and industry best practices while balancing mission-critical priorities and risk considerations.
- Leverage existing governance structures, such as Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP), to support operationalizing the strategy efficiently and effectively.
- Continuously assess infrastructure and bandwidth capacity needs to accommodate both current operational demands and future growth, especially in distributed and emergency environments.

Implementation

The implementation table below provides practical, actionable recommendations to help Components achieve the expected outcomes of this activity. These recommendations are not prescriptive or mandatory, and their applicability may vary depending on the



specific environment and architecture. For a visual representation of the activity tasks covered in this section, refer to Appendix D.

Table 55: Implementation Tasks for Activity 7.1.1 — Scale Considerations

Conduct a comprehensive needs assessment in preparation for scaling.
Identify scaling requirements to perform a comprehensive needs assessment: ☐ Engage with stakeholders and partners to identify current and future requirements for scaling the ZT Architecture (ZTA), focusing on how core ZT principles and capabilities, such as Least Privilege access, micro-segmentation, and continuous verification, can be maintained and enhanced as the environment expands. ☐ Use the information gathered to conduct a comprehensive needs assessment that incorporates operational needs and aligns with ZT Pillar requirements. Analyze and prioritize existing Component environment in preparation for scaling: ☐ Evaluate the current Component infrastructure (e.g., bandwidth capacity, distributed environments, etc.) to understand limitations and risks in supporting the scalability and performance of the ZTA. ☐ Conduct a gap analysis to identify areas where the current architecture and infrastructure must be enhanced to effectively scale the ZT implementation and maintain its security posture as the environment expands [27]. ☐ Develop a prioritization plan for scaling the ZTA that aligns with mission and business continuity considerations, ensuring that risk mitigation efforts and resource allocation prioritize the most critical ZT capabilities and address the Component's essential business/mission needs.
Develop a scaling strategy aligned with ZT Pillar requirements.
Align the scaling strategy with ZT Pillar requirements: ☐ Adopt a phased approach to scaling the ZTA, prioritizing the most critical ZT capabilities and ensuring that each Phase maintains core ZT principles and strengthens the overall security posture. Verify and validate the effectiveness of each scaling Phase before proceeding to the next [27, 28]. Design scalable architecture(s) and integrate with the existing environment: ☐ Develop scalable architectures that seamlessly integrate ZT monitoring and analytics solutions with the existing security infrastructure. Ensure these integrations enhance, rather than hinder, the overall effectiveness of the ZT security posture as the environment scales [28, 29]. ☐ Develop a governance structure to oversee the scaling of the ZTA, incorporating policies that ensure the consistent application of ZT principles, maintain continuous monitoring and response capabilities, and effectively manage risks as the environment expands [28].
Collaborate with business continuity and disaster recovery teams to integrate scaling needs.
Review existing BCP and DRP group strategies: ☐ Coordinate with BCP and DRP teams to ensure scaling strategies are incorporated into emergency plans for distributed environments, ensuring resilience during scaling and/or disaster recovery [30].

**Integrate ZT considerations into BCP/DRP planning and execution:**

- ☐ Collaborate with BCP/DRP teams to ensure the resilience and availability of ZT capabilities during emergencies and disaster recovery.
- ☐ Update BCP/DRP plans to reflect scaling requirements and leverage Visibility and Analytics to inform decision-making and restore ZT security following a disruption.

Update BCP/DRP frameworks:

- ☐ Adjust existing plans to reflect the newly identified scaling needs, ensuring the integration of Visibility and Analytics Pillar outcomes support decision-making during emergency operations [31].



Summary

This diagram outlines the Activity 7.1.1 (Discovery) – *Scale Considerations* of the Department of War (DoW) Zero Trust (ZT) Framework, focusing on current and future logging requirements for scalability. It presents strategic insights that drive implementation and expected outcomes, including the evaluation of opportunities for scaling across the different pillars as they apply to the visibility and analytics outcomes.

Table 56: Activity 7.1.1 — Scale Considerations - Workflow

 ZERO TRUST READINESS ASSESSMENT QUESTIONS 1. How are current and future logging requirements analyzed for scalability within the DoW Components?
 STRATEGIC INSIGHTS • The Component defines and documents a comprehensive needs assessment framework for scaling, engaging stakeholders to identify current and future requirements for monitoring, detection, and response while ensuring alignment with ZT Pillar requirements. • The Component demonstrates readiness for scaling by analyzing and prioritizing its existing infrastructure, conducting gap analyses to identify areas for enhancement, and developing a prioritization plan that aligns scaling efforts with mission continuity and risk management. • The Component provides a structured scaling strategy that integrates with ZT principles, designing scalable architectures for analytics and monitoring while maintaining security, visibility, and interoperability across all infrastructure layers. • The Component leverages governance structures to oversee the implementation of the scaling strategy, incorporating policies for continuous monitoring, response capabilities, and risk management to ensure sustainable growth. • The Component ensures business continuity and disaster recovery preparedness by collaborating with relevant teams, updating frameworks to reflect new scaling needs, and integrating visibility and analytics outcomes into emergency decision-making processes.
 EXPECTED OUTCOMES 1. Evaluate opportunities for scaling (e.g., infrastructure sizing, bandwidth capacity, distributed environments) across the different pillars as it applies to visibility and analytics outcomes. 2. Create or utilize existing governance structure to operationalize the strategy.



Appendix A – Terms and Definitions

Terms and definitions used within this Zero Trust Implementation Guideline.

Access Control

The process of granting or denying specific requests to 1) obtain and use information and related information processing services and 2) enter specific physical facilities (e.g., federal buildings, military establishments, border crossing entrances).

Source: NIST Computer Security Resource Center (CSRC) Glossary

Access Management

Access Management is how an agency authenticates enterprise identities and authorizes appropriate access to protected services.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Alerts

Data that indicates some trigger or threshold passing event has occurred and which is transmitted from the managed device/service to the managing service. A notification that a specific attack has been detected or directed at an organization's information systems.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Analytics

Information resulting from the systematic analysis of data or statistics. This analysis includes discovering, interpreting, and communicating significant patterns in data.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Application Programming Interface

A system access point or library function that has a well-defined syntax and is accessible from application programs or user code to provide well-defined functionality.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Artificial Intelligence

The capability of computer processes to perform functions that are normally associated with human intelligence such as reasoning, learning and self-improvement.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Attribute-Based Access Control

An access control method where subject requests to perform operations on objects are granted or denied based on assigned attributes of the subject, assigned attributes of the object, environment conditions, and a set of policies that are specified in terms of those attributes and conditions.

Source: DoD Zero Trust Reference Architecture, Version 2.0



Authentication

Verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Automation

Ability to create and apply application technology to monitor and control the production and delivery of otherwise manual services.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Availability

Ensuring timely and reliable access to and use of information.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Behavior

Aggregate data from logs and reports that provides packet, flow, file, and other types of information, as well as certain kinds of threat data to figure out whether certain kinds of activity and behavior are likely to constitute a cyberattack.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Business Continuity Plan

The documentation of a predetermined set of instructions or procedures that describe how an organization's mission/business processes will be sustained during and after a significant disruption.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Capability

A combination of mutually reinforcing security and privacy controls implemented by technical, physical, and procedural means. Such controls are typically selected to achieve a common information security- or privacy-related purpose.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Certificate

A set of data that uniquely identifies a public key (which has a corresponding private key) and an owner that is authorized to use the key pair. The certificate contains the owner's public key and possibly other information and is digitally signed by a Certification Authority (i.e., a trusted party), thereby binding the public key to the owner.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Challenge

Additional or secondary question response from a user to confirm identity or further authenticate.

Source: DoD Zero Trust Reference Architecture, Version 2.0



NSA | Zero Trust Implementation Guideline Discovery Phase

Chief Information Officer

The senior official that provides advice and other assistance to the head of the agency and other senior management personnel of the agency to ensure that IT is acquired and information resources are managed for the agency in a manner that achieves the agency's strategic goals and information resources management goals; and is responsible for ensuring agency compliance with, and prompt, efficient, and effective implementation of, the information policies and information resources management responsibilities, including the reduction of information collection burdens on the public.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Code

Computer instructions and data definitions expressed in a programming language or in a form output by an assembler, compiler, or other translator.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Commercial Off-The-Shelf

Hardware and software IT products that are ready-made and available for purchase by the general public.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Communities of Interest

A collaborative group of users (working at the appropriate security level or levels) who exchange information in pursuit of their shared goals, interests, missions, or business processes, and must have a shared vocabulary for the information exchanged. The group exchanges information within and between systems.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Comply-to-Connect

Comply-to-Connect (C2C) is the identification, protection, and detection of DoDIN connected devices to ensure a continuous secure configuration. C2C enables the conduct of Defensive Cyber Operations in response to detected and prevailing threats by providing critical enabling information for the development of a Common Operating Picture. C2C standards are based on a framework of managing access to the network and its information resources by restricting or limiting access to those devices that do not comply with the standards.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Component

The organization implementing ZT.

Source: ZIG Primer

Concept of Operations

Verbal and graphic statement, in broad outline, of an organization's assumptions or intent in regard to an operation or series of operations of new, modified, or existing organizational systems.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Configuration

The possible conditions, parameters, and specifications with which an information system or system component can be described or arranged.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Configuration Management

A collection of activities focused on establishing and maintaining the integrity of information technology products and systems, through control of processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Continuous

Occur periodically without interruption during the ordinary performance of services.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Continuous Authentication

The ability validate network users are the ones who they claim to be throughout an entire session at every step.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Continuous Monitoring

The ability to determine if the complete set of planned, required, and deployed security controls within an information system or inherited by the system continue to be effective over time in light of the inevitable changes that occur.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Controlled Unclassified Information

Information that law, regulation, or government-wide policy requires to have safeguarding or disseminating controls, excluding information that is classified under Executive Order 13526, Classified National Security Information, December 29, 2009, or any predecessor or successor order, or the Atomic Energy Act of 1954, as amended.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Countermeasures

Actions, devices, procedures, techniques, or other measures that reduce the vulnerability of a system. Synonymous with security controls and safeguards.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Credential

An object or data structure that authoritatively binds an identity, via an identifier or identifiers, and (optionally) additional attributes, to at least one authenticator possessed and controlled by a subscriber.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Cyber Threat Intelligence

Cyber threat information that has been aggregated, transformed, analyzed, interpreted, or enriched to provide the necessary context for decision-making processes.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Cybersecurity Service Provider

A CSSP is an organization that provides one or more cybersecurity services to implement and protect the Department of Defense Information Network (DODIN).

Source: United States Cybersecurity Magazine

Data Catalog

Data Catalog contains descriptions and meta data about the data without itself holding that data.

Source: DoD Zero Reference Architecture, Version 2.0

Data Governance

Set of processes that ensures that data assets are formally managed throughout the enterprise. A data governance model establishes authority, management and decision-making parameters related to the data produced or managed by the enterprise.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Data Loss Prevention

A systems ability to identify, monitor, and protect data in use (e.g. endpoint actions), data in motion (e.g. network actions), and data at rest (e.g. data storage) through deep packet content inspection, contextual security analysis of transaction (attributes of originator, data object, medium, timing, recipient/destination, etc.), within a centralized management framework. Data loss prevention capabilities are designed to detect and prevent the unauthorized use and transmission of NSS information.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Data Plane

The data plane is used for communication between software components. This communication channel may not be possible before the path has been established via the control plane. For example, the control plane could be used by the PA and PEP to set up the communication path between the subject and the enterprise resource. The application/service workload would then use the data plane path that was established.

Source: NIST SP 800-207 Zero Trust Architecture

Data Rights Management

DRM is a set of access control technologies and policies that proactively detect and protect access to data and proprietary hardware and prevent unauthorized modification or redistribution of protected data.

Source: DoD Zero Trust Reference Architecture, Version 2.0



Defense Industrial Base

The U.S. Defense Industrial Base (DIB) is the network of organizations, facilities, and resources that provides the U.S. government—particularly the Department of Defense (DOD)—with defense-related materials, products, and services.

The DIB encompasses a wide variety of entities, including commercial firms operated on a for-profit basis, not-for-profit research centers and university laboratories, and government-owned industrial facilities. It provides everything from large, technologically sophisticated weapon systems and highly specialized operational support to general commercial products and routine services. By supplying and equipping the armed services, the DIB enables the United States to execute national strategy and develop, maintain, and project military power.

Source: Congress.Gov

Development, Security, Operations

A combination of software engineering methodologies, practices, and tools that unifies software development (Dev), security (Sec), and operations (Ops). It emphasizes collaboration across these disciplines, along with automation and continuous monitoring to support the delivery of secure, high-quality software. DevSecOps integrates security tools and practices into the development pipeline, emphasizes the automation of processes, and fosters a culture of shared responsibility for performance, security, and operational integrity throughout the entire software lifecycle, from development to deployment and beyond.

Source: DoD Enterprise DevSecOps Fundamentals, Version 2.5

Device

A combination of components that function together to serve a specific purpose.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Disaster Recovery Plan

A written plan for recovering one or more information systems at an alternate facility in response to a major hardware or software failure or destruction of facilities.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Dynamic

Occurring in near-real-time under conditions then present.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Enclave

A set of system resources that operate in the same security domain and that share the protection of a single, common, continuous security perimeter.

Source: NIST Computer Security Resource Center (CSRC) Glossary



NSA | Zero Trust Implementation Guideline Discovery Phase

Encryption

Cryptographic transformation of data (called “plaintext”) into a form (called “ciphertext”) that conceals the data’s original meaning to prevent it from being known or used. If the transformation is reversible, the corresponding reversal process is called “decryption,” which is a transformation that restores encrypted data to its original state.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Endpoint

Endpoint is role given to any devices capable of initiating or terminating a session on a network. Often described as end-user devices, such as mobile devices, laptops, and desktop machine. Hardware servers in data centers. Devices such as zero clients, virtualized systems, and infrastructure equipment (i.e. routers, switches, virtual desktop machine) are considered endpoints.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Endpoint Protection Platform

Safeguards implemented through software to protect end-user machines such as workstations and laptops against attack (e.g., antivirus, antispyware, antiadware, personal firewalls, host-based intrusion detection and prevention systems, etc.).

Source: NIST Computer Security Resource Center (CSRC) Glossary

Enterprise

The governing body that an organization falls under or reports to. The Enterprise is responsible for providing policies and guidance to those Components that fall under its purview.

Source: ZIG Primer

Enterprise Identity Provider

A service which provides state/status determination and access to Identity and Credential information. It may also provide baseline user/NPE access roles.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Executive Order

Legally binding orders given by the President, acting as the head of the Executive Branch, to Federal Administrative Agencies. Executive Orders are generally used to direct federal agencies and officials in their execution of congressionally established laws or policies.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Federal Information Processing Standards

A standard for adoption and use by federal departments and agencies that has been developed within the Information Technology Laboratory and published by NIST, a part of the U.S. Department of Commerce. A FIPS covers some topic in information technology to achieve a common level of quality or some level of interoperability.

Source: NIST Computer Security Resource Center (CSRC) Glossary



File Integrity Monitoring

Detecting any suspicious changes to files in a computer system.

Source: MITRE D3FEND

Health Insurance Portability and Accountability Act

A federal statute that called on the federal Department of Health and Human Services to establish regulatory standards to protect the privacy and security of individually identifiable health information.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Identification and Authentication

The process of establishing the identity of an entity interacting with a system.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Identity

The set of physical and behavioral characteristics by which an individual is uniquely recognizable.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Identity Lifecycle Management

The evolution of an identity from creation to deactivation.

Source: GSA Identity Lifecycle Management Playbook, Version 1.3

Identity Management

Identity Management is how an agency collects, verifies, and manages attributes to establish and maintain enterprise identities for employees and contractors.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Identity Provider

The party in a federation transaction that creates an assertion for the subscriber and transmits the assertion to the RP.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Identity and Access Management

Broadly refers to the administration of individual identities within a system, such as a company, a network or even a country. In enterprise IT, identity management is about establishing and managing the roles and access privileges of individual network users.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Identity, Credential, and Access Management

Programs, processes, technologies, and personnel used to create trusted digital identity representations of individuals and non-person entities (NPEs), bind those identities to credentials that may serve as a proxy for the individual or NPE in access transactions, and leverage the credentials to provide authorized access to an agency's resources. See also Attribute-Based Access Control (ABAC).

Source: NIST Computer Security Resource Center (CSRC) Glossary



Incident Response

The remediation or mitigation of violations of security policies and recommended practices.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Indicators of Compromise

Technical artifacts or observables that suggest that an attack is imminent or is currently underway or that a compromise may have already occurred.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Infrastructure as a Service

The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources where the consumer is able to deploy and run arbitrary software, which can include operating systems and applications. The consumer does not manage or control the underlying cloud infrastructure but has control over operating systems, storage, and deployed applications; and possibly limited control of select networking components (e.g., host firewalls).

Source: NIST Computer Security Resource Center (CSRC) Glossary

Integrity

Guarding against improper information modification or destruction and includes ensuring information nonrepudiation and authenticity.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Internet Protocol

Standard protocol for transmission of data from source to destinations in packet-switched communications networks and interconnected systems of such networks.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Internet Protocol Security

A protocol that adds security features to the standard IP protocol to provide confidentiality and integrity services.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Internet of Things

The network of devices that contain the hardware, software, firmware, and actuators which allow the devices to connect, interact, and freely exchange data and information.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Intrusion Prevention Systems

A system that can detect an intrusive activity and also attempt to stop the activity, ideally before it reaches its targets.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Inventory

A listing of items including identification and location information.

Source: NIST Computer Security Resource Center (CSRC) Glossary



NSA | Zero Trust Implementation Guideline Discovery Phase

Just-in-Time

Using the current values of all indicators and analytics as input to a policy decision or enforcement.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Key

A parameter used in conjunction with a cryptographic algorithm that determines the specific operation of that algorithm.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Least Privilege

A security principle that a system should restrict the access privileges of users (or processes acting on behalf of users) to the minimum necessary to accomplish assigned tasks.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Logs

Digital information that provided a history of events and states of a specific system or device.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Machine Learning

The development and use of computer systems that adapt and learn from data with the goal of improving accuracy.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Maintenance

Any act that either prevents the failure or malfunction of equipment or restores its operating capability.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Metadata

Information describing the characteristics of data including, for example, structural metadata describing data structures (e.g., data format, syntax, and semantics) and descriptive metadata describing data contents (e.g., information security labels).

Source: NIST Computer Security Resource Center (CSRC) Glossary

Micro-Segmentation

Micro-segmentation is the practice of dividing (isolating) the network into small logical segments by enabling granular access control, whereby users, applications, workloads and devices are segmented based on logical, not physical, attributes. This also provides an advantage over traditional perimeter security, as the smaller segments present a reduced attack surface (for malicious actors). In a ZT Architecture, security settings can be applied to different types of traffic, creating policies that limit network and application flows between workloads to those that are explicitly permitted.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Microservices

Small, decoupled components that ideally work independently of the other software components.

Source: GAO Agile Assessment Guide



Mobile Device Management

The administration of mobile devices such as smartphones, tablets, computers, laptops, and desktop computers. MDM is usually implemented through a third-party product that has management features for particular vendors of mobile devices.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Multi-Factor Authentication

Authentication using two or more factors to achieve authentication. Factors include: (i) something you know (e.g., password/Personal Identification Number [PIN]); (ii) something you have (e.g., cryptographic identification device, token); or (iii) something you are (e.g., biometric).

Source: NIST Computer Security Resource Center (CSRC) Glossary

National Security Systems

Any information system (including any telecommunications system) used or operated by an agency or by a contractor of an agency, or other organization on behalf of an agency— (i) the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions (excluding a system that is to be used for routine administrative and business applications, for example, payroll, finance, logistics, and personnel management applications); or (ii) is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive Order or an Act of Congress to be kept classified in the interest of national defense or foreign policy.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Network Access Control

A feature provided by some firewalls that allows access based on a user's credentials and the results of health checks performed on the telework client device.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Next-Generation Firewall

Allows integration of other tools to defend the network against malicious activity.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Non-Person Entity

An entity with a digital identity that acts in cyberspace but is not a human actor. This can include organizations, hardware devices, software applications, and information artifacts.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Operating System

The software “master control application” that runs the computer. It is the first program loaded when the computer is turned on, and its main component, the kernel, resides in memory at all times. The operating system sets the standards for all application programs (such as the Web server) that run in the computer. The applications communicate with the operating system for most user interface and file management operations.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Operational Technology

Programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems/devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Permission

Authorization to perform some action on a system.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Person Entity

The role a human actor (i.e., User) performs when accessing IT assets with a specific identify.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Personally Identifiable Information

Information applied to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Pillars

A Pillar is a key focus area for implementation of Zero Trust controls.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Platform as a Service

The capability provided to the consumer is to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages, libraries, services, and tools supported by the provider. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, or storage, but has control over the deployed applications and possibly configuration settings for the application-hosting environment.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Policy

Statements, rules, or assertions that specify the correct or expected behavior of an entity. For example, an authorization policy might specify the correct access control rules for a software component.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Policy Decision Point

Mechanism that examines requests to access resources and compares them to the policy that applies to all requests for accessing that resource to determine whether specific access should be granted to the particular requester who issued the request under consideration.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Policy Enforcement Point

This system is responsible for enabling, monitoring, and eventually terminating connections between a subject and an enterprise resource. The PEP communicates with the PA to forward requests and/or receive policy updates from the PA. This is a single logical component in ZTA but may be broken into two different components: the client (e.g., agent on a laptop) and resource side (e.g., gateway component in front of resource that controls access) or a single portal component that acts as a gatekeeper for communication paths.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Privileged User

A user that is authorized (and therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Public Key Infrastructure

A framework that is established to issue, maintain and revoke public key certificates.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Reference Architecture

An authoritative source of information about a specific subject area that guides and constrains the instantiations of multiple architectures and solutions.

Source: DoD Reference Architecture Description, Version 1.0

Resource

Resources are data, information, performers, materiel, or personnel types that are produced or consumed.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Risk Assessment

The process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of an information system. Part of risk management, incorporates threat and vulnerability analyses, and considers mitigations provided by security controls planned or in place. Synonymous with risk analysis.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Role-Based Access Control

Access control based on user roles (i.e., a collection of access authorizations a user receives based on an explicit or implicit assumption of a given role). Role permissions may be inherited through a role hierarchy and typically reflect the permissions needed to perform defined functions within an organization. A given role may apply to a single individual or to several individuals.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Secure Shell

A protocol for securely logging into a remote host and executing commands on that host (e.g., administrative commands).

Source: NIST IR7966 Security of Interactive and Automated Access Management Using Secure Shell (SSH)

Secure Sockets Layer

A protocol used for protecting private information during transmission via the Internet. Note: SSL works by using the service public key to encrypt a secret key that is used to encrypt the data that is transferred over the SSL session. Most web browsers support SSL and many web sites use the protocol to obtain confidential user information, such as credit card numbers. By convention, URLs that require an SSL connection start with "https:" instead of "http:". The default port for SSL is 443.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Security Information and Event Manager

Control log management system that helps filter the types of events and reduce alert fatigue.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Security Orchestration, Automation, and Response

A security strategy that has evolved in recent years to automate the IR process. Some of the state of practice applications of SOAR include threat detection and response, vulnerability prioritization, compliance checks, and security audits with potential applications in many emerging areas, such as IoT management.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Separation of Duty

Refers to the principle that no user should be given enough privileges to misuse the system on their own. For example, the person authorizing a paycheck should not also be the one who can prepare them. Separation of duties can be enforced either statically (by defining conflicting roles, i.e., roles which cannot be executed by the same user) or dynamically (by enforcing the control at access time). An example of dynamic separation of duty is the two-person rule. The first user to execute a two-person operation can be any authorized user, whereas the second user can be any authorized user different from the first [R.S. Sandhu, and P Samarati, "Access Control: Principles and Practice," IEEE Communications Magazine 32(9), September 1994, pp. 40-48.]. There are various types of SOD, an important one is history-based SOD that regulate for example, the same subject (role) cannot access the same object for variable number of times.

Source: NIST Computer Security Resource Center (CSRC) Glossary

**Service Provider**

A provider of basic services or value-added services for operation of a network; generally refers to public carriers and other commercial enterprises.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Simple Object Access Protocol

An XML-based protocol for exchanging structured information in a decentralized, distributed environment.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Software Defined Networking

The ability to separate the control and data planes and centrally manage and control the elements in the data plane.

Source: DoD Zero Trust Reference Architecture, Version 2.0

Supply Chain Risk Management

A systematic process for managing supply chain risk by identifying susceptibilities, vulnerabilities, and threats throughout the supply chain and developing mitigation strategies to combat those threats whether presented by the supplier, the supplies product and its subcomponents, or the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal).

Source: NIST Computer Security Resource Center (CSRC) Glossary

System

A discrete set of resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.

Source: NIST Computer Security Resource Center (CSRC) Glossary

System Owner

Person or organization having responsibility for the development, procurement, integration, modification, operation and maintenance, and/or final disposition of an information system.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Tailoring

The process by which security control baselines are modified by: identifying and designating common controls, applying scoping considerations on the applicability and implementation of baseline controls, selecting compensating security controls, assigning specific values to organization-defined security control parameters, supplementing baselines with additional security controls or control enhancements, and providing additional specification information for control implementation.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Telemetry

Telemetry is the automated collection of measurements or other data at remote points and their automatic transmission to receiving equipment for monitoring.

Source: DoD Zero Trust Reference Architecture, Version 2.0



Transmission Control Protocol

TCP is one of the main protocols in TCP/IP networks. Whereas the IP protocol deals only with packets, TCP enables two hosts to establish a connection and exchange streams of data. TCP guarantees the delivery of data and also guarantees that packets will be delivered in the same order in which they were sent.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Transport Layer Security

An authentication and encryption protocol widely implemented in browsers and Web servers. HTTP traffic transmitted using TLS is known as HTTPS.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Trusted Automated Exchange of Intelligence Information

An application layer protocol for exchanging Cyber Threat Intelligence over HTTPS.

Source: OASIS Cyber Threat Intelligence (CTI) Technical Committee

Zero Trust

A collection of concepts and ideas designed to minimize uncertainty in enforcing accurate, least privilege per-request access decisions in information systems and services in the face of a network viewed as compromised.

Source: NIST Computer Security Resource Center (CSRC) Glossary

Zero Trust Architecture

An enterprise's cybersecurity plan that utilizes zero trust concepts and encompasses component relationships, workflow planning, and access policies. Therefore, a zero trust enterprise is the network infrastructure (physical and virtual) and operational policies that are in place for an enterprise as a product of a zero trust architecture plan.

Source: NIST Computer Security Resource Center (CSRC) Glossary



Appendix B – Abbreviations and Acronyms

The following provides a complete list of abbreviated terms and acronyms used within this Zero Trust Implementation Guideline.

ABAC	Attribute-Based Access Control
AFID	Air Force Identity Database
AI	Artificial Intelligence
AM	Asset Management
AMID	Authoritative Mission Identity Database
API	Application Programming Interface
APM	Application Portfolio Management
AUP	Acceptable Use Policy
AV	Architecture View
BCP	Business Continuity Planning
C2C	Comply-to-Connect
cATO	Continuous Authorization to Operate
CBA	Capabilities-Based Assessment
CI/CD	Continuous Integration/Continuous Delivery (or Deployment)
CIKR	Critical Infrastructure and Key Resources
CIO	Chief Information Office
CISA	Cybersecurity and Infrastructure Security Agency
CISO	Chief Information Security Office
CMDB	Configuration Management Database
CNDSP	Computer Network Defense Service Provider
COI	Communities of Interest
CONOPS	Concept of Operations
COTS	Commercial Off-The-Shelf
CSI	Cybersecurity Information Sheet
CSRC	Computer Security Resource Center
CSSP	Cybersecurity Service Provider
CTI	Cyber Threat Intelligence
CUI	Controlled Unclassified Information
CyberOps	Cyber Operations
DAAS	Data, Applications, Assets, and Services
DBAC	Discretionary-Based Access Control
DCI	Defense Critical Infrastructure
DevSecOps	Development, Security, and Operations
DIB	Defense Industrial Base
DiU	Data in Use
DLP	Data Loss Prevention



NSA | Zero Trust Implementation Guideline Discovery Phase

DoD	Department of Defense
DoW	Department of War (authorized secondary title for the DoD)
DoW CIO	Department of War Chief Information Office (formerly DoD CIO)
DRM	Data Rights Management
DRP	Disaster Recovery Plan
EAM	Entity Activity Monitoring
EDR	Endpoint Detection and Response
EO	Executive Order
EPP	Endpoint Protection Platform
ETL	Extract, Transform, Load
FAM	File Activity Monitoring
FIM	File Integrity Monitoring
FIPS	Federal Information Processing Standards
GDPR	General Data Protection Regulation
GO	Global Orchestrator
GRC	Governance, Risk, and Compliance
HIPAA	Health Insurance Portability and Accountability Act
I/A RBAC	Identity, Attribute, Role-Based Access Control
IAM	Identity and Access Management
ICAM	Identity, Credential, and Access Management
ICD	Interface Control Document
ID	Identification
IdM	Identity Management
IdP	Identity Provider
IDS	Intrusion Detection System
IoC	Indicators of Compromise
IoT	Internet of Things
IP	Internet Protocol
IPS	Intrusion Prevention Systems
IPsec	Internet Protocol Security
IR	Incident Response
IT	Information Technology
ITAM	Information Technology Asset Management
JIT	Just-In-Time
LAN	Local Area Network
MDM	Mobile Device Management
MDR	Managed Detection and Response
ML	Machine Learning
NAC	Network Access Control
NextGen AV	Next-Generation Antivirus



NSA | Zero Trust Implementation Guideline Discovery Phase

NFV	Network Function Virtualization
NGFW	Next-Generation Firewall
NIS	Navy Identity Service
NIST	National Institute of Standards and Technology
NM	National Manager
NPE	Non-Person Entity
NSA	National Security Agency
NSM	National Security Memorandum
NSS	National Security Systems
NTA	Network Traffic Analysis
OSS	Operations Support System
OT	Operational Technology
PA	Policy Administrator
PaaS	Platform as a Service
PCI	Payment Card Industry
PCI DSS	Payment Card Industry Data Security Standard
PDP	Policy Decision Point
PE	Person Entity
PEP	Policy Enforcement Point
PfMO	Portfolio Management Office
PHI	Protected Health Information
PII	Personally Identifiable Information
PIN	Personal Identification Number
PKI	Public Key Infrastructure
PPSM	Ports, Protocols, and Services Management
RA	Reference Architecture
RBAC	Role-Based Access Control
REST	Representational State Transfer
RPA	Robotic Process Automation
SA	System Administrator
SaaS	Software as a Service
SALC	Software Acquisition Lifecycle
SAM	Software Asset Management
SCIM	System for Cross-domain Identity Management
SCM	Source Code Management
SDN	Software-Defined Networking
SecOps	Security Operations
SFTP	Secure File Transfer Protocol
SIEM	Security Information and Event Management
SME	Subject Matter Expert



NSA | Zero Trust Implementation Guideline Discovery Phase

SOAP	Simple Object Access Protocol
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
SP	Special Publication
SSH	Secure Shell
SSL	Secure Sockets Layer
STIX	Structured Threat Information eXpression
TAXII	Trusted Automated Exchange of Intelligence Information
TCP	Transmission Control Protocol
TIP	Threat Intelligence Platform
TLS	Transport Layer Security
UEDM	Unified Endpoint and Device Management
UEM	Unified Endpoint Management
USG	United States Government
VAULTIS	Visible, Assessable, Understandable, Linked, Trusted, Interoperable, and Secure
WAN	Wide Area Network
XDR	Extended Detection and Response
ZIG	Zero Trust Implementation Guideline
ZT	Zero Trust
ZTA	Zero Trust Architecture



Appendix C – References

- [1] Department of War. "Zero Trust Reference Architecture, Version 2.0." 2022. Available: [https://dodcio.defense.gov/Portals/0/Documents/Library/\(U\)ZT_RA_v2.0\(U\)_Sep22.pdf](https://dodcio.defense.gov/Portals/0/Documents/Library/(U)ZT_RA_v2.0(U)_Sep22.pdf)
- [2] Department of War Office of the Chief Information Officer. "Department of Defense Zero Trust Strategy, Version 1.0." 2022. Available: <https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf>
- [3] Department of War Office of the Chief Information Officer. "Department of Defense Zero Trust Capabilities and Activities, Dated 22 January 2025." 2024. Available: <https://dodcio.defense.gov/Portals/0/Documents/Library/ZT-CapabilitiesActivities.pdf?ver=-o9HgclD4LQHccIGjNQtiw%3d%3d>
- [4] National Security Agency. "CSI: Embracing a Zero Trust Security Model." 2021. Available: https://media.defense.gov/2021/Feb/25/2002588479/-1/-1/0/CSI_EMBRACING_ZT_SECURITY_MODEL_UOO115131-21.PDF
- [5] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the User Pillar." 2023. Available: https://media.defense.gov/2023/Mar/14/2003178390/-1/-1/0/CSI_Zero_Trust_User_Pillar_v1.1.PDF
- [6] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Device Pillar." 2023. Available: <https://media.defense.gov/2023/Oct/19/2003323562/-1/-1/0/CSI-DEVICE-PILLAR-ZERO-TRUST.PDF>
- [7] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Application & Workload Pillar." 2024. Available: <https://media.defense.gov/2024/May/22/2003470825/-1/-1/0/CSI-APPLICATION-AND-WORKLOAD-PILLAR.PDF>
- [8] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Data Pillar." 2024. Available: https://media.defense.gov/2024/Apr/09/2003434442/-1/-1/0/CSI_DATA_PILLAR_ZT.PDF
- [9] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Network & Environment Pillar." 2024. Available: <https://media.defense.gov/2024/Jul/10/2003500250/-1/-1/0/CSI-ZT-AUTOMATION-ORCHESTRATION-PILLAR.PDF>
- [10] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Automation & Orchestration Pillar." 2024. Available: <https://media.defense.gov/2024/Jul/10/2003500250/-1/-1/0/CSI-ZT-AUTOMATION-ORCHESTRATION-PILLAR.PDF>
- [11] National Security Agency. "CSI: Advancing Zero Trust Maturity Throughout the Visibility & Analytics Pillar." 2024. Available: <https://media.defense.gov/2024/May/30/2003475230/-1/-1/0/CSI-VISIBILITY-AND-ANALYTICS-PILLAR.PDF>
- [12] National Institute of Standards and Technology. "Computer Security Resource Center Glossary." 2021. Available: <https://csrc.nist.gov/glossary/>
- [13] National Institute of Standards and Technology. "Cybersecurity and Privacy Reference Tool: Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5.1.1), AC-02 Account Management." 2025. Available: https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_1/home?element=AC-02
- [14] National Institute of Standards and Technology. "Implementing a Zero Trust Architecture, NIST Special Publication 1800-35B, Third Preliminary Draft." 2023. Available: <https://www.nccoe.nist.gov/sites/default/files/2023-07/zta-nist-sp-1800-35b-preliminary-draft-3.pdf>



NSA | Zero Trust Implementation Guideline Discovery Phase

- [15] Sasha Kranjac and Omar Kudović. "Microsoft 365 Security and Compliance for Administrators." Packt Publishing. 2024. Available: <https://www.packtpub.com/en-us/product/microsoft-365-security-and-compliance-for-administrators-9781837638376>
- [16] National Institute of Standards and Technology. "Guide for Security-Focused Configuration Management of Information Systems, NIST Special Publication 800-128." U.S. Department of Commerce. 2019. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-128.pdf>
- [17] Avinash Naduvath. "In Zero Trust We Trust: A Practical Guide to Adopting Zero Trust Architectures." 2024. Available: <https://www.ciscopress.com/store/in-zero-trust-we-trust-9780138237400>
- [18] Dennis Drogseth, Rick Sturm, and Dan Twing. "CMDB Systems: Making Change Work in the Age of Cloud and Agile." 2015. Available: <https://www.oreilly.com/library/view/cmdb-systems/9780128012659/>
- [19] Department of War. "DoD Data Strategy: Unleashing Data to Advance the National Defense Strategy." 2020. Available: <https://media.defense.gov/2020/Oct/08/2002514180/-1/-1/0/DOD-DATA-STRATEGY.PDF>
- [20] Department of War Office of the Chief Information Officer. "Zero Trust Execution Roadmap, Version 1.1." 2024. Available: <https://dodcio.defense.gov/Portals/0/Documents/Library/ZT-ExecutionRoadmap-v1.1.pdf>
- [21] National Institute of Standards and Technology. "Cybersecurity Log Management Planning Guide, NIST Special Publication 800-92, Rev. 1, Initial Public Draft." U.S. Department of Commerce. 2023. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-92r1.ipd.pdf>
- [22] Microsoft Learn. "Learn About Data Loss Prevention." 2025. Available: <https://learn.microsoft.com/en-us/purview/dlp-learn-about-dlp>
- [23] Department of War Chief Digital and Artificial Intelligence Officer. "Department of Defense Metadata Guidance, Version 1.0." 2023. Available: <https://www.ai.mil/Portals/137/Documents/Resources%20Page/DoD%20Metadata%20Guidance.pdf>
- [24] Department of War. "DoD Instruction 8520.03: Identity Authentication for Information Systems." 2023. Available: <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/852003p.pdf>
- [25] Karen Scarfone and Murugiah Souppaya. "Data Classification Practices: Facilitating Data-Centric Security Management." 2021. Available: <https://www.nccoe.nist.gov/sites/default/files/legacy-files/data-classification-project-description-final.pdf>
- [26] Department of War Office of the Chief Information Officer. "DoD Instruction 8330.01: Interoperability of Information Technology, Including National Security Systems (NSS)." 2022. Available: <https://www.esd.whs.mil/portals/54/documents/dd/issuances/dodi/833001p.pdf>
- [27] National Institute of Standards and Technology. "Security and Privacy Controls for Information Systems and Organizations, NIST Special Publication 800-53, Rev. 5." 2020. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- [28] President Joseph R. Biden Jr. "Executive Order 14028, Improving the Nation's Cybersecurity." The White House. 2021. Available: <https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity>
- [29] National Institute of Standards and Technology. "Zero Trust Architecture, NIST Special Publication 800-207." 2020. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>



NSA | Zero Trust Implementation Guideline Discovery Phase

- [30] Federal Emergency Management Agency. "Guide to Continuity of Government for State, Local, Tribal, and Territorial Governments." 2021. Available: https://www.fema.gov/sites/default/files/documents/fema_slrt-cog-guidance_070921.pdf
- [31] National Institute of Standards and Technology. "Contingency Planning Guide for Federal Information Systems, NIST Special Publication 800-34, Rev. 1." 2010. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>
- [32] National Security Agency. "CTR: Zero Trust Implementation Guideline Primer, Version 1.0." 2026. Available: https://media.defense.gov/2026/Jan/08/2003852320/-1/-1/0/CTR_ZERO_TRUST_IMPLEMENTATION_GUIDELINE_PRIMER.PDF
- [33] United States Cybersecurity Magazine. "Department of Defense (DOD) Cybersecurity Service Providers (CSSPs): A Unique Component of DOD's Defense-in-Depth Strategy." n.d. Available: <https://www.uscybersecurity.net/dod/>
- [34] Congressional Research Service. "The U.S. Defense Industrial Base: Background and Issues for Congress." 2024. Available: <https://www.congress.gov/crs-product/R47751>
- [35] Department of War. "DoD Enterprise DevSecOps Fundamentals, Version 2.5." 2024. Available: <https://dodcio.defense.gov/Portals/0/Documents/Library/DoD%20Enterprise%20DevSecOps%20Fundamentals%20v2.5.pdf>
- [36] MITRE. "MITRE D3FEND." 2025. Available: <https://d3fend.mitre.org>
- [37] General Services Administration. "Identity Lifecycle Management Playbook, Version 1.3." 2024. Available: <https://www.idmanagement.gov/playbooks/ilm/#stage-2---provisioning--identity-governance-administration-iga>
- [38] Government Accountability Office. "Agile Assessment Guide: Best Practices for Adoption and Implementation." 2023. Available: <https://www.gao.gov/assets/d24105506.pdf>
- [39] Department of War Office of the Chief Information Officer. "DoD Reference Architecture Description." 2010. Available: https://dodcio.defense.gov/Portals/0/Documents/Ref_Archi_Description_Final_v1_18Jun10.pdf
- [40] National Institute of Standards and Technology. "Security of Interactive and Automated Access Management Using Secure Shell (SSH), NIST IR 7966." 2015. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2015/nist.ir.7966.pdf>
- [41] OASIS. "Introduction to TAXII." 2024. Available: <https://oasis-open.github.io/cti-documentation/taxii/intro.html>



Appendix D – Activity Task Diagrams

The Department of War (DoW) Chief Information Officer (CIO) Zero Trust (ZT) Framework defines 152 Activities (91 Target-level) that describe how organizations can implement ZT. The relationship between the implementation of these Activities is identified through DoW-defined predecessors and successors for each Activity. These Zero Trust Implementation Guidelines (ZIGs) provide a set of Implementation Tasks associated with DoW-defined ZT Activities to accomplish the Expected Outcomes and Capability intents.

In the ZIGs, the activities feature multiple tasks, with several predecessors and successors, leading to a complex and intricate implementation process. Additionally, dependency and constraint relationships between tasks within a single Activity or across different Activities add to this complexity. The following Activity Task Diagrams provide a non-linear, illustrative example of a one-to-one visualization of the Activity, beginning on the left with any defined predecessors, followed by the Activity tasks as outlined in the applicable Activity, and ending on the right with defined successors. A filled in circle at the beginning indicates that there is/are no DoW-defined predecessor(s) and a non-filled in circle at the end indicates there is/are no DoW-defined successor(s) for that particular Activity. The diagrams provide a standardized visual representation for navigating the implementation process. Appendix D begins with a linear graphic illustrating the Pillars and Activities, by both Pillar and Phase. This diagram serves as a reference guide to the subsequent Activity Task Diagrams.



NSA | Zero Trust Implementation Guideline Discovery Phase

Zero Trust Target Level Activities			
Pillar	Discovery	Phase I	Phase II
 USER	1.1.1 Inventory User	1.3.1 Organizational MFA & IdP 1.4.1 Implement System and Migrate Privileged Users Pt. 1 1.5.1 Organizational Identity Lifecycle Management 1.7.1 Deny User by Default Policy 1.8.1 Single Authentication	1.2.1 Implement App-Based Permissions per Enterprise 1.2.2 Rule-Based Dynamic Access Pt. I 1.4.2 Implement System and Migrate Privileged Users Pt. 2 1.5.2 Enterprise Identity Lifecycle Management Pt. 1 1.6.1 Implement UEBA & UAM Tooling 1.8.2 Periodic Authentication 1.9.1 Enterprise PKI & IdP Pt. 1
 DEVICE	2.1.1 Device Health Tool Gap Analysis 2.3.4 Integrate NextGen AV Tools w/C2C	2.1.2 NPE & PKI, Device Under Management 2.4.1 Deny Device by Default Policy 2.5.1 Implement Asset, Vulnerability, & Patch Management Tools 2.6.1 Implement UEDM or Equivalent Tools 2.6.2 Enterprise Device Management Pt. 1 2.7.1 Implement EDR Tools & Integrate w/C2C	2.1.3 Enterprise IdP Part 1 2.2.1 Implement C2C/Compliance-Based Network Authorization Pt. 1 2.3.3 Implement Application Control & FIM Tools 2.4.2 Managed & Limited BYOD & IoT Support 2.6.3 Enterprise Device Management Pt. 2 2.7.2 Implement XDR Tools & Integrate w/C2C Pt. 1
 APPLICATION & WORKLOAD	3.1.1 Application/Code Identification	3.2.1 Build DevSecOps Software Factory Pt. 1 3.2.2 Build DevSecOps Software Factory Pt. 2 3.3.1 Approved Binaries/Code 3.3.2 Vulnerability Management Program Pt. 1 3.4.1 Resource Authorization Pt. 1 3.4.3 SDC Resource Authorization Pt. 1	3.2.3 Automate Application Security & Code Remediation Pt. 1 3.3.3 Vulnerability Management Program Pt. 2 3.3.4 Continual Validation 3.4.2 Resource Authorization Pt. 2 3.4.4 SDC Resource Authorization Pt. 2
 DATA	4.1.1 Data Analysis 4.4.1 DLP Enforcement Point Logging & Analysis 4.4.2 DRM Enforcement Point Logging & Analysis	4.2.1 Define Data Tagging Standards 4.2.2 Interoperability Standards 4.3.1 Implement Data Tagging & Classification Tools 4.4.3 File Activity Monitoring Pt. 1 4.5.1 Implement DRM and Protection Tools Pt. 1 4.6.1 Implement Enforcement Points	4.2.3 Develop SDS Policy 4.3.2 Manual Data Tagging Pt. 1 4.4.4 File Activity Monitoring Pt. 2 4.5.2 Implement DRM & Protection Tools Pt. 2 4.5.3 DRM Enforcement via Data Tags & Analytics Pt. 1 4.6.2 DLP Enforcement via Data Tags & Analytics Pt. 1 4.7.1 Integrate DAAS Access w/SDS Policy Pt. 1 4.7.4 Integrate Solution(s) & Policy w/Enterprise IdP Pt. 1
 NETWORK & ENVIRONMENT	5.1.1 Define Granular Control Access Rules & Policies Pt. 1 5.2.1 Define SDN APIs	5.1.2 Define Granular Control Access Rules & Policies Pt. 2 5.2.2 Implement SDN Programmable Infrastructure 5.3.1 Datacenter Macro-Segmentation 5.4.1 Implement Micro-Segmentation	5.2.3 Segment Flows into Control, Management, & Data Planes 5.3.2 B/C/P/S Macro-Segmentation 5.4.2 Application & Device Micro-Segmentation 5.4.4 Protect Data in Transit
 AUTOMATION & ORCHESTRATION	6.1.1 Policy Inventory & Development 6.2.1 Task Automation Analysis 6.5.1 Response Automation Analysis 6.6.1 Tool Compliance Analysis	6.1.2 Organization Access Profile 6.5.2 Implement SOAR Tools 6.6.2 Standardized API Calls & Schemas Pt. 1 6.7.1 Workflow Enrichment Pt. 1	6.1.3 Enterprise Security Profile Pt. 1 6.2.2 Enterprise Integration & Workflow Provisioning Pt. 1 6.3.1 Implement Data Tagging & Classification ML Tools 6.6.3 Standardized API Calls & Schemas Pt. 2 6.7.2 Workflow Enrichment Pt. 2
 VISIBILITY & ANALYTICS	7.1.1 Scale Considerations	7.1.2 Log Parsing 7.2.1 Threat Alerting Pt. 1 7.2.4 Asset ID & Alert Correlation 7.3.1 Implement Analytics Tools 7.5.1 Cyber Threat Intelligence Program Pt. 1	7.1.3 Log Analysis 7.2.2 Threat Alerting Pt. 2 7.2.5 User & Device Baselines 7.3.2 Establish User Baseline Behavior 7.4.1 Baseline & Profiling Pt. 1 7.5.2 Cyber Threat Intelligence Program Pt. 2
Target Activities: 91			

Figure D-1: Target-level Activities by Pillar



Activity 1.1.1 Inventory User

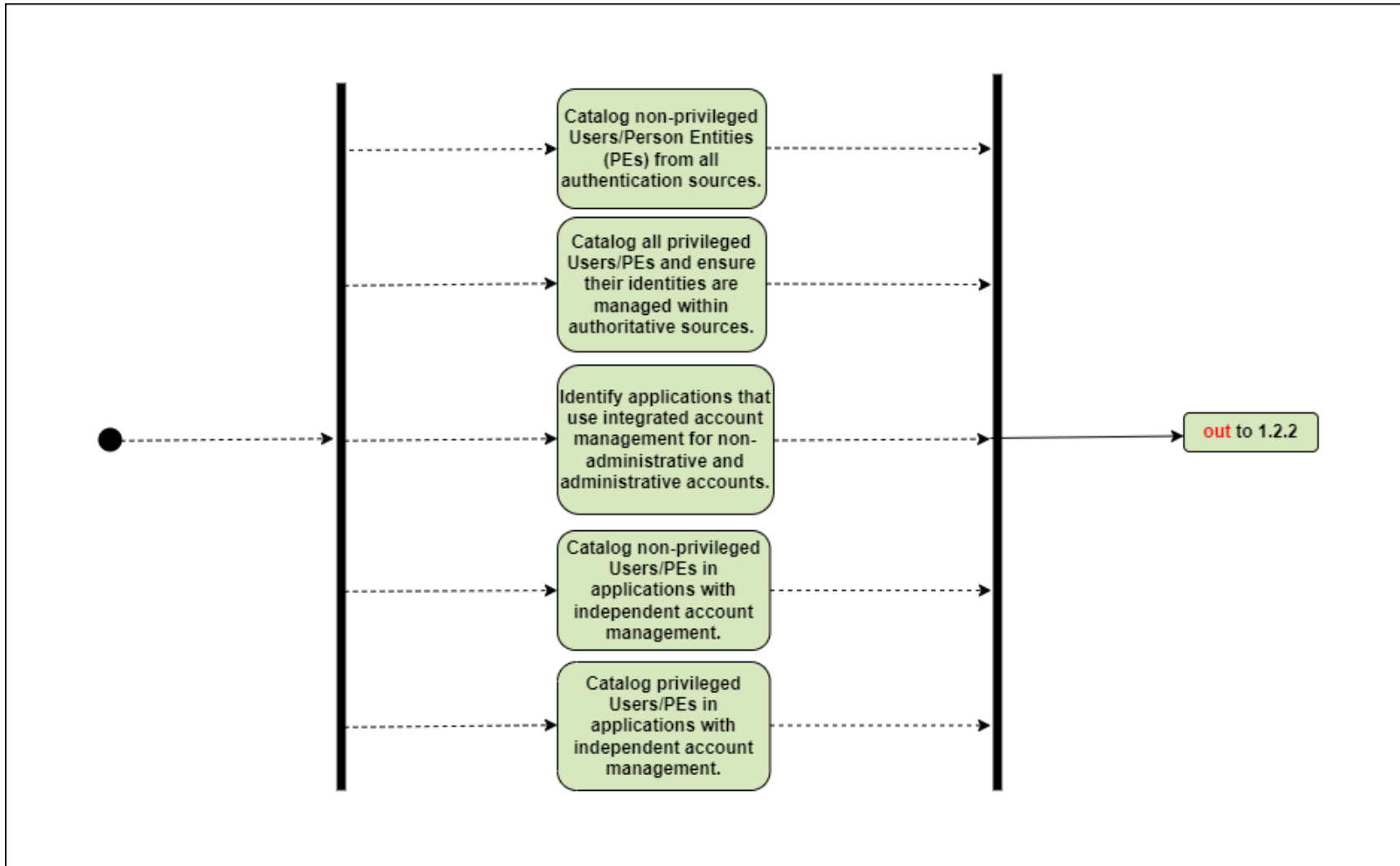


Figure D- 2: Implementation Tasks for Activity 1.1.1 — Inventory User



Activity 2.1.1 Device Health Tool Gap Analysis

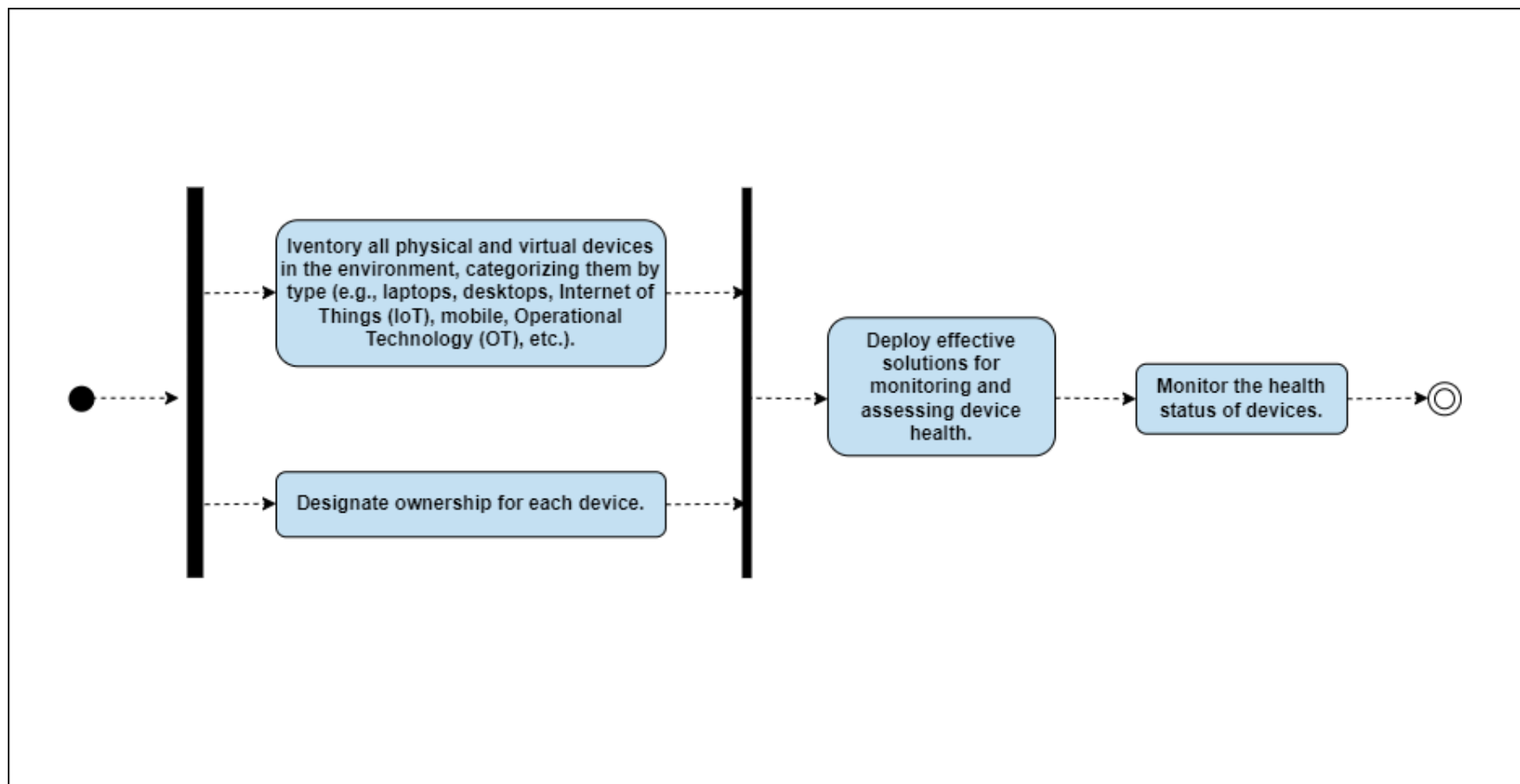


Figure D- 3: Implementation Tasks for Activity 2.1.1 — Device Health Tool Gap Analysis



Activity 2.3.4 Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)

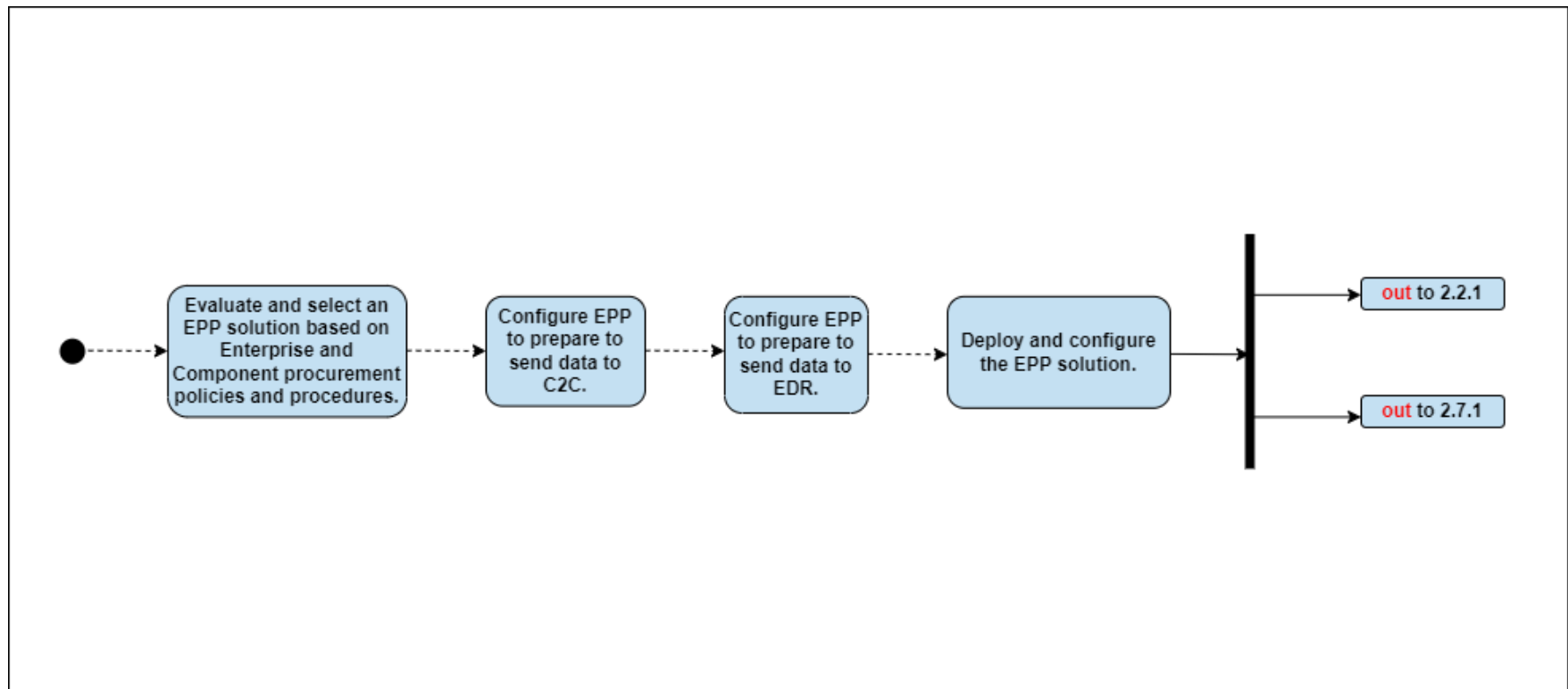


Figure D- 4: Implementation Tasks for Activity 2.3.4 — Integrate Next-Generation Antivirus (NextGen AV) Tools with Comply-to-Connect (C2C)



Activity 3.1.1 Application and Code Identification

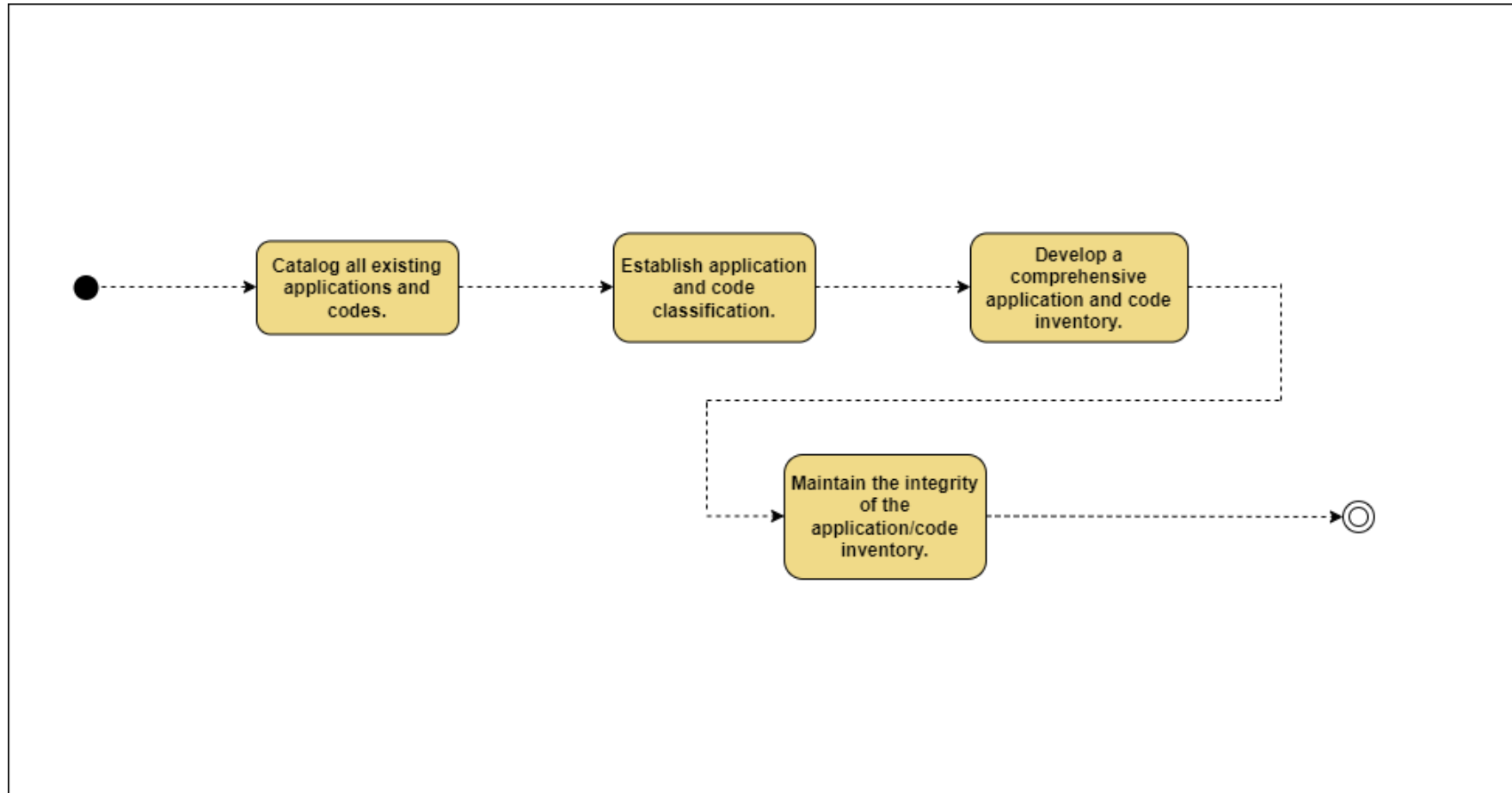


Figure D- 5: Implementation Tasks for Activity 3.1.1 — Application and Code Identification



Activity 4.1.1 Data Analysis

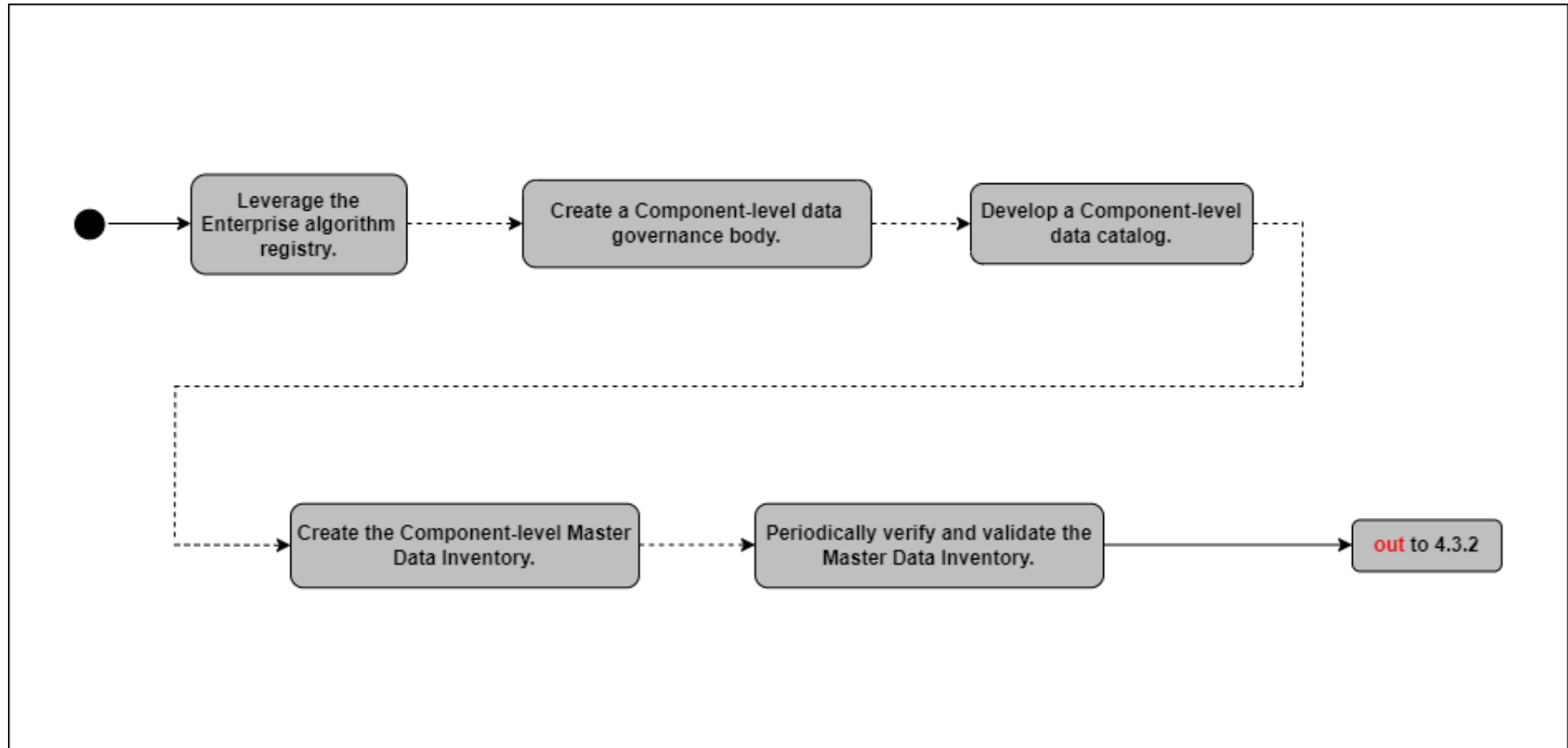


Figure D- 6: Implementation Tasks for Activity 4.1.1 — Data Analysis



Activity 4.4.1 Data Loss Prevention (DLP) Enforcement Point Logging and Analysis

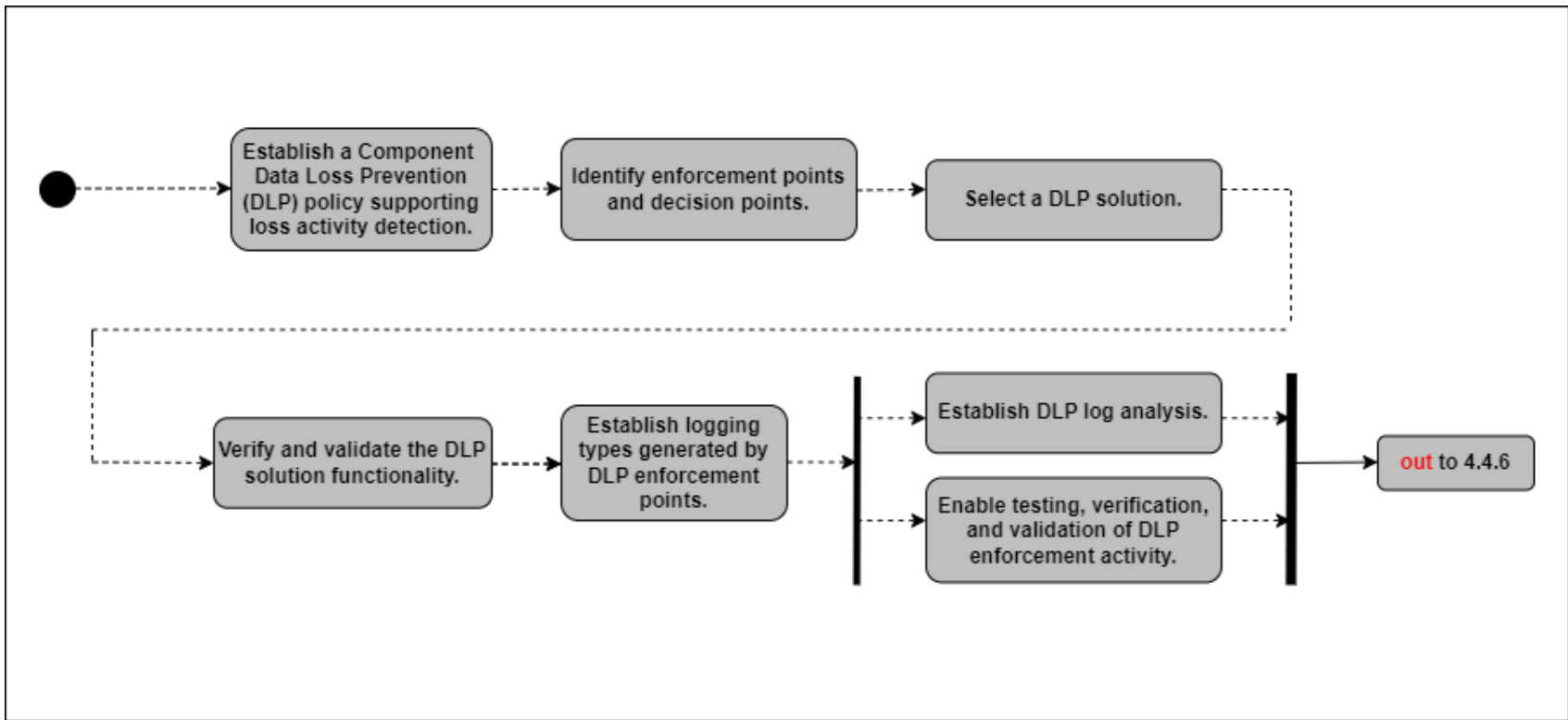


Figure D- 7: Implementation Tasks for Activity 4.4.1 — Data Loss Prevention (DLP) Enforcement Point Logging and Analysis



Activity 4.4.2 Data Rights Management (DRM) Enforcement Point Logging and Analysis

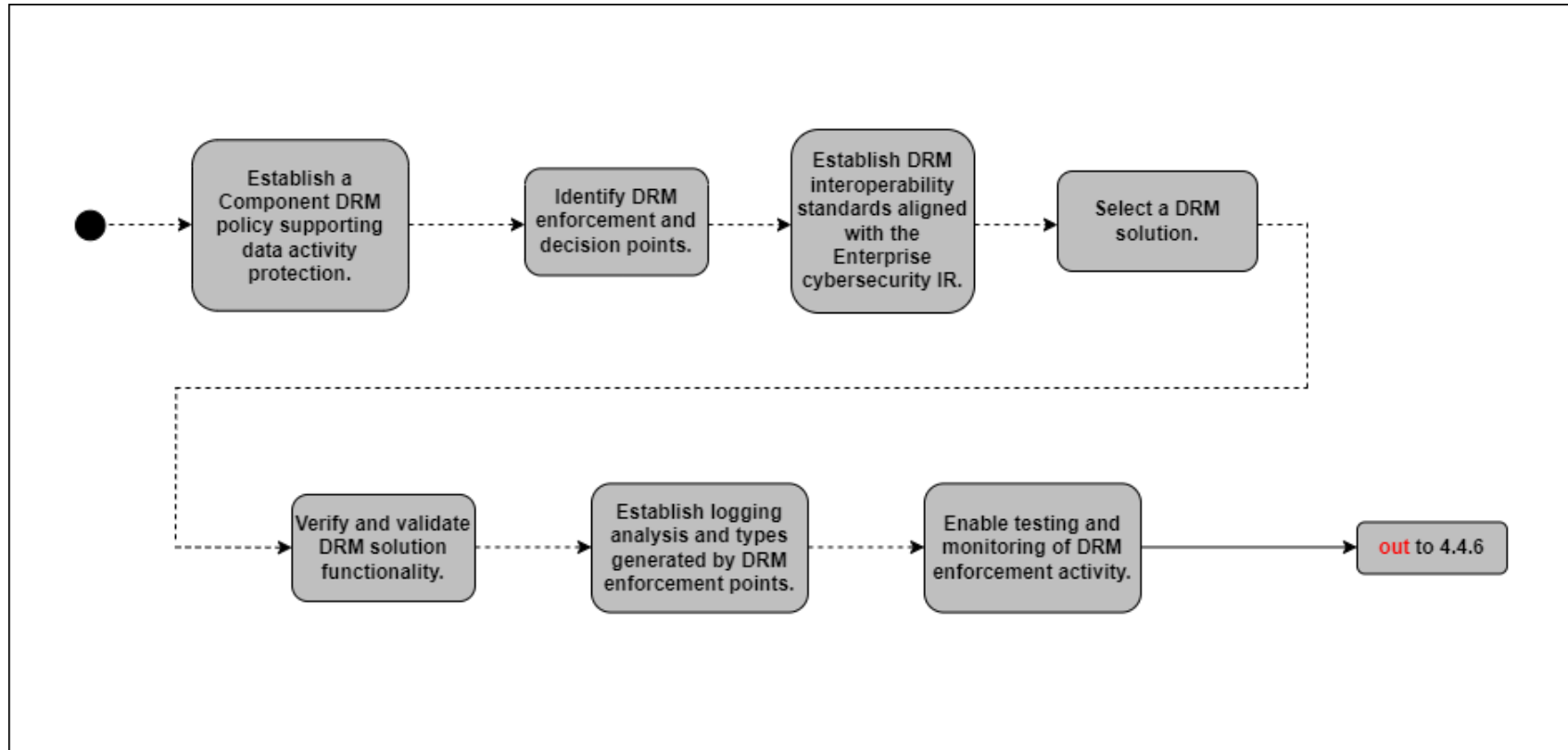


Figure D- 8: Implementation Tasks for Activity 4.4.2 — Data Rights Management (DRM) Enforcement Point Logging and Analysis



Activity 5.1.1 Define Granular Control Access Rules and Policies Part 1

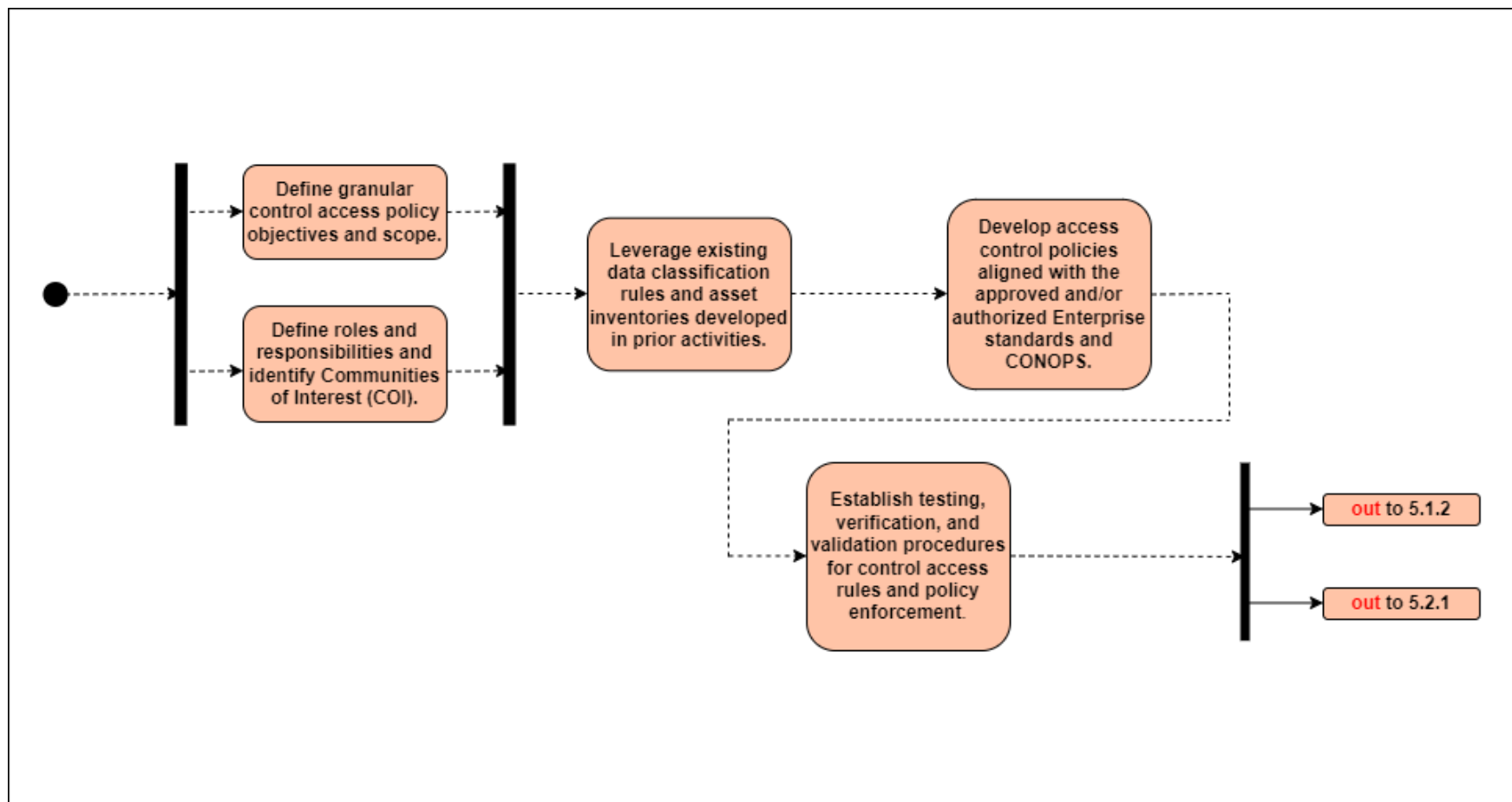


Figure D- 9: Implementation Tasks for Activity 5.1.1 — Define Granular Control Access Rules and Policies Part 1



Activity 5.2.1 Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)

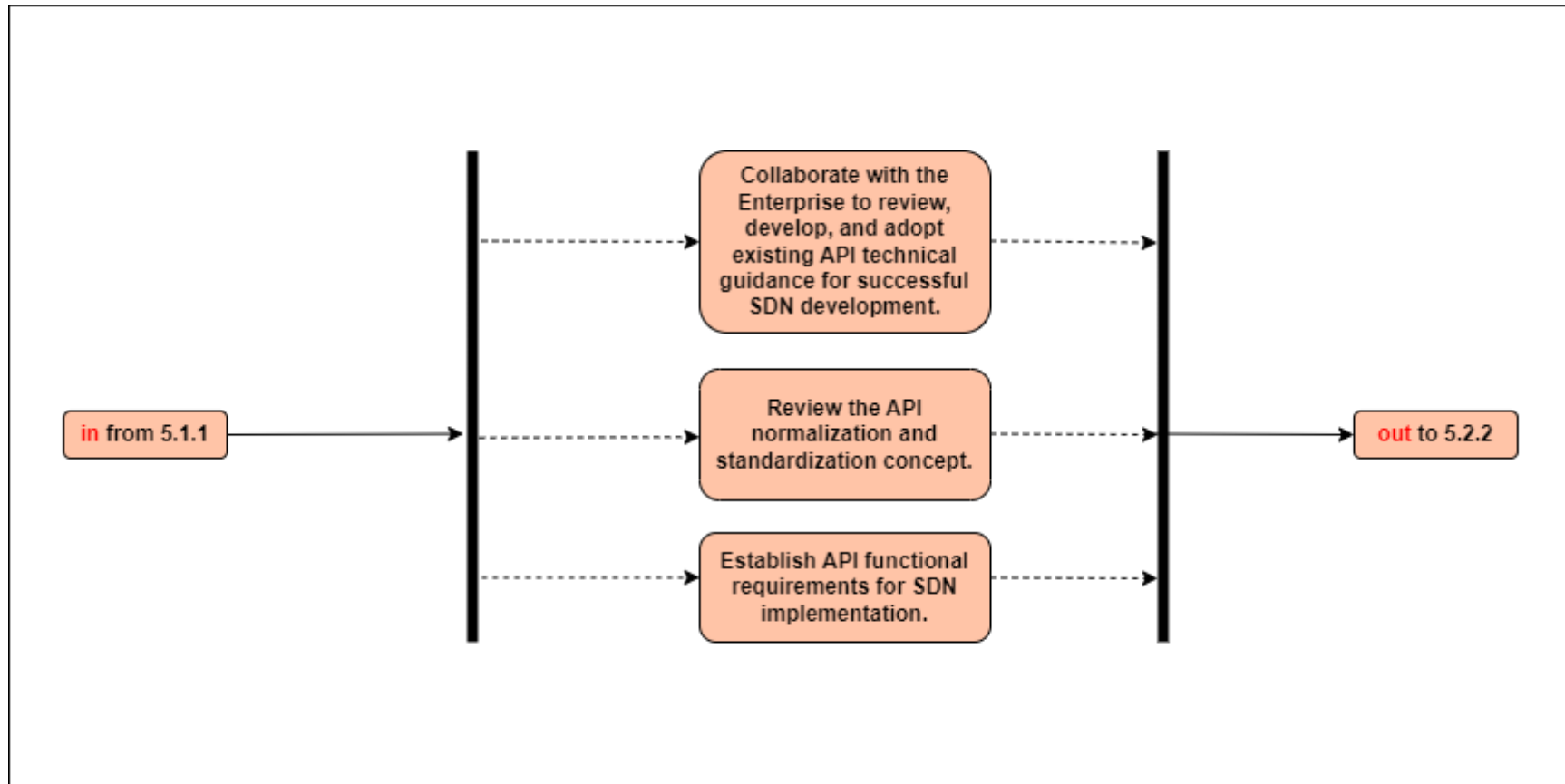


Figure D- 10: Implementation Tasks for Activity 5.2.1 — Define Software-Defined Networking (SDN) Application Programming Interfaces (APIs)



Activity 6.1.1 Policy Inventory and Development

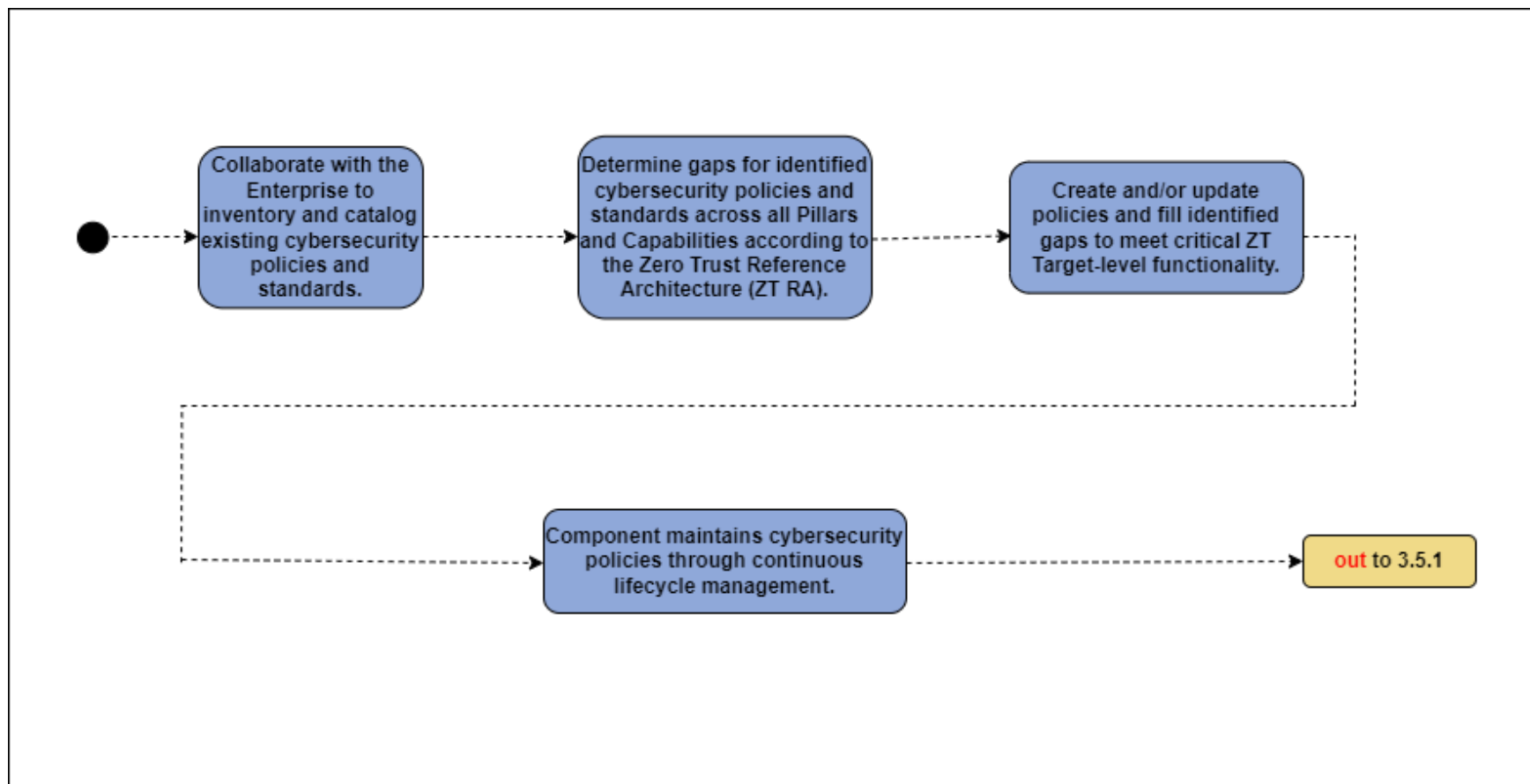


Figure D- 11: Implementation Tasks for Activity 6.1.1 — Policy Inventory and Development



Activity 6.2.1 Task Automation Analysis

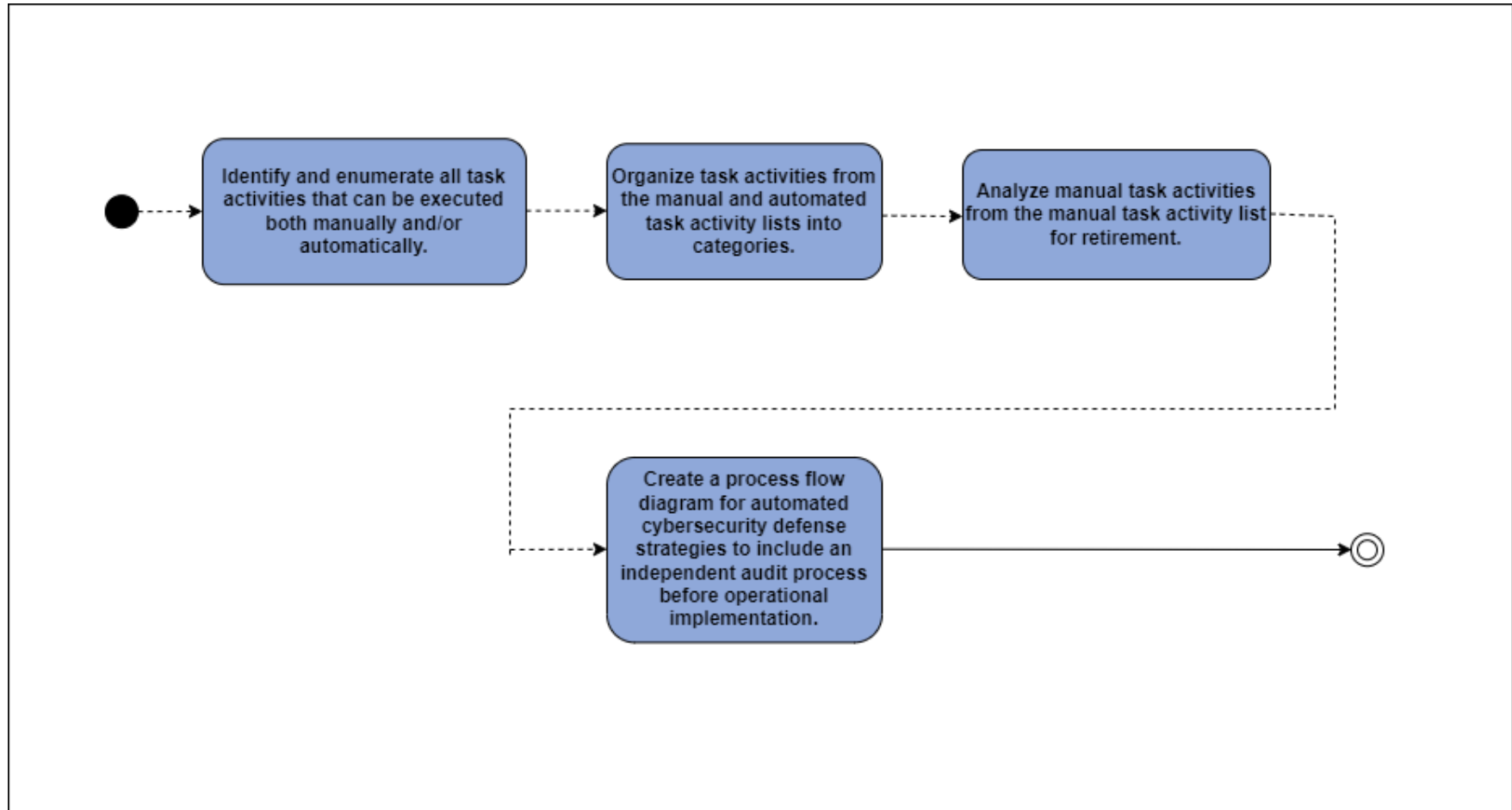


Figure D- 12: Implementation Tasks for Activity 6.2.1 — Task Automation Analysis



Activity 6.5.1 Response Automation Analysis

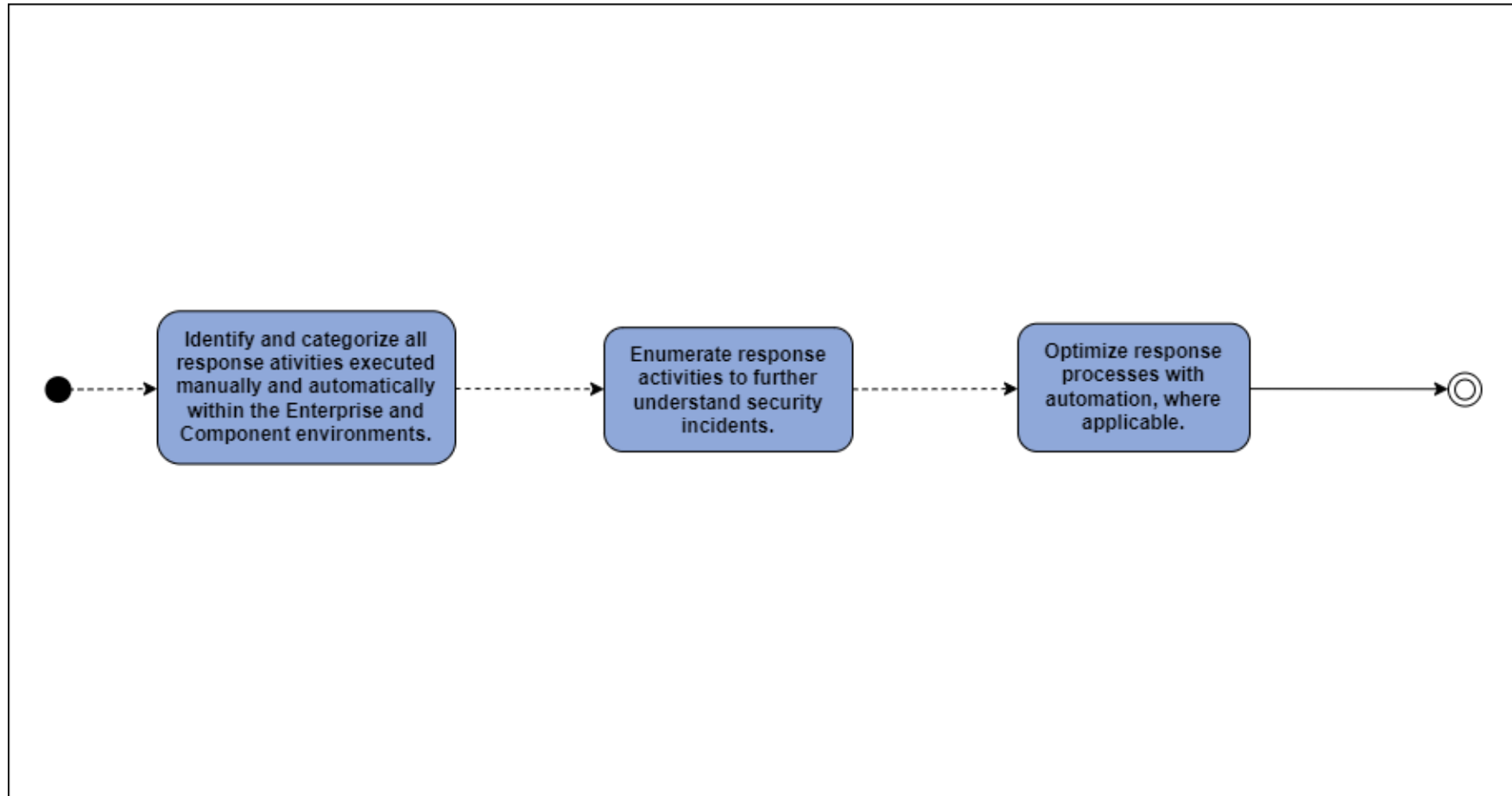


Figure D- 13: Implementation Tasks for Activity 6.5.1 — Response Automation Analysis



Activity 6.6.1 Tool Compliance Analysis

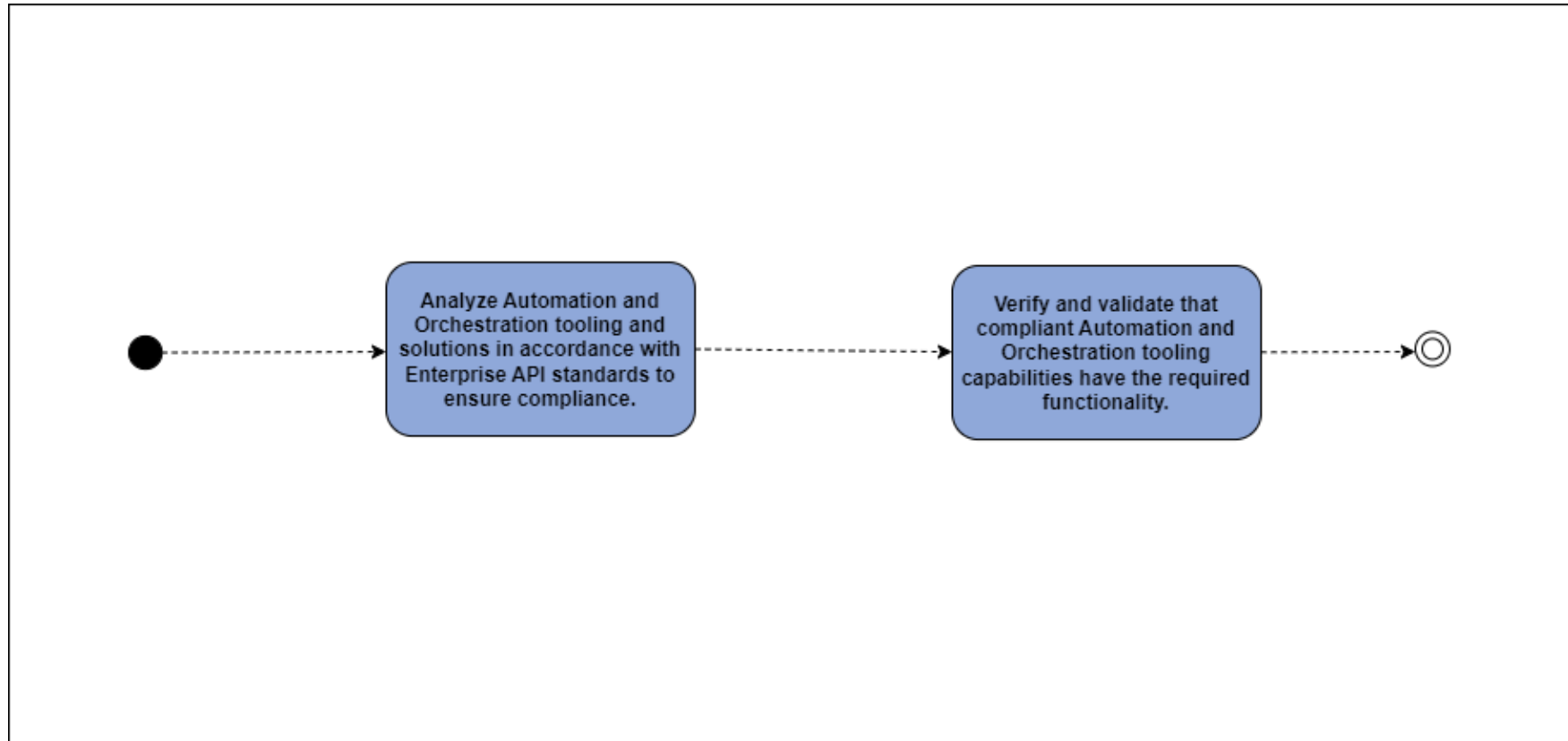


Figure D- 14: Implementation Tasks for Activity 6.6.1 — Tool Compliance Analysis



Activity 7.1.1 Scale Considerations

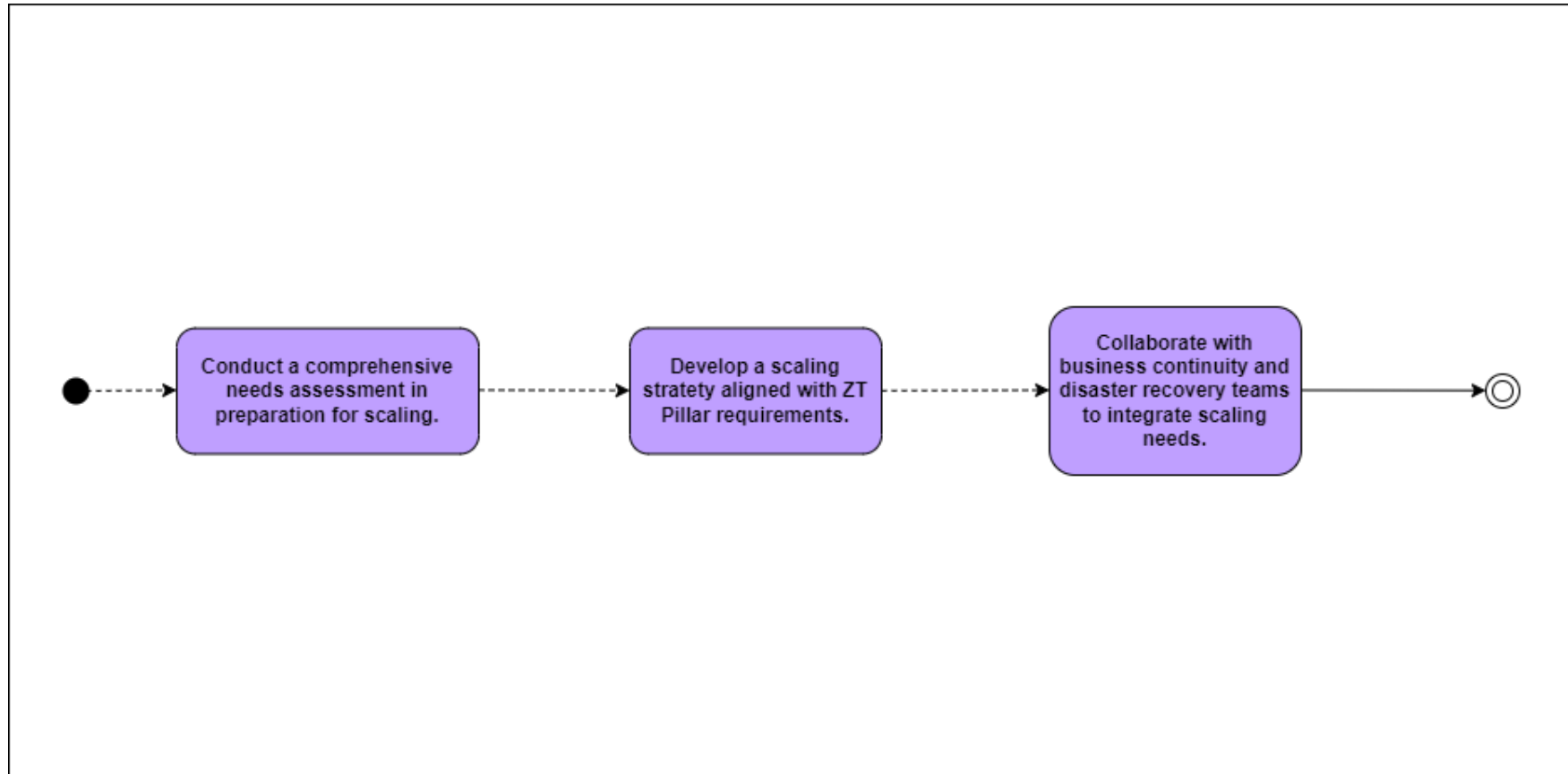


Figure D- 15: Implementation Tasks for Activity 7.1.1 — Scale Considerations